

# Bridging the Gap: A Survey and Classification of Research-informed Ethical Hacking Tools

Paolo Modesti, Lewis Golightly, Louis Holmes, Chidimma Opara, Marco Moscini

*Teesside University, Middlesbrough, United Kingdom*

---

## Abstract

The majority of Ethical Hacking (EH) tools utilised in penetration testing are developed by practitioners within the industry or underground communities. Similarly, academic researchers have also contributed to developing security tools. However, there appears to be limited awareness among practitioners of academic contributions in this domain, creating a significant gap between industry and academia's contributions to EH tools. This research paper aims to survey the current state of EH academic research, primarily focusing on research-informed security tools. We categorise these tools into process-based frameworks (such as PTES and Mitre ATT&CK) and knowledge-based frameworks (such as CyBOK and ACM CCS). This classification provides a comprehensive overview of novel, research-informed tools, considering their functionality and application areas. The analysis covers licensing, release dates, source code availability, development activity, and peer review status, providing valuable insights into the current state of research in this field.

*Keywords:* Ethical Hacking; Tools and Techniques; Research-informed, Classification; PTES; Mitre ATT&CK; CyBOK; ACM CCS

---

## 1. Introduction

In the domain of Ethical Hacking (EH), developing innovative tools is essential to tackle emerging threats and vulnerabilities. Ethical Hacking tools are designed mainly by industry practitioners, occasionally by underground communities [2], and sometimes even by state actors [3]. However, even experienced security developers may overlook critical requirements for such applications. An intriguing example is provided by Valenza et al. [4], challenging the conventional belief that remote scanning carries negligible risk. Their methodology, which transformed the scanning system into a target for counterattacks, revealed vulnerabilities in widely deployed tools, including Metasploit Pro. Overall, the researchers identified weaknesses in 36 out of 78 scanning applications.

The existing divide between industry and academia in developing EH tools reflects differing goals and approaches, highlighting a significant awareness gap. Industry practitioners are often insufficiently informed about the outcomes and insights generated by academic research in this field. Driven by immediate operational requirements, the industry tends to favour established tools and practices that promptly address real-time threats. However, this emphasis on practical application can result in a lack of awareness regarding significant academic contributions, such as novel methodologies and solutions for emerging threats or advancements in theoretical frameworks. Consequently, research findings may remain underutilised by industry practitioners.

One way to bridge the gap between industry and academia in developing EH tools is by producing in-depth survey papers that detail the tools created by both communities. However, existing surveys primarily assess

---

*Email addresses:* p.modesti@tees.ac.uk (Paolo Modesti), l.golightly@tees.ac.uk (Lewis Golightly), b1445121@tees.ac.uk (Louis Holmes), c.opara@tees.ac.uk (Chidimma Opara), m.moscini@tees.ac.uk (Marco Moscini)

This is the extended version of the published paper [1] is available at <https://doi.org/10.3390/jcp4030021>.

and compare tools used by industry practitioners, with only occasional consideration of research-informed tools [5, 6, 7]. This focus overlooks the innovative contributions from the research community.

Additionally, the quantity and breadth of tools reviewed by state-of-the-art surveys in EH tools are limited. For instance, the work by Altulaihan et al. [8] covered 15 papers for web application penetration testing, while Yaacoub et al. [6] reviewed 13 tools specifically applied to IoT. This limited scope restricts the comprehensive evaluation of EH tools. Moreover, existing surveys that classify EH methodologies or frameworks compare existing frameworks such as PTES or other industry methodologies like the Information Systems Security Assessment Framework (ISAF) [9]. However, they do not discuss the specific tools that fall under each category. This narrow focus fails to provide a holistic view of the EH tools landscape.

**Research Contributions** In light of these limitations, this paper makes two significant contributions:

1. *Survey of Research-Informed EH Tools*: this study surveys 100 research-informed EH tools developed in the last decade. It highlights key areas such as licensing, release dates, source code availability, development activity level, and peer review status. This analysis aims to provide insights into the state-of-the-art EH tools developed by the research community.
2. *Alignment with Recognised Frameworks*: this study categorises the tools into *process-based* frameworks, such as the *Penetration Testing Execution Standard* (PTES) [10], and the *Mitre ATT&CK framework* [11] and *knowledge-based* frameworks like the *National Cyber Security Centre’s Cyber Security Body Of Knowledge* (CyBOK) [12] and the *Association for Computing Machinery’s Computing Classification System* (ACM CCS) [13]. Combining these four classifications offers an informative view of the landscape of novel and research-informed ethical tools, their functionality, and application domain for the benefit of scholars, researchers, and practitioners.

This comprehensive approach not only bridges the gap between industry and academia but also ensures that Ethical Hacking tools evolve in tandem with the ever-changing cyber threat landscape.

**Outline of the Paper** Section 2 introduces the background of EH and the methodologies used by practitioners, Section 3 presents our research methodology, and Section 4 discusses the classification criteria applied to the EH tools. Section 5 discusses the tool categorisation into process-based and knowledge-based frameworks. Section 6 presents the systematic evaluation of research-informed EH tools, while Section 7 concludes the paper.

## 2. Background

In this section, we discuss the background and fundamentals of Ethical Hacking, including the motivations behind hacking systems and the different motivations of hackers categorised and represented using *hats*. Additionally, we introduce methodologies used in EH.

### 2.1. (Un)ethical Hacking Landscape and Motivations

Cyberattacks, intrusion techniques, social engineering, and information manipulation are increasingly becoming more sophisticated, targeting individuals and organisations. The objective of each attack, regardless of its nature, is to circumvent the three primary principles of security: *Confidentiality*, *Integrity*, and *Availability* [14]. There is a wide range of motivations for cyberattacks, and many factors interplay. According to [15, 16, 17, 18], the motivations for these attacks can be grouped into:

- *Economic Gain*: cybercriminals often target individuals, businesses, or organisations to extort money through ransomware [19] or financial fraud. Financial institutions such as banks and related services can be a target, as in the case of the attack on the Swift international transaction system [20].

- *Competitive Advantage and Sabotage*: competing companies, state-sponsored actors, and individuals can steal and reveal industrial secrets and intellectual properties to gain a competitive edge and compromise the data integrity and accessibility in businesses. While the WannaCry ransomware was used primarily to extort money from the victims, the attack on the UK National Health Service (NHS) could have also been done to demonstrate the business complacency and lack of digital transformation [19].
- *Personal Revenge*: cyberattacks driven by personal revenge are often perpetrated by disgruntled insiders or individuals with a vendetta against specific targets. These attacks leverage insider knowledge or access to inflict damage, disrupt operations, or steal sensitive data.
- *Political*: the attack is carried out as groups of hackers engaged in politics, sponsored-state hacking teams aiming at damaging specific targets. This includes governmental institutions, political parties, social society organisations and other public subjects. Examples are the alleged interference in the US presidential elections by Russian state-sponsored cyber actors in 2016 [21], and the *Operation Socialist* in 2010–2013 against Belgacom attributed to the UK’s GCHQ [22], a case of an attack perpetrated by a NATO member state against another one.

The activities described above broadly fall into the category of cybercrime and involve hacking, data theft, identity theft, financial fraud, and malware distribution. However, when cyberattacks are carried out by state-sponsored actors against other nations or entities, they are often called cyber warfare. The distinction can be blurred in some cases, as the direct involvement of government organisations can have surprising ramifications and side effects.

The *EternalBlue* exploit [23] was developed by the United States National Security Agency (NSA) targeting a vulnerability in Microsoft’s Windows operating system, specifically in the Server Message Block (SMB) protocol. The NSA utilised the exploit for years without reporting the vulnerability to Microsoft. However, it became widely known when a hacking group called the Shadow Brokers leaked the exploit in April 2017. The most notorious incident involving EternalBlue was the aforementioned WannaCry attack in May 2017. The exploit allowed the rapid spread of malware across networks, affecting hundreds of thousands of computers in over 150 countries and causing hundreds of millions of USD of damage worldwide.

This demonstrates the potential for unintended consequences and collateral damage as malicious actors can weaponise an offensive security tool developed by a government agency for large-scale cybercrime. This case also highlights the importance of responsible handling and disclosure of vulnerabilities by any entity, including government intelligence agencies.

## 2.2. Ethical Hacking

Ethical Hacking, also known as penetration testing, aims to identify vulnerabilities in computer systems, networks, and software applications before real-world attackers can exploit them. By uncovering weaknesses and providing recommendations for mitigation, EH helps organisations enhance their defences, protect sensitive data, and prevent unauthorised access. Ethical hackers utilise their skills to simulate potential cyberattacks and assess the security of a system. In fact, such specialists essentially utilise the same techniques as cyber attackers, with the important difference being that the system’s owner authorises them and agrees on the scope of the penetration testing exercise. As individuals capable of compromising systems, any misuse of their skills is criminally punishable according to the laws of various countries. The Budapest Convention on Cybercrime of 2001 (Article 6) [24], the EU Directive 2013/40 (Article 7) [25], and the UK Computer Misuse Act of 1990 (Section 3A) [26] are some of the legislations that regulate cybersecurity activities in terms of the improper use of personal capabilities, software, and hardware dedicated to unauthorised access to third-party information.

The key issue in determining the legality of hacking activities is avoiding actions that contravene the law. Hacking professionals must prioritise legal compliance to avoid prosecution. While the term *Legal Hacking* may more accurately describe this focus on legality, it is essential to recognise that legality does not always equate to ethical behaviour. Nevertheless, the term *Ethical Hacking* remains widely used, emphasising the importance of both legal compliance and ethical conduct in the profession.

### 2.3. Ethical Hackers

Traditional media often portrays hackers as mysterious figures, typically depicted wearing hoodies in dimly lit rooms, perpetuating a stereotype prevalent in pop culture. Hackers are commonly seen as computer pirates who infiltrate systems for personal or financial gain. However, historical context reveals a more nuanced understanding. According to the classic definition reported by Gehring [27], hackers enjoy the intellectual challenge of overcoming programming limitations and seeking to extend their capabilities. This definition, prevalent until the 1980s and intertwined with notions of democracy and freedom, has evolved, as discussed by Jaquet-Chiffelle and Loi [28]. *Hats* of different colours are broadly used as a symbolic representation of individuals based on their intentions and actions related to hacking [16]:

- *White Hat* (ethical): Embodies the principles of hacker culture by employing technical skills to proactively enhance system security measures. These individuals focus on identifying vulnerabilities and developing defensive strategies to mitigate potential risks.
- *Black Hat* (malicious): Represents individuals who maliciously exploit vulnerabilities within systems for personal gain or disruptive purposes. Their actions typically involve unauthorised access, data theft, and system manipulation, often resulting in financial losses or reputational damage for targeted entities.
- *Grey Hat* (undecided): Occupies an intermediary role, engaging in activities that blur the line between ethical and malicious hacking. These individuals engage in operations as both Black Hat and White Hat, depending on the circumstances [28].

According to [29, 17], further categories have been identified based on distinctive motivations and competencies from the original definition of hacker:

- *Red Hat*: Individuals dedicated to countering black hat hackers using offensive techniques rather than defensive ones [30].
- *Blue Hat*: People employed in companies that test software before release to find bugs [31].
- *Green Hat*: A category composed of people new to the hacking world [29].
- *Script Kiddie*: People with few hacking skills who use software already created by real hackers.
- *Hacktivist*: People who use hacking to promote political, social, or ideological manifestos [32].
- *Professional Criminals*: People with professional skills in security who use hacking to steal financial information.
- *Internals or Insiders*: People who usually attack their workplace for revenge or financial gain.

In recent years, cybersecurity and privacy protection have emerged as central themes for all organisations, and professional roles have arisen to address these needs. Penetration testing and malware analysis are among the sought-after roles in the cybersecurity job market, falling under the main category of EH.

### 2.4. Ethical Hacking Methodologies

Penetration Testing takes different forms and can cover various areas. Yaacoub et al. [15] describe the process of conducting an attack in five main phases:

- *Reconnaissance*: The hacker gathers information on systems and users through passive or active techniques. This includes physical methods like social engineering and analysing network packets to identify details such as network configuration, hardware, and security measures.

- *Scanning*: The hacker searches for vulnerabilities in systems through simulated tests, including identifying open ports, active hosts, and weak firewall configurations. Enumeration is then carried out to gather further information while maintaining an active connection.
- *Gaining Access*: The hacker attempts to access the system using penetration testing tools and techniques, aiming to bypass security measures.
- *Maintaining Access*: The hacker establishes backdoors or rootkits to maintain remote access with elevated privileges.
- *Covering Tracks*: The hacker eliminates evidence that could reveal their identity or traces of the attack.

Each phase is complex and crucial for the success of a cyber attack. Due to the unique nature of each system, there are no strict rules for systematically executing an attack or penetration test. However, various frameworks and methodologies have been developed to guide the penetration testing process in planning and executing cyber attack simulations.

These frameworks can be categorized into three main areas: open source, maintained by non-profit organisations or security institutes; industrial/governmental, maintained by government entities such as the National Institute of Standards and Technology (NIST); and proprietary, maintained by private companies and accessible through payment of a usage license.

#### 2.4.1. PTES

The *Penetration Testing Execution Standard* [10] was created in 2009 by a group of practitioners who developed this framework to provide both businesses and security service providers with a common language for conducting penetration tests. It comprises 7 phases: *Pre-engagement Interactions*, *Intelligence Gathering*, *Threat Modelling*, *Vulnerability Analysis*, *Exploitation*, *Post Exploitation*, and *Reporting*. The methodology is presented in detail in Section 4.1.

#### 2.4.2. Mitre ATT&CK

*Mitre Adversarial Tactics, Techniques, and Common Knowledge* [11] is a matrix that describes the behaviour of attackers throughout the life cycle of an operation. It covers *tactics, techniques, and procedures (TTP)* used by threat actors to achieve their objectives. Mitre is a non-profit American company involved in numerous cybersecurity standards and frameworks, such as *CVE (Common Vulnerabilities and Exposures)* [33] to identify and classify disclosed security vulnerabilities. *CWE (Common Weakness Enumeration)* [34] is used as a common language for weakness identification, prevention and mitigation. See Section 4.2 for the details of this methodology.

#### 2.4.3. PCI DSS Penetration Testing guidance

*Payment Card Industry Data Security Standard* (PCI DSS) [35] is a set of security requirements designed to protect payment card information during transactions. Developed by the PCI Security Standards Council, it applies to all organisations that accept, process, store, or transmit payment card data. PCI DSS establishes requirements for data security, network management, application protection, and other measures to prevent credit card fraud. The *Penetration Testing Guide* [36] is divided into four parts: *Penetration Tester Components*, *Qualification of a Penetration Tester*, *Methodology* and *Reporting and Documentation*. Organisations must comply with these requirements to ensure the security of credit card transactions and protect cardholders' sensitive data.

#### 2.4.4. ISSAF

The *Information Systems Security Assessment Framework* [37] is a standard supported by the Open Information System Security Group (OISSG). It incorporates all possible attack domains, and the main feature is that the penetration testing activity is divided into three phases: *Planning and Preparation*, *Assessment* and *Reporting, Cleanup, and Artefact Destruction*.

#### 2.4.5. OSSTMM

The *Open Source Security Testing Methodology Manual* [38] is a set of guidelines and procedures for conducting security tests and assessing the security of information systems. Developed by the Institute for Security and Open Methodologies (ISECOM), OSSTMM aims to provide an open-source standardised methodology for cybersecurity professionals. It focuses on testing operational security through five channels: *Human Security, Physical Security, Wireless Communications, Telecommunications, and Data Networks*.

#### 2.4.6. NIST800-115

*NIST800-115* [39] is a methodology published by the National Institute of Standards and Technology (NIST) in the United States. This standard provides detailed guidelines for conducting tests and assessments of information security in computer environments. It covers a wide range of security testing and assessment activities. The standard includes planning, information gathering, vulnerability analysis, test execution, risk assessment, and documentation. It offers practical and detailed recommendations for performing various tests, including tool selection and management of information collected during the testing process. Although published by NIST, the standard is designed to be adopted in both the public and private sectors, providing a flexible framework that can be applied to different environments.

#### 2.4.7. OWASP

The *Open Worldwide Application Security Project* [40] was launched in 2001 as an open-source project that provides guidelines, tools, and methodologies to improve the security of applications, collected into a guide named OTG 4.0 (*Owasp Testing Guide*) [41]. This document is divided into five parts: *Before development begins, During definition and design, During development, During deployment and Maintenance and operations*. By completing these procedures, developers can significantly reduce the risk of data breaches caused by attacks facilitated by poor code quality.

### 3. Survey Methodology

A three-step approach was devised to investigate Ethical Hacking tools developed by the research community over the past decade (Figure 1). First, clear guidelines were established to determine the inclusion of tools in the survey. Second, relevant papers and tools satisfying the above criteria were identified. Finally, these tools were categorised based on established cybersecurity frameworks.

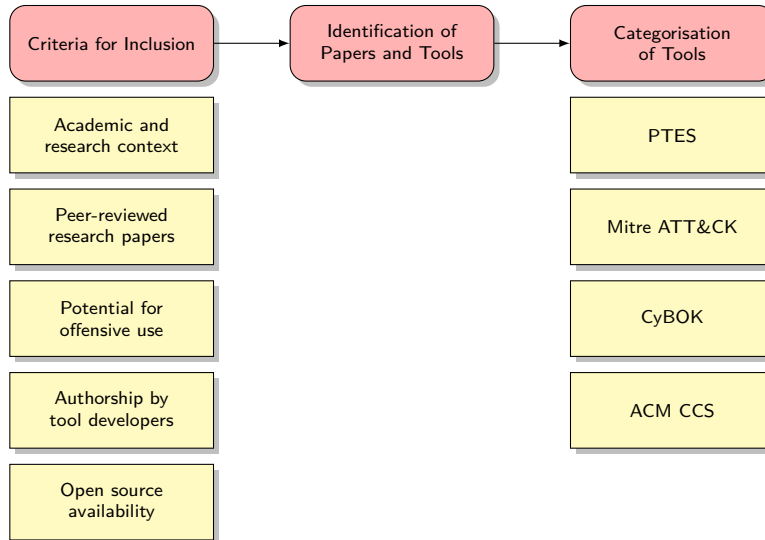


Figure 1: Survey Methodology

### 3.1. Criteria for Inclusion of Ethical Hacking Tools in the Paper

This survey established specific conditions to determine the inclusion of state-of-the-art EH tools in the paper. The following criteria were adhered to:

- *Academic and research context:* The tool has been developed within an academic/research project: this excludes any tools developed primarily as practitioner tools (e.g. they are included in a popular EH distribution, like Kali Linux).
- *Peer-reviewed research papers:* Each EH tool included in the survey must be published in a peer-reviewed venue. Peer review validates the tool’s architecture, functionalities, and relevance.
- *Potential for offensive use:* The tool has at least the potential to be used in an offensive context even if authors do not state that explicitly, as the tool could have been developed for another purpose (e.g. software testing, supporting software or system development).
- *Authorship by tool developers:* The survey also requires that the authors of the papers have designed/developed the tool. This criterion ensures credibility and depth of insight, as the creators are directly involved in its conception and development.
- *Open source availability:* The tool should be open source, and the source code (or distribution package) should be freely available. However, this requirement was relaxed throughout the research as we acknowledge that some tools may not be open-source for various reasons, such as proprietary nature, pending patents, or limited accessibility.

### 3.2. Collating Research-Informed Ethical Hacking Tools

The inclusion of 100 EH tools was driven by the aim of achieving a balance between depth and breadth in our analysis. The selection process was systematic and rigorous, inspired by the PRISMA methodology [42], with identification, screening and inclusion phases.

Initially, we initiated a collaborative research project involving cohorts of students from the MSc Cybersecurity program at Teesside University (United Kingdom). Despite the absence of a dedicated module on EH in their curriculum, the students showed considerable interest in working within this domain. This project allowed them to integrate EH professionalism with their research interests.

The students’ initial submissions yielded over 200 academic references. However, after a careful review process conducted by the authors, approximately 30 tools aligned with the research scope and were included in this paper. Many tools found by the students were excluded for these reasons:

- Difficulty of the students in distinguishing between research-informed and practitioner tools.
- Confusion between papers describing the design and implementation of a tool and those describing its application.
- The approach of identifying tools first and then searching for papers to support the findings leads to the above misconceptions.

Following the criteria outlined in Section 3.1, the authors expanded the total count of EH tools to 185. These tools were then resampled, and 100 tools were finally selected. The final selection was based not only on adherence to the criteria in Section 3.1 but also on the fact that these tools were not merely applications of existing methodologies, frameworks, or aggregations of practitioner tools.

In fact, among the 85 candidates excluded in the final round, 28 focused on mitigation tools and techniques, 18 on methodologies and frameworks, 14 on the application of practitioner tools, 13 were surveys, 5 addressed socio-technical aspects, 4 were simulation tools, and 3 focused on education.

For details of the 100 tools surveyed in this paper, see Table 1.

Moreover, as discussed in Section 6, to include a significant number of tools that could reflect the current state of the art, we had to relax on the criteria of availability of the source code. Therefore, in this survey, we have 41 tools that satisfy all other criteria, but no source code has been published.

For a detailed description of each tool included in this survey, please refer to Appendix C.

### 3.3. Classification of Identified Ethical Hacking Tools

In the second phase of the research, the identified EH tools were classified according to established cybersecurity frameworks. This task was undertaken by the authors, who have extensive expertise in EH from years of teaching, research, and professional experience in the field.

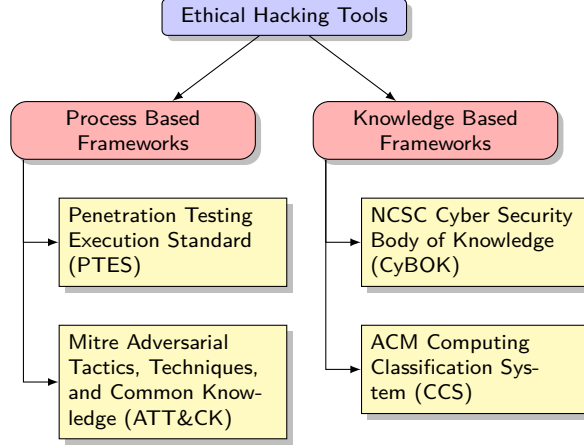


Figure 2: Classification Criteria applied in this survey

All 100 identified tools were categorised according to the following classifications (Figure 2):

1. Penetration Testing Execution Standard (PTES) [10]
2. Mitre ATT&CK Framework [11]
3. NCSC CyBOK [12]
4. ACM Computing Classification System (CCS) [13]

Incorporating **process-based** classifications such as the PTES and the Mitre ATT&CK Frameworks ensures that the survey covers the practical aspects of EH tools. On the other hand, **knowledge-based** classifications such as NCSC CyBOK and ACM CCS focus on the theoretical and conceptual aspects of computing and cybersecurity domains, thereby exploring the underlying theoretical bases of EH tools.

The next section provides an in-depth discussion of these frameworks.

## 4. Cybersecurity Frameworks used for Tools Classification

This section delves into a detailed examination of the cybersecurity frameworks used to categorise the Ethical Hacking tools surveyed in this paper. These frameworks include PTES, MITRE ATT&CK framework, CyBOK, and ACM CCS).

### 4.1. Penetration Testing Execution Standard

*PTES* [10] is a standardised methodology for planning, executing, and reporting security tests and it is widely used within the cybersecurity industry as one of the most significant standards for conducting penetration tests. PTES was proposed by a group of penetration testers and security professionals to provide guidance and best practices for conducting effective penetration tests within legal and ethical boundaries. It consists of seven phases (Figure 3):

1. *Pre-engagement Interactions*: In this phase, the scope and rules of engagement are defined through an agreement between the pen-testing team and the system's owner. The system's owner must provide permissions and authorizations, and communication lines must be established between the testers and the target organization.



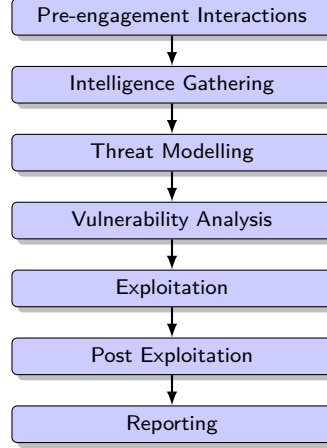


Figure 3: Penetration Testing phases according to PTES methodology

2. *Intelligence Gathering*: Information about the target organization or system is collected using techniques such as open-source intelligence (OSINT) gathering, reconnaissance, and network scanning. Active and passive information gathering methods are distinguished based on direct interaction with the target system.
3. *Threat Modelling*: This phase identifies potential vulnerabilities and threats specific to the target organization or system. It involves analysing collected information, understanding infrastructure and architecture, prioritizing attack vectors, and assigning risks to threats to inform vulnerability mitigation.
4. *Vulnerability Analysis*: Vulnerabilities and weaknesses in the target’s systems and applications are identified and assessed, typically using classification systems like the *Common Vulnerability Scoring System* (CVSS). Manual and automated testing, configuration analysis, and examination of insecure application design may be involved.
5. *Exploitation*: Vulnerabilities previously identified are exploited to compromise the target system, gain unauthorized access, or execute malicious activities. The goal is to demonstrate the impact of vulnerabilities and their potential exploitation, bypassing security mechanisms.
6. *Post-Exploitation*: After successful exploitation, the focus shifts to determining the value of the compromised system, maintaining access, escalating privileges, and pivoting to other systems within the network. This simulates an attacker’s post-compromise activities, considering the data’s importance and the advantage provided for further attacks.
7. *Reporting*: the final phase involves documenting the findings, including identified vulnerabilities, their impact, and recommendations for remediation. The report should be clear, concise, and actionable for the target organization, tailored to various audiences ranging from senior managers to technical staff.

The PTES methodology can be applied to various systems to assess their security, including networks and critical infrastructures [43].

#### 4.2. Mitre Att&ck Framework

*Mitre ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)* [11] is a framework that categorises the tactics, techniques, and procedures (TTPs) used by real-world threat actors during cyberattacks (Figure 4). It provides a standardised and comprehensive mapping of the various stages of an attack and consists of a matrix that categorises adversary behaviours across different stages of the attack lifecycle. Within each tactic, specific techniques and procedures are listed, which outline the specific actions and methods used by adversaries to accomplish their objectives.

Mitre ATT&CK consists of fourteen phases [44]:

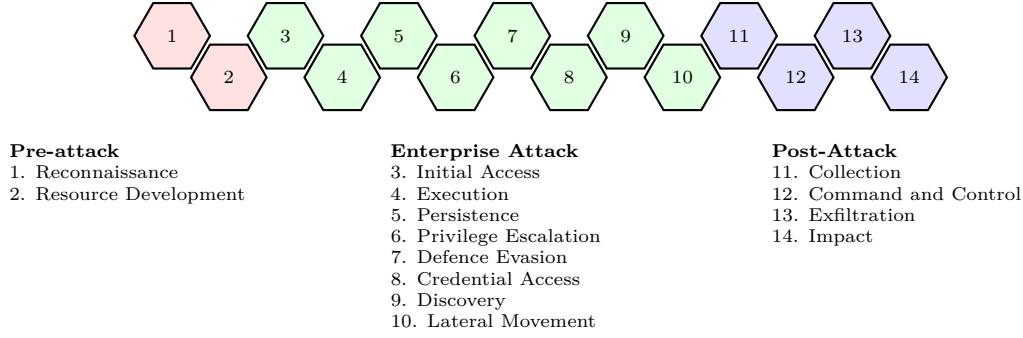


Figure 4: Mitre ATT&CK Framework: Phases and Tactics (inspired by [2])

1. *Reconnaissance*: Collecting information on the target to plan and execute attacks. Methods include: *Active Scanning*, *Passive Scanning*, *Social Engineering* and *OSINT*.
2. *Resource Development*: Acquiring resources required for further exploitation and maintaining access. Methods include: *Developing Tools* and *Developing and Executing Malware*.
3. *Initial Access*: Techniques performed to gain access to the target environment. Methods to achieve this include: *Spear-Phishing*, *Exploiting Vulnerabilities* and *Stolen Credentials*.
4. *Execution*: Techniques performed executing Malicious Software (Malware) on a target system. Methods include: *Executing Binaries*, *Scripts* and *System Tools*.
5. *Persistence*: Techniques performed around maintaining system access over a significant period of time. Methods include: *Backdoor Creation* and *Scheduled Tasks*.
6. *Privilege Escalation*: Increasing the Access Control levels in the compromised environment. Methods include: *Vulnerability Exploitation*, *Configuration Manipulation* and *Credential Theft*.
7. *Defence Evasion*: Techniques to avoid detection or target defensive mechanisms. Methods include: *Anti-Virus Evasion*, *Obfuscation* and *Living-off-the-land Techniques*.
8. *Credential Access*: Techniques for stealing credentials for unauthorised access. Methods include: *Credential Dumping*, *Keylogging* and *Brute-Force Attacks*.
9. *Discovery*: Techniques for identifying information about the target system. Methods include: *Network Scanning*, *System Enumeration* and *Querying Systems*.
10. *Lateral Movement*: Methods for moving through the network for accessing additional systems by using: *RDP*, *Trust Relationships* and *Lateral Tool Transfer*.
11. *Collection*: Acquiring and consolidating target system information. Methods include: *Data Mining*, *Scraping* and *Information Capture*.
12. *Command and Control*: Creating and Maintaining communication channels between the attacker and compromised systems. Methods include: *Command and Control (C2)*, *Covert Channels* and *Network Protocols*.
13. *Exfiltration*: Techniques around the unauthorised data transfer external to the target environment. Methods include: *Network Data Exfiltration*, *Encryption Channels* and *Scheduled Transfer*.
14. *Impact*: Achieving the desired outcome or effect could involve damaging a target. Methods include: *Destroying Data*, *System Operation Disruption* and *Deploying Malware*.

The Mitre ATT&CK framework can be applied to broad kinds of targets, including, financial systems [45], healthcare [46] and Industrial Control Systems (ICS) [47].

#### 4.3. NCSC CyBOK

The *Cyber Security Body of Knowledge* (CyBOK) [12] is a project developed by the United Kingdom's National Cyber Security Centre (NCSC), a child agency of the Government Communications Headquarters (GCHQ), in collaboration with academia, industry, and government partners. CyBOK aims to provide

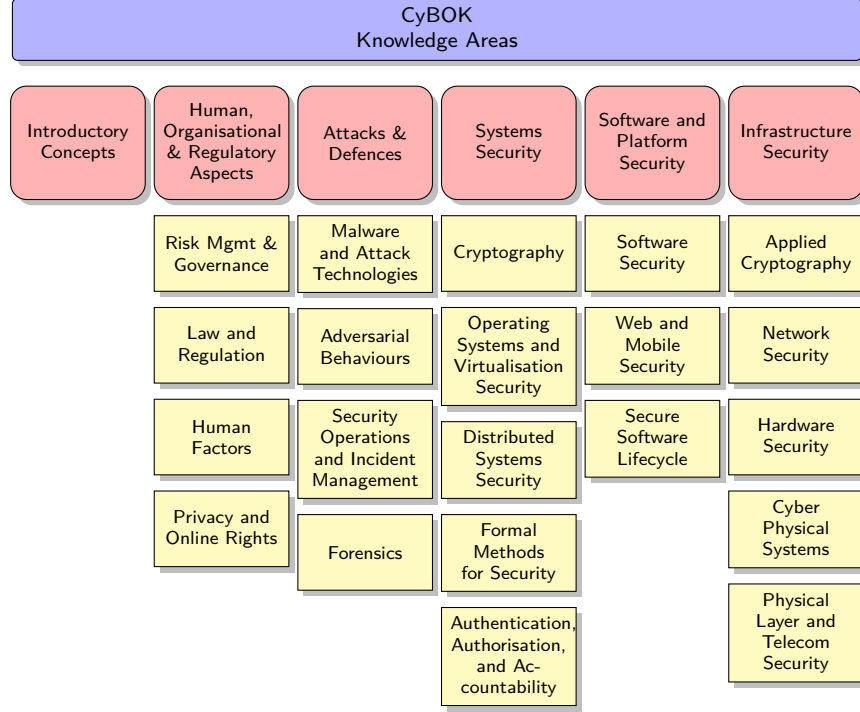


Figure 5: Cyber Security Body Of Knowledge (CyBOK) Knowledge Areas

a comprehensive and authoritative reference for the knowledge, skills, and competencies on which various educational programmes and job descriptions may be aligned. The CyBOK is divided into 21 top-level *Knowledge Areas* (KAs) and five broad categories, along with the introductory concepts, as shown in Figure 5. These categories, while orthogonal, are not entirely separate from each other, reflecting the interdisciplinary nature of cyber security.

In summary, Knowledge Areas in CyBOK version 1.1 [48] are organised as follows:

1. Introductory Concepts: *Introduction to CyBOK*.
2. Human, Organisational & Regulatory Aspects: (a) *Risk Management and Governance*, (b) *Law and Regulation*, (c) *Human Factors* and (d) *Privacy and Online Rights*.
3. Attacks & Defences: (a) *Malware and Attack Technologies*, (b) *Adversarial Behaviours*, (c) *Security Operations and Incident Management* and (d) *Forensics*.
4. Systems Security: (a) *Cryptography*, (b) *Operating Systems and Virtualisation Security*, (c) *Distributed Systems Security*, (d) *Formal Methods for Security* and (e) *Authentication, Authorisation, and Accountability*.
5. Software and Platform Security: (a) *Software Security*, (b) *Web and Mobile Security* and (c) *Secure Software Lifecycle*.
6. Infrastructure Security: (a) *Applied Cryptography*, (b) *Network Security*, (c) *Hardware Security*, (d) *Cyber Physical Systems* and (e) *Physical Layer and Telecommunications Security*.

The CyBOK can be applied in various ways to enhance the security posture of businesses. It can be used to assess skills, develop workforces, curriculum design in higher education, and certification programs [49, 50].

#### 4.4. ACM Computing Classification System (CCS)

The *Computing Classification System* (CCS) [13] is a taxonomy developed by the Association for Computing Machinery (ACM). It is designed to categorise and organise the various areas of research and practice

within the field of computing. The CCS provides a hierarchical structure that classifies research papers, articles, conference proceedings, and other scholarly works in computing. Authors use appropriate CSS categories when submitting publication manuscripts to journals and conferences for classification and organisation. This system helps to locate relevant literature, understand the structure of the field, and facilitate communication within the computing community. The root concepts of ACM CSS include [13]:

1. *General and Reference*: Fundamental concepts and cross-disciplinary topics in computing.
2. *Hardware*: Physical components and architecture of computing systems.
3. *Computer Systems Organisation*: Organisation and structure of computer systems.
4. *Networks*: Communication and connectivity in computing environments.
5. *Software and Its Engineering*: Development, design, and maintenance of software systems.
6. *Theory of Computation*: Mathematical and theoretical aspects of computation.
7. *Mathematics of Computing*: Mathematical foundations of algorithms and computation.
8. *Information Systems*: Management, retrieval, and processing of information in computing.
9. *Security and Privacy*: Protection of computing systems and data privacy concerns.
10. *Human-Centred Computing*: Interaction between humans and computing technologies.
11. *Computing Methodologies*: Methodological approaches in computing research and practice.
12. *Applied Computing*: Application of computing techniques in various domains.
13. *Social and Professional Topics*: Ethical, legal, and social aspects of computing.

## 5. Classification

The complete list of identified tools is available in Table 1. We include the availability of source code, the license type, the source code repository and the year of publication. For readability reasons, we put the other classification tables in Appendix B. The description of individual tools is presented in Appendix C.

| <i>Tool Name</i>   | <i>Year</i> | <i>License Type</i>    | <i>Source Code Repository</i>                                                                                   |
|--------------------|-------------|------------------------|-----------------------------------------------------------------------------------------------------------------|
| ADaMs [51]         | 2021        | MIT License            | <a href="https://github.com/TheAdamProject/adams">https://github.com/TheAdamProject/adams</a>                   |
| AIBugHunter [52]   | 2023        | MIT License            | <a href="https://github.com/aws-m-research/aibughunter">https://github.com/aws-m-research/aibughunter</a>       |
| ARMONY [53]        | 2013        | Not Available          | Not Available                                                                                                   |
| Autosploit [54]    | 2020        | Not Available          | Not Available                                                                                                   |
| AVAIN [55]         | 2019        | MIT License            | <a href="https://github.com/ra1nb0rN/Avain">https://github.com/ra1nb0rN/Avain</a>                               |
| Bbuzz [56]         | 2017        | MIT License            | <a href="https://github.com/lockout/Bbuzz">https://github.com/lockout/Bbuzz</a>                                 |
| Black Ostrich [57] | 2023        | Not Available          | Not Available                                                                                                   |
| Black Widow [58]   | 2021        | Not Specified          | <a href="https://github.com/SecuringWeb/BlackWidow">https://github.com/SecuringWeb/BlackWidow</a>               |
| Bleem [59]         | 2023        | Not Available          | Not Available                                                                                                   |
| Cairis [60]        | 2020        | Apache 2.0             | <a href="https://github.com/cairis-platform/cairis">https://github.com/cairis-platform/cairis</a>               |
| Censys [61]        | 2015        | Apache 2.0 + ISC       | <a href="https://github.com/zmap/zgrab2">https://github.com/zmap/zgrab2</a>                                     |
| Chainsaw [62]      | 2016        | Not Available          | Not Available                                                                                                   |
| Chucky [63]        | 2013        | GPLv3                  | <a href="https://github.com/a0x77n/chucky-ng/">https://github.com/a0x77n/chucky-ng/</a>                         |
| Commix [64]        | 2019        | GPLv3                  | <a href="https://github.com/commixproject/commix">https://github.com/commixproject/commix</a>                   |
| CryptoGuard [65]   | 2019        | GPLv3                  | <a href="https://github.com/CryptoGuardOSS/cryptoguard">https://github.com/CryptoGuardOSS/cryptoguard</a>       |
| CuPerFuzzer [66]   | 2021        | Not Specified          | <a href="https://github.com/little-leiry/CuPerFuzzer">https://github.com/little-leiry/CuPerFuzzer</a>           |
| Deemon [67]        | 2017        | GPLv3                  | <a href="https://github.com/tgiano/deemon">https://github.com/tgiano/deemon</a>                                 |
| Delta [68]         | 2017        | Not Specified          | <a href="https://github.com/seungsoo-lee/DELTA">https://github.com/seungsoo-lee/DELTA</a>                       |
| DFBC [69]          | 2021        | Not Available          | Not Available                                                                                                   |
| Diane [70]         | 2021        | Not Specified          | <a href="https://github.com/ucsb-seclab/diane">https://github.com/ucsb-seclab/diane</a>                         |
| EBF [71]           | 2021        | MIT License            | <a href="https://github.com/fatimahkj/EBF">https://github.com/fatimahkj/EBF</a>                                 |
| ELAID [72]         | 2020        | Not Available          | Not Available                                                                                                   |
| ESASCF [73]        | 2023        | Available upon request | Available upon request                                                                                          |
| ESRFuzzer [74]     | 2021        | Not Available          | Not Available                                                                                                   |
| ESSecA [75]        | 2022        | Not Specified          | <a href="https://github.com/DanieleGranata94/SlaGenerator">https://github.com/DanieleGranata94/SlaGenerator</a> |
| Firmaster [76]     | 2018        | Not Available          | Not Available                                                                                                   |
| FUGIO [77]         | 2022        | Not Specified          | <a href="https://github.com/WSP-LAB/FUGIO">https://github.com/WSP-LAB/FUGIO</a>                                 |
| FUSE [78]          | 2020        | Not Specified          | <a href="https://github.com/WSP-LAB/FUSE">https://github.com/WSP-LAB/FUSE</a>                                   |
| Gail-PT [79]       | 2023        | Not Specified          | <a href="https://github.com/Shulong98/GAIL-PT/">https://github.com/Shulong98/GAIL-PT/</a>                       |

| <i>Tool Name</i>               | <i>Year</i> | <i>License Type</i>    | <i>Source Code Repository</i>                                                                                                                                             |
|--------------------------------|-------------|------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GNPassGAN [80]                 | 2022        | MIT License            | <a href="https://github.com/fangyiyu/GNPassGAN/">https://github.com/fangyiyu/GNPassGAN/</a>                                                                               |
| HARMer [81]                    | 2020        | MIT License            | <a href="https://github.com/whistlebee/harmat">https://github.com/whistlebee/harmat</a>                                                                                   |
| HILTI [82]                     | 2014        | Not Specified          | <a href="https://github.com/rsmmr/hilti">https://github.com/rsmmr/hilti</a>                                                                                               |
| IoTFuzzer [83]                 | 2018        | Not Specified          | <a href="https://github.com/zyw-200/IOTFuzzer_Full">https://github.com/zyw-200/IOTFuzzer_Full</a>                                                                         |
| JCOMIX [84]                    | 2019        | Not Specified          | <a href="https://github.com/SERG-Delft/JCOMIX">https://github.com/SERG-Delft/JCOMIX</a>                                                                                   |
| LAID [85]                      | 2018        | Not Available          | Not Available                                                                                                                                                             |
| Link [86]                      | 2022        | Not Specified          | <a href="https://github.com/WSP-LAB/Link">https://github.com/WSP-LAB/Link</a>                                                                                             |
| Lore [87]                      | 2023        | Not Available          | Not Available                                                                                                                                                             |
| LTESniffer [88]                | 2023        | Not Specified          | <a href="https://github.com/SysSec-KAIST/LTESniffer">https://github.com/SysSec-KAIST/LTESniffer</a>                                                                       |
| Mace [89]                      | 2014        | Not Available          | Not Available                                                                                                                                                             |
| MAIT [90]                      | 2021        | Not Available          | Not Available                                                                                                                                                             |
| MAL [91]                       | 2018        | Apache 2.0             | <a href="https://github.com/mal-lang/malcompiler/">https://github.com/mal-lang/malcompiler/</a>                                                                           |
| MaliceScript [92]              | 2018        | Not Available          | Not Available                                                                                                                                                             |
| Masat [93]                     | 2015        | Not Available          | Not Available                                                                                                                                                             |
| Mirage [94]                    | 2019        | MIT License            | <a href="https://github.com/RCayre/mirage">https://github.com/RCayre/mirage</a>                                                                                           |
| Mitch [95]                     | 2019        | Not Specified          | <a href="https://github.com/alviser/mitch">https://github.com/alviser/mitch</a>                                                                                           |
| MoScan [96]                    | 2021        | UPL 1.0                | <a href="https://github.com/baigd/moscan">https://github.com/baigd/moscan</a>                                                                                             |
| NAUTILUS [97]                  | 2023        | Apache 2.0             | <a href="https://github.com/chenleji/nautilus">https://github.com/chenleji/nautilus</a>                                                                                   |
| NAVEX [98]                     | 2018        | GPLv3                  | <a href="https://github.com/aalhuz/navex">https://github.com/aalhuz/navex</a>                                                                                             |
| NetCAT [99]                    | 2020        | Not Available          | Not Available                                                                                                                                                             |
| NeuralNetworkCracking [100]    | 2016        | Apache 2.0             | <a href="https://github.com/cupslab/neural_network_cracking">https://github.com/cupslab/neural_network_cracking</a>                                                       |
| No Name (CSRF) [101]           | 2020        | Not Available          | Not Available                                                                                                                                                             |
| No Name (TTCN-3) [102]         | 2018        | Not Available          | Not Available                                                                                                                                                             |
| NoCrack [103]                  | 2015        | MIT License            | <a href="https://github.com/rchatterjee/nocrack">https://github.com/rchatterjee/nocrack</a>                                                                               |
| NodeXP [104]                   | 2021        | Not Specified          | <a href="https://github.com/esmog/nodexp">https://github.com/esmog/nodexp</a>                                                                                             |
| ObjectMap [105]                | 2019        | MIT License            | <a href="https://github.com/georlav/objectmap">https://github.com/georlav/objectmap</a>                                                                                   |
| OMEN [106]                     | 2015        | MIT License            | <a href="https://github.com/RUB-SysSec/OMEN">https://github.com/RUB-SysSec/OMEN</a>                                                                                       |
| OSV [107]                      | 2017        | GPLv3                  | <a href="https://github.com/Emoform/OSV">https://github.com/Emoform/OSV</a>                                                                                               |
| Owfuzz [108]                   | 2023        | GPLv3                  | <a href="https://github.com/alipay/Owfuzz">https://github.com/alipay/Owfuzz</a>                                                                                           |
| PassGAN [109]                  | 2019        | MIT License            | <a href="https://github.com/brannondorsey/PassGAN">https://github.com/brannondorsey/PassGAN</a>                                                                           |
| PassGPT [110]                  | 2023        | CC BY-NC 4.0           | <a href="https://github.com/javirandor/passgpt">https://github.com/javirandor/passgpt</a>                                                                                 |
| PasswordCrackingTraining [111] | 2022        | MIT License            | <a href="https://github.com/focardi/PasswordCrackingTraining">https://github.com/focardi/PasswordCrackingTraining</a>                                                     |
| PenQuest [112]                 | 2020        | Proprietary            | <a href="https://www.pen.quest/">https://www.pen.quest/</a>                                                                                                               |
| PentestGPT [113]               | 2023        | MIT License            | <a href="https://github.com/GreyDGL/PentestGPT">https://github.com/GreyDGL/PentestGPT</a>                                                                                 |
| PhpSAFE [114]                  | 2015        | GPLv2                  | <a href="https://github.com/JoseCarlosFonseca/phpSAFE">https://github.com/JoseCarlosFonseca/phpSAFE</a>                                                                   |
| PJCT [115]                     | 2015        | Not Available          | Not Available                                                                                                                                                             |
| Project Achilles [116]         | 2019        | LGPLv3                 | <a href="https://github.com/secure-software-engineering/achilles-benchmark-depscanners">https://github.com/secure-software-engineering/achilles-benchmark-depscanners</a> |
| PURITY [117]                   | 2015        | Proprietary            | Not Available                                                                                                                                                             |
| Pyciuti [118]                  | 2023        | Not Available          | Not Available                                                                                                                                                             |
| RAT [119]                      | 2022        | Available upon request | Available upon request                                                                                                                                                    |
| Revealer [120]                 | 2021        | GPLv2                  | <a href="https://github.com/cuhk-seclab/Revealer">https://github.com/cuhk-seclab/Revealer</a>                                                                             |
| RiscyROP [121]                 | 2022        | Not Available          | Not Available                                                                                                                                                             |
| Robin [122]                    | 2020        | Not Specified          | <a href="https://github.com/olmps/Robin">https://github.com/olmps/Robin</a>                                                                                               |
| ROSploit [123]                 | 2019        | MIT License            | <a href="https://github.com/seanrivera/rosploit">https://github.com/seanrivera/rosploit</a>                                                                               |
| RT-RCT [124]                   | 2021        | Not Available          | Not Available                                                                                                                                                             |
| Scanner++ [125]                | 2023        | Not Available          | Not Available                                                                                                                                                             |
| SemanticGuesser [126]          | 2014        | Not Specified          | <a href="https://github.com/vialab/semantic-guesser">https://github.com/vialab/semantic-guesser</a>                                                                       |
| SerialDetector [127]           | 2021        | Not Specified          | <a href="https://github.com/yuske/SerialDetector">https://github.com/yuske/SerialDetector</a>                                                                             |
| ShoVAT [128]                   | 2016        | Not Available          | Not Available                                                                                                                                                             |
| Snout [129]                    | 2019        | Not Specified          | <a href="https://github.com/nislab/snout/">https://github.com/nislab/snout/</a>                                                                                           |
| SOA-Scanner [130]              | 2013        | Not Available          | Not Available                                                                                                                                                             |
| Spicy [131]                    | 2016        | MIT License            | <a href="https://github.com/zeek/spicy/">https://github.com/zeek/spicy/</a>                                                                                               |
| SuperEye [132]                 | 2019        | Not Available          | Not Available                                                                                                                                                             |
| SVED [133]                     | 2016        | Not Available          | Not Available                                                                                                                                                             |
| TAMELESS [134]                 | 2023        | Not Specified          | <a href="https://github.com/FulvioValenza/TAMELESS">https://github.com/FulvioValenza/TAMELESS</a>                                                                         |
| TChecker [135]                 | 2022        | Not Available          | Not Available                                                                                                                                                             |
| TORPEDO [136]                  | 2015        | Not Available          | Not Available                                                                                                                                                             |
| UE Security Reloaded [137]     | 2023        | Not Available          | Not Available                                                                                                                                                             |
| Untangle [138]                 | 2023        | Not Specified          | <a href="https://github.com/untangle-tool/untangle">https://github.com/untangle-tool/untangle</a>                                                                         |
| VAPE-BRIDGE [139]              | 2022        | Not Available          | Not Available                                                                                                                                                             |
| VERA [140]                     | 2013        | Not Available          | Not Available                                                                                                                                                             |

| <i>Tool Name</i>   | <i>Year</i> | <i>License Type</i>    | <i>Source Code Repository</i>                                                                       |
|--------------------|-------------|------------------------|-----------------------------------------------------------------------------------------------------|
| VUDDY [141]        | 2017        | MIT License            | <a href="https://github.com/squizz617/vuddy">https://github.com/squizz617/vuddy</a>                 |
| Vulcan [142]       | 2013        | Not Available          | Not Available                                                                                       |
| VulCNN [143]       | 2022        | Not Specified          | <a href="https://github.com/CGCL-codes/VulCNN">https://github.com/CGCL-codes/VulCNN</a>             |
| VulDeePecker [144] | 2018        | Apache 2.0             | <a href="https://github.com/CGCL-codes/VulDeePecker">https://github.com/CGCL-codes/VulDeePecker</a> |
| Vulnet [145]       | 2019        | Not Available          | Not Available                                                                                       |
| Vulnsloit [146]    | 2020        | Available upon request | Available upon request                                                                              |
| VulPecker [147]    | 2016        | Not Specified          | <a href="https://github.com/vulpecker/Vulpecker">https://github.com/vulpecker/Vulpecker</a>         |
| WAPTT [148]        | 2014        | Not Available          | Not Available                                                                                       |
| WebFuzz [149]      | 2021        | GPLv3                  | <a href="https://github.com/ovanr/webFuzz">https://github.com/ovanr/webFuzz</a>                     |
| WebVIM [150]       | 2020        | Not Available          | Not Available                                                                                       |

Table 1: Classified tools, licence type and source code availability

### 5.1. Process Based Classification: PTES and Mitre ATT&CK

| <i>PTES Phase</i>           | <i>No.</i> |
|-----------------------------|------------|
| Vulnerability Analysis      | 80         |
| Exploitation                | 39         |
| Post Exploitation           | 21         |
| Intelligence Gathering      | 20         |
| Threat Modelling            | 6          |
| Reporting                   | 4          |
| Pre-engagement Interactions | 0          |

(a) Number of Tools identified according to PTES phases

| <i>Mitre ATTA&amp;CK Phase</i> | <i>No.</i> |
|--------------------------------|------------|
| Reconnaissance                 | 84         |
| Initial Access                 | 48         |
| Resource Development           | 21         |
| Discovery                      | 11         |
| Execution                      | 9          |
| Credential Access              | 9          |
| Collection                     | 2          |
| Impact                         | 1          |
| Persistence                    | 0          |
| Privilege Escalation           | 0          |
| Defense Evasion                | 0          |
| Lateral Movement               | 0          |
| Command and Control            | 0          |
| Exfiltration                   | 0          |

(b) Number of Tools identified according to Mitre ATT&CK phases

Table 2: Tool counts for process-based classification

Table B.7 shows the tools identified and classified for the different PTES phases. The tools distribution according to steps in the Ethical Hacking process is reported in Table 2a. The absence of tools in the *Pre-engagement Interactions* phase aligns with expectations, considering its non-technical nature, which typically involves scoping, planning, and agreement on the terms of engagement between the penetration tester and the client. This may potentially explain the lack of interest from the research community.

The significant presence of tools in the *Vulnerability Analysis* phase (80 tools) reflects the importance of identifying and assessing vulnerabilities within target systems, which is essential for any security assessment activity. In particular, many scanners were developed.

Additionally, 20 tools possess *Intelligence Gathering* capabilities, primarily because this phase sometimes overlaps with vulnerability analysis attackers interact with target systems.

*Exploitation* (39 tools) has a substantial number of tools designed to exploit identified vulnerabilities to gain unauthorised access to systems. Post Exploitation has slightly fewer tools than other phases (21 tools). We found 6 tools for *Threat Modelling*. However, other researchers have developed some methodologies which are not implemented as tools that we discuss in Section 5.3.

The Mitre ATT&CK classification table (Table B.8) shows tools associated with different stages of the attack process. The *Reconnaissance* (84 tools) and *Initial Access* (48 tools) stages exhibit a higher concentration of tools (Table 2b), indicating the significance of these phases. This aligns with PTES findings, where most research effort seems to be put into vulnerability analysis. *Resource Development* (21) and *Discovery* (11) are also well represented. In contrast, stages such as *Persistence* and *Privilege Escalation* appear to have

no tools directly associated with them, implying potential areas of development of novel research-informed tools. Further details on the classification, with sub areas, are presented in Table B.9.

Overall, researchers seem to have focused more on the technical aspects of the penetration testing process, and most of the tools have vulnerability analysis capability.

## 5.2. Knowledge Based Classification: NCSC CyBOK and ACM CCS

| <i>CyBOK Knowledge Area</i>                                           | <i>No.</i> |
|-----------------------------------------------------------------------|------------|
| Software and Platform Security: Software Security                     | 77         |
| Software and Platform Security: Web & Mobile Security                 | 38         |
| Infrastructure Security: Network Security                             | 26         |
| Attacks & Defences: Adversarial Behaviours                            | 9          |
| Systems Security: Authentication, Authorisation & Accountability      | 9          |
| Systems Security: Distributed Systems Security                        | 3          |
| Infrastructure Security: Applied Cryptography                         | 2          |
| Human, Organisational & Regulatory Aspects: Human Factors             | 2          |
| Attacks & Defences: Malware & Attack Technology                       | 1          |
| Infrastructure Security: Physical Layer & Telecommunications Security | 1          |
| Human, Organisational & Regulatory Aspects: Privacy & Online Rights   | 1          |

Table 3: Number of Tools identified according to CyBOK, for KAs with at least 1 tool

Table B.10 presents the classification of tools according to NCSC CyBOK. The distribution of tools across different *Knowledge Areas* (KAs) reflects the range of cybersecurity domains and disciplines covered by penetration testing activities. From the categorisation in Table 3, it is evident that certain areas, such as *Software & Platform Security* and *Networks Security*, are unsurprisingly more prominent, indicating areas of emphasis within cybersecurity practice. It should also be noted that while each category addresses specific aspects of cybersecurity, many tools may span multiple categories.

Most of the tools are classified under *Software & Platform Security: Software Security: Detection of Vulnerabilities* (57 tools), which is a subcategory of *Software & Platform Security: Software Security*. The significant number of tools in this area reflects the recognition of software as a primary attack vector and demonstrates the research community’s effort. Moreover, 38 tools are classified in the *Software & Platform Security: Web & Mobile Security*, highlighting the research work done to address the challenges posed by the development and deployment of web and mobile applications.

The 26 tools falling under *Infrastructure Security: Network Security* demonstrate the academic efforts in this area, ranging from network traffic monitoring and anomaly detection to implementing robust encryption protocols.

Nine tools classified under the *Attacks & Defences: Adversarial Behaviours* category indicate research aimed at understanding and simulating the techniques used by attackers.

Among the various categories within the ACM CCS, EH tools in Table B.11 predominantly fall into the *Security and Privacy* root category, specifically within the subcategories of *Systems Security*, *Software and Application Security*, and *Network Security*. In general, ACM CSS categories are too coarse to capture certain peculiarities of the tools. As CyBOK is specific to cybersecurity, it is more granular than ACM CSS for our purpose. We discuss the limitations in the classification in Section 5.4.

*Software And Application Security: Vulnerability Management: Vulnerability Scanners* has the highest number of tools: 73. This indicates the proactive measures the research community is taking to detect various issues, from misconfigurations and missing patches to software flaws and weak passwords. The categorisation of 35 tools under the *Software and Application Security: Web Applications Security* highlights the focus on developing specialised tools designed to test and secure web applications. These tools analyse web applications for vulnerabilities like SQL injection, cross-site scripting (XSS), and security misconfigurations.

22 tools were categorised under the *Network Security* domain and sub-domains, focusing on protecting the data during its transmission across networks. These tools are essential for detecting intrusions, monitoring network traffic for suspicious activities, and implementing preventive measures such as firewalls and

encryption. EH tools within this category enable security professionals to simulate attacks on the network to identify vulnerabilities and assess the network’s resilience against cyber threats.

### 5.3. A note on Threat Modelling tools and methodologies

The PTES classification shows that the number of tools identified for *Threat Modelling* is relatively small. However, the research field is somewhat active, but some contributions only propose new methodologies without implementing specific tools, so we did not include them in the classification. Some threat modelling methodologies discussed here cover different frameworks, each designed to improve security in cyber-physical systems (CPS), information technology, and critical infrastructure areas.

Ding et al.’s [151] framework integrates vulnerability assessment with reliability and threat analysis (both external and internal) within a unified model focused on critical infrastructures integrated with CPS. Similarly, Agadakos et al. [152] present a novel method for modelling cyber and physical interactions within IoT networks. The study emphasises the identification of unexpected event chains that could lead to security vulnerabilities. Additionally, Castiglione et al. [153] proposed a hazard-driven threat modelling methodology tailored for CPS, focusing on the interplay between security, reliability, and safety.

To highlight the critical role of human factors in information security, Evans et al. [154] introduce a methodology that systematically evaluates information security incidents caused by human error, adopting the HEART methodology from high-reliability sectors like aviation and energy. Also, David et al. [155] propose using timed automata to model socio-technical attacks, offering a method that incorporates time and cost into analysing socio-technical systems and attacks.

Furthermore, using formal methods for security analysis, Malik et al. [156] introduce an algorithm that transforms Attack Trees into Markov Decision Process models, aiming to address the limitations of scalability, state explosion, and manual interaction inherent in Attack Trees.

Collectively, these methodologies demonstrate a shift towards integrating diverse analytical tools and perspectives, from human factors to formal methods and system theory, to address the increasingly complex and interconnected nature of modern systems.

### 5.4. Limitations surrounding the classification of tools

The four classification systems identified in this study were chosen due to their overall topic coverage and relevance to computing topics and concepts. When combined, the classifications can give a precise idea of what a tool can do and the cybersecurity field it falls under.

Although these four classifications are fit for purpose when considered within the scope and the goal of this survey and its goals, there are some challenges and potential limitations in classifying tools in this manner. The first issue is an inconsistency within the specificity of the tools.

For example, within *MITRE* [11], despite having hundreds of individual attack techniques and vectors, such as *Enterprise: Privilege Escalation: Access Token Manipulation: SID-History injection* and *Enterprise: Defence Evasion: Hijack Execution Flow: Path Interception by PATH Environment Variable*, which are very specific vectors down to the operating system architecture within individual target systems, MITRE lumps the entire concept of compromising a web application under *Enterprise: Initial Access: Exploit Public-Facing Application*. There are other means of gaining specificity within this classification system, such as the *Reconnaissance: Vulnerability Scanning* field. All together, these give a more specific view of the tool. However, both fields do not offer the specificity of the *SID-History Injection* or *Path Interception by PATH Environment Variable* fields.

Another issue relates to tools that can be used for activities potentially unintended by the application designer. Deciding whether to include the ACM CSS *Security and privacy: Network security: Denial-of-service attacks* field when considering a web application fuzzer that could potentially crash the target web application (and making similar decisions throughout the classification of the many tools within this survey), posed a significant challenge, as opinions on whether to include the field may vary between researchers.

Another issue was found when trying to discern the exact scope of any given tools. There were many instances when, in the paper, a tool would present itself as one thing, for example, being capable of completing



a specific task within the abstract and majority of the discussion in the associated paper, only to reveal that the tool itself is a *proof-of-concept*, with limited capabilities than was assumed initially.

To fully understand each tool’s potential, an in-depth evaluation involving running the tools and testing their capabilities would be necessary. However, this is beyond the scope of this survey. Future work could focus on specific subject clusters to provide an in-depth comparison of the tools.

## 6. Evaluation

This section evaluates 100 research-informed Ethical Hacking tools developed within the past decade and included in this study. The discussion will focus on several key aspects: their licensing, release dates, availability of source code, the activity level of their development, whether the papers publishing them underwent peer review and their alignment with recognised cybersecurity frameworks.

### 6.1. Peer Review Analysis and Date of Publication

Of the 100 tools discussed in this study, 96% were disseminated through peer-reviewed journals and conferences (Table 4a).

| <i>Peer Reviewed</i> | <i>No.</i> | <i>%</i>       |
|----------------------|------------|----------------|
| Y                    | 96         | 96.00%         |
| N                    | 4          | 4.00%          |
| <i>Total</i>         | <i>100</i> | <i>100.00%</i> |

(a) Peer Reviewed

| <i>Source Code Avail.</i> | <i>No.</i> | <i>%</i>       |
|---------------------------|------------|----------------|
| Y                         | 59         | 59.00%         |
| N                         | 41         | 41.00%         |
| <i>Total</i>              | <i>100</i> | <i>100.00%</i> |

(b) Source Code Available

Table 4: Classification

This indicates that the proposed tools have undergone rigorous validation, guaranteeing their effectiveness and reliability. This emphasis on peer-reviewed tools in our study reflects our commitment to ensuring readers have confidence in the credibility and utility of the tools presented. The remaining tools, which were not yet peer-reviewed at the time of our survey but are available as pre-print (e.g., [113, 54]), potentially under review or to be submitted in the near future.

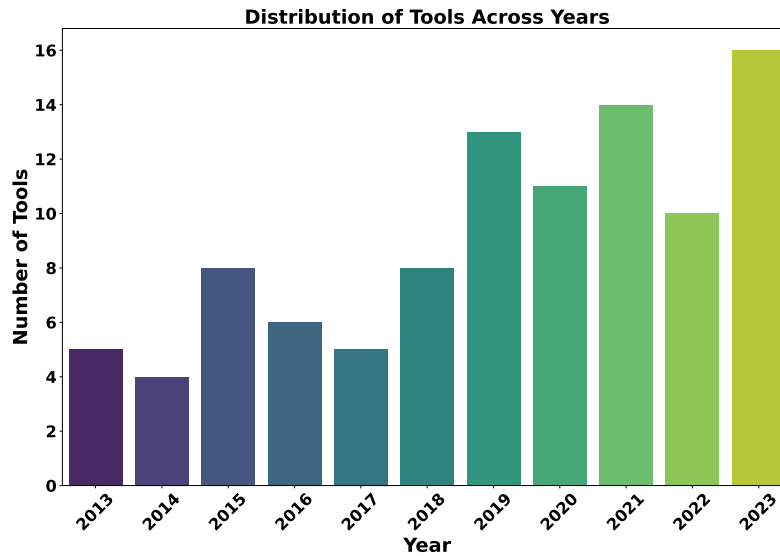


Figure 6: Distribution of Tool Releases Over Last Decade

Furthermore, the distribution of tool releases over the years, as illustrated in Figure 6, shows an increase in development activities in recent years, with 16 tools released in 2023, 14 in 2021, and 13 in 2019. This trend mirrors the evolution of cybersecurity threats and the response from the research community to address these problems.

### 6.2. Types of Licensing and Source Code Availability

This section delves into the licensing types, development activity, and source code availability for the tools discussed in this paper. The evaluation found that out of the 100 tools included in this study, 59 have their source code readily available on GitHub, while 41 are unavailable (Table 4b).

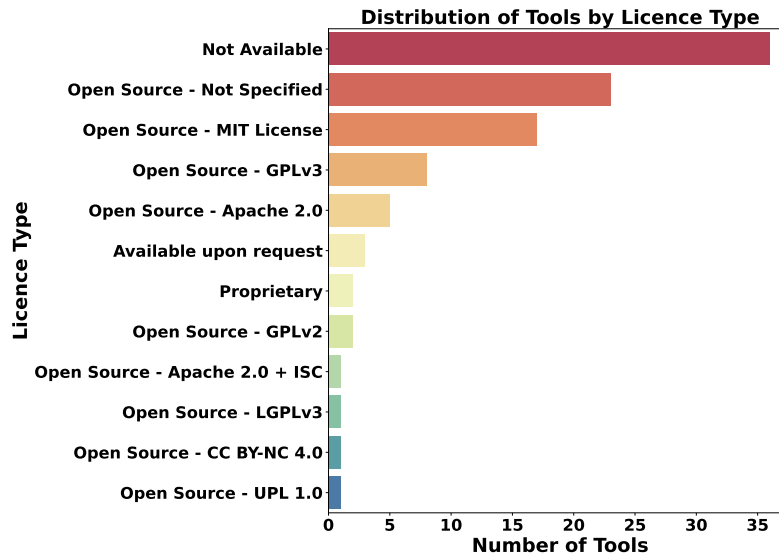


Figure 7: Distribution of Tools by License Type

The types of licenses for the tools available on GitHub vary widely (Figure 7), mostly open source licences, ranging from the *MIT License* (17 tools), *GPLv3* (8 tools). However, for 23 tools, the licence is *Not Specified*. The lack of clear licensing information could be an oversight by developers regarding the importance of transparent communication of usage rights. This ambiguity may potentially hinder adoption and adaptability. In the absence of a license, default copyright laws apply, meaning that authors retain all rights to their source code and reproduction, distribution, or creation of derivative works is prohibited.

Overall, the fact that source code is available for more than half of the tools (59 tools) demonstrates the cybersecurity researchers’ dedication to openness and active community participation. However, 41 inaccessible tools in this study highlight an ongoing debate: the need to balance transparency with security, privacy, and commercial interests.

### 6.3. Tools Development and Maintenance

We examined the GitHub repositories of the 59 publicly available tools to understand specific features related to tool development and maintenance. Specifically, we collected data on the number of *Commits* and the dates of the first and the last commits. We believe analysing commit activity in GitHub repositories provides insights into the development intensity and duration. However, we must consider that projects can move from one repository to another and that a private repository is used alongside a private one, and the public one is used only for dissemination purposes. Therefore, we can only attempt to capture some trends with this analysis, but we must be cautious about making statements regarding specific projects.

Table 5a provides an overview of the distribution of project activity periods. We measured the difference in months between the first and last commit for the considered projects. The data shows that approximately

| <i>Period (Months)</i> | <i>No.</i> | <i>%</i>       |
|------------------------|------------|----------------|
| 0-3                    | 19         | 32.20%         |
| 4-6                    | 3          | 5.08%          |
| 6-12                   | 6          | 10.17%         |
| 13-24                  | 6          | 10.17%         |
| 25-36                  | 10         | 16.95%         |
| 37-60                  | 8          | 13.56%         |
| 61-inf                 | 7          | 11.86%         |
| <i>Total</i>           | <i>59</i>  | <i>100.00%</i> |

(a) Distribution of Period of Project Activity (last – first commit)

| <i>Commits Range</i> | <i>No.</i> | <i>%</i>       |
|----------------------|------------|----------------|
| 1-10                 | 17         | 28.81%         |
| 11-50                | 19         | 32.20%         |
| 51-100               | 4          | 6.78%          |
| 101-250              | 6          | 10.17%         |
| 251-500              | 5          | 8.47%          |
| 501-inf              | 8          | 13.56%         |
| <i>Total</i>         | <i>59</i>  | <i>100.00%</i> |

(b) Distribution of Number of Project's Commits

Table 5: Distribution of Project Activity and Commits

| <i>% of Project Activity</i> | <i>No</i> | <i>%</i>       |
|------------------------------|-----------|----------------|
| 0-0                          | 5         | 8.47%          |
| 1-25                         | 12        | 20.34%         |
| 26-50                        | 15        | 25.42%         |
| 51-75                        | 5         | 8.47%          |
| 76-99                        | 2         | 3.39%          |
| 100-100                      | 20        | 33.90%         |
| <i>Total</i>                 | <i>59</i> | <i>100.00%</i> |

Table 6: Distribution of Project Activity within 3 Years after Release

one-third of the projects have a relatively short activity span of less than 3 months. This may indicate that the publication of the source code has likely been instrumental to the publication of the paper.

Comparing the year of publication of the paper and the date of the first commit, we can see that around 90% of the projects have been active sometime in the year before or after the publication. This is not surprising. However, fewer than 10% of the projects have been active 2 or more years before the publication, according to data publicly available.

Another parameter we considered is the number of commits (Table 5b). The data highlights the diversity in project engagement and development intensity within the examined dataset. Around 30% of the projects have just up to 10 commits. As the commit ranges increase, the percentage of projects gradually decreases. Projects with a higher number of commits (500+) account for 13.33% of the total, indicating a smaller but notable proportion of projects with an extensive development history.

Table 6 represents the activity level as a percentage of the time between a project's release and the present. *100-100* indicates continuous activity throughout the period, while *0-0* signifies no activity at all. For example, *26-50* means that the project was active for at least 26% up to 50% of the considered time interval (9-18 months).

The data shows that one-third of the projects remained active within three years after their release. However, over half of these projects ceased activity after just 1.5 years. This trend sheds light on the development lifecycle of these projects, indicating a high initial engagement that tends to taper off relatively quickly for a significant number of projects.

#### 6.4. Recommendations

To improve the dissemination and enhance the impact of research on the wider community of practitioners, we suggest that researchers should:

- Distribute the software open source without exception and keep the software repository alive. Otherwise, it would be impossible for any dissemination within the practitioner community [157].
- Clearly specify the licence type and adopt standard FOSS licences [158], like GNU GPLv3, so that users may know precisely what they can do with the tools.

- Produce comprehensive documentation and tutorials on how to use the tools. Currently, this is partially done, but the existing documentation is primarily intended to support the peer-review process, as noted by Mirhosseini (2020) [159].
- Try to maintain the software by implementing bug fixes and improvements after publishing the paper. This is particularly challenging for academic projects as they operate with limited availability of human resources and funding. Once the project ends or the paper is published, the interest of the researcher tends to move to new projects [157].
- Some tools may become obsolete due to several reasons: incompatibility with more recent versions of other software (OSs, libraries, applications, etc.) or the vulnerability covered by the tool being patched. In those cases, authors should update the documentation and clearly specify the requirements, scope, context and limitations of the tool.
- Try to implement their solutions in modular tools utilised by practitioners like Metasploit and Nmap. While this can be possible for certain solutions, in general, some tools are so different and innovative that they cannot fit into the API of existing tools.
- Consider that public dissemination mitigates the risk of weaponizing tools by promoting a level playing field approach.

Another question is: what can practitioners and industry do? We cannot expect many individual practitioners to engage directly with the research outputs except when driven by intellectual curiosity. However, the IT and cybersecurity industry should try to incentivise collaboration with academia. Industry and venture capitalists likely monitor academic research to understand the state-of-the-art and gain inspiration for new ideas. However, more effective engagement from the industry may help academic research to enhance its impact.

For example, the industry currently invests in bug bounty programs, providing monetary incentives to security researchers to identify and report vulnerabilities. This informs bug fixes and improves the quality of the product overall. However, this process is typically ex-post and not something an academic researcher would be directly involved in, except if finding a bug is a by-product of the research work. However, in many cases, academic researchers would likely engage in a responsible disclosure process.

Concretely, the industry could redirect some funding from bug bounty programs [160] to grant schemes supporting open source projects, for example, the Google Summer of Code, which could enable researchers to develop and enhance their tools. This is likely something that medium to large companies could be interested in. Still, it requires a shift in perspective beyond the immediate rewards and limited risks and commitments of current bug bounty programs.

Finally, an important aspect is that most research-informed tools are developed by small teams, sometimes even by a single individual, for non-profit reasons. Given the working conditions in many higher education institutions, especially in countries where the sector is very competitive and commercialised [161], it is often the case that, unless a research grant supports the project, the developers end up working significant hours during their own free time [162].

### 6.5. Related Work

Existing reviews of Ethical Hacking tools typically focus on industry practitioner tools, with occasional consideration of research-informed tools. Many popular practitioner tools included in these reviews (e.g., [15, 2, 163, 164]) are recurrent: Nmap, Metasploit Framework, OpenVAS/GVM, Nessus, Burp Suite, OWASP ZAP, SQLMap, BeEF, Nikto, W3AF, and others.

Yaacoub et al. [15] survey and classify around 40 practitioner tools and OSs (e.g., Kali Linux and ParrotOS), focusing on challenges and issues associated with EH activities. The paper maps the tools and techniques for vulnerability assessment, network scanning tools, crimeware toolkits, etc., considering different attack types and application domains. Duque Anton et al. [2] include in their review around 25 popular practitioner tools, and their capabilities are evaluated using criteria such as active maintenance, licensing,

commercial aspects (paid vs. free), and technical elements like programming language and interaction with other technology.

Moreover, Alhamed et al. [163] analyse around 20 mostly practitioner tools, with good coverage of network vulnerability and exploitation in particular. However, they consider existing research proposals for mitigating techniques. Additionally, Sarker et al. [164] reviewed penetration testing frameworks, processes, tools, and scoring methods, encompassing around 15 practitioner EH tools.

In some cases, authors restrict their focus to a specific domain. For example, Yaacoub et al. [6] provide good coverage of practitioner commercial and open-source solutions for EH in IoT, while Altulaihan et al. [8] review and compare industry practitioner tools for web application penetration testing. Similarly, Shahid et al. [165] provide a comparative analysis of commercial and open-source tools for Web Application Security with a focus on accuracy and precision. Alzahrani et al. [166] and Ravindran et al. [167] compare many EH tools, including both industry practitioner tools and a few research-informed tools for web vulnerability assessment and exploitation, e.g., XSS and SQL injection. Kowta et al. [168] analysed a variety of reconnaissance and information-gathering tools and techniques including Google Dorking, Shodan, Web Crawler, Recon-ng, Photon, Final Recon, and Sherlock. The tools are compared with criteria such as update frequency, languages used, and supported OSs, with some research-informed tools also included in the review.

In a few cases, authors systematically classify the tools according to some methodology or taxonomy. Duque Anton et al. [2] compared and classified practitioner tools, mapping them to the Mitre ATT&CK framework. Moreover, Zilberman et al. [169] provide a review of threat emulators while mapping to the Mitre ATT&CK matrix tactics.

Shanley et al. [9] review and compare several methodologies and frameworks, including PTES, Building Security in Maturity Model (BSIMM), Metasploit Framework (MSF), OWASP Testing Guide (OTG), Information Systems Security Assessment Framework (ISSAF), and the Open Source Security Testing Methodology Manual (OSSTMM). However, no tools are reviewed; therefore, no classification is attempted.

Our study significantly differs from previously published papers in both the number of tools covered and its exclusive focus on research-informed EH tools. By categorising the tools into process-based and knowledge-based classifications, we organise them according to specific phases, demonstrating where and when they are utilised in EH processes. While other reviews include classifications, the main contribution of our work is a more comprehensive and unique exploration. We surveyed 100 tools and classified them according to four different frameworks: PTES, Mitre ATT&CK, CyBOK, and ACM CCS. Additionally, we identify and analyze trends in developing, maintaining, and disseminating novel research-informed tools.

## 7. Conclusion and Future work

Addressing emerging cyber security threats requires developing Ethical Hacking tools to identify vulnerabilities in networks, systems, and applications. While practitioners design most EH tools for immediate use in the industry, academic researchers have also significantly contributed to developing security tools. However, there is a noticeable gap in awareness among practitioners about academic contributions in this domain. This paper evaluates 100 research-informed tools, examining aspects such as licensing, release dates, source code availability, development activity, and peer review status. These tools are then aligned with established frameworks like PTES, the Mitre ATT&CK framework, CyBOK, and ACM CCS.

Key findings indicate that 96% of these tools originate from peer-reviewed research, with 59% having their source code readily accessible on GitHub. Activity analysis shows that 90% of projects were active around their publication year, yet activity dwindles significantly within 1.5 years post-release. Under the PTES framework classification, most tools are designed for vulnerability analysis, whereas threat modelling tools are relatively few. The CyBOK and ACM CCS classifications emphasise tools for detecting vulnerabilities, particularly under the *Software & Platform Security* and *Security And Privacy*, respectively. For the Mitre ATT&CK framework, most tools primarily focus on reconnaissance, highlighting the vital role of information gathering in identifying network and system details. Future directions involve experimental evaluations and comparisons of specific tools, integration of existing practitioner tools, and exploration of using large language

models in penetration testing. This approach aims to bridge the gap between industry and academia, enhancing the development and effectiveness of Ethical Hacking tools.

### *Acknowledgement*

The authors express their gratitude to Zia Ush Shamszaman, Sachin Manakkil Jolly, and the Advanced Practice students of the MSc Cybersecurity course at Teesside University for engaging in constructive discussions and recommending certain tools for inclusion in this survey.

### *Author Contributions*

Conceptualization, P.M.; methodology, P.M.; software, P.M.; validation, P.M. and L.H.; formal analysis, P.M.; investigation, P.M., L.G., L.H, C.O and M.M.; resources, P.M.; data curation, P.M and L.H.; writing—original draft preparation, P.M., L.G., L.H, C.O and M.M.; writing—review and editing, P.M., L.G., L.H, C.O and M.M.; visualization, P.M., L.G., and C.O.; project administration, P.M., L.G., and C.O.; funding acquisition, N/A. All authors have read and agreed to the published version of the manuscript.

## **Appendix A. List of Abbreviations**

|                   |                                                               |
|-------------------|---------------------------------------------------------------|
| <b>ABAC</b>       | Attribute-Based Access Control                                |
| <b>ACL</b>        | Access Control Lists                                          |
| <b>AE</b>         | Authenticated Encryption                                      |
| <b>APT</b>        | Advanced Persistent Threats                                   |
| <b>AP</b>         | Access Point                                                  |
| <b>ATT&amp;CK</b> | (Mitre) Adversarial Tactics, Techniques, and Common Knowledge |
| <b>C2</b>         | Command and Control                                           |
| <b>CBAC</b>       | Code-Based Access Control                                     |
| <b>CI</b>         | Continuous Integration                                        |
| <b>CLI</b>        | Command Line Interface                                        |
| <b>CPE</b>        | Common Platform Enumeration                                   |
| <b>CSRF</b>       | Cross Site Request Forgery                                    |
| <b>CSS</b>        | (ACM) Computing Classification System                         |
| <b>CTI</b>        | Cyber Threat Intelligence                                     |
| <b>CVE</b>        | Common Vulnerabilities and Exposures                          |
| <b>CVSS</b>       | Common Vulnerability Scoring System                           |
| <b>CWE</b>        | Common Weakness Enumeration                                   |
| <b>CyBOK</b>      | Cyber Security Body of Knowledge                              |
| <b>DFBC</b>       | Digital Footprint and Breach Check                            |
| <b>DFD</b>        | Data Flow Diagrams                                            |
| <b>DoS</b>        | Denial of Service                                             |
| <b>DPI</b>        | Deep Packet Inspection                                        |
| <b>DRL</b>        | Deep Reinforcement Learning                                   |
| <b>E2E</b>        | End-to-End                                                    |
| <b>EH</b>         | Ethical Hacking                                               |
| <b>ETSI</b>       | European Telecommunications Standards Institute               |
| <b>FTP</b>        | File Transfer Protocol                                        |
| <b>GAIL</b>       | Generative Adversarial Imitation Learning                     |
| <b>GAN</b>        | Generative Adversarial Network                                |
| <b>GUI</b>        | Graphical User Interface                                      |
| <b>HARM</b>       | Hierarchical Attack Representation Model                      |
| <b>ICS</b>        | Industrial Control Systems                                    |

|                |                                                  |
|----------------|--------------------------------------------------|
| <b>IO2BO</b>   | Integer-Overflow-to-Buffer-Overflow              |
| <b>IoMT</b>    | Internet of Medical Things                       |
| <b>IoT</b>     | Internet of Things                               |
| <b>ISAAF</b>   | Information System Security Assessment Framework |
| <b>LFA</b>     | Link Flooding Attacks                            |
| <b>MAC</b>     | Message Authentication Code                      |
| <b>MITM</b>    | Man-In-The-Middle                                |
| <b>NFC</b>     | Near-Field Communications                        |
| <b>NHS</b>     | National Health Service                          |
| <b>NVD</b>     | National Vulnerability Database                  |
| <b>OSINT</b>   | Open-Source INTelligence                         |
| <b>OSPF</b>    | Open Shortest Path First                         |
| <b>OSSTMM</b>  | Open-Source Security Testing Methodology Manuel  |
| <b>OS</b>      | Operating System                                 |
| <b>OWASP</b>   | Open Web Application Security Project            |
| <b>PCI DSS</b> | Payment Card Industry Data Security Standard     |
| <b>POI</b>     | PHP Object Injection                             |
| <b>PTES</b>    | Penetration Testing Execution Standard           |
| <b>RBAC</b>    | Role-Based Access Control                        |
| <b>RDP</b>     | Remote Desktop Protocol                          |
| <b>RL</b>      | Reinforcement Learning                           |
| <b>SDN</b>     | Software Defined Networking                      |
| <b>SDR</b>     | Software Defined Radio                           |
| <b>SET</b>     | Social Engineering Toolkit                       |
| <b>SOHO</b>    | Small Office and Home Office                     |
| <b>SP</b>      | Special Publication                              |
| <b>SQLIA</b>   | SQL Injection Attacks                            |
| <b>SSJI</b>    | Server-Side Javascript Injection                 |
| <b>TPM</b>     | Trusted Platform Module                          |
| <b>TTP</b>     | Tactics, Techniques, and Procedures              |
| <b>UEFU</b>    | Unrestricted Executable File Upload              |
| <b>UFU</b>     | Unrestricted File Upload                         |
| <b>VAPT</b>    | Vulnerability Assessment and Penetration Testing |
| <b>VM</b>      | Virtual Machine                                  |
| <b>WCMS</b>    | Web Content Management Systems                   |
| <b>XMLi</b>    | XML injection                                    |
| <b>XSS</b>     | Cross Site Scripting                             |

## Appendix B. Classification

| <i>PTES Phase</i>           | <i>Tools</i>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Pre-Engagement Interactions |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Intelligence Gathering      | Bbuzz [56], DFBC [69], ESASCF [73], ESRFuzzer [74], Firmaster [76], IoTFuzzer [83], LTESniffer [88], Lore [87], MaliceScript [92], Owfuzz [108], Pyciuti [118], RT-RCT [124], SVED [133], Scanner++ [125], ShoVAT [128], SuperEye [132], TORPEDO [136], UE Security Reloaded [137], Vulcan [142], Vulnsloit [146]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                |
| Threat Modelling            | Cairis [60], ESSecA [75], HARMer [81], MAL [91], PenQuest [112], TAMELESS [134]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |
| Vulnerability Analysis      | AIBugHunter [52], ARMONY [53], AVAIN [55], Autosplit [54], Bbuzz [56], Black Ostrich [57], Black Widow [58], Bleem [59], Censys [61], Chainsaw [62], Chucky [63], Commix [64], CryptoGuard [65], CuPerFuzzer [66], Deemon [67], Delta [68], Diane [70], EBF [71], ELAID [72], ESASCF [73], ESRFuzzer [74], FUGIO [77], FUSE [78], Firmaster [76], Gail-PT [79], HILTI [82], IoTFuzzer [83], JCOMIX [84], LAID [85], Link [86], Lore [87], Mace [89], MaliceScript [92], Masat [93], Mirage [94], Mitch [95], MoScan [96], NAUTILUS [97], NAVEX [98], No Name (CSRF) [101], No Name (TTCN-3) [102], NodeXP [104], OSV [107], ObjectMap [105], Owfuzz [108], PJCT [115], PURITY [117], PentestGPT [113], PhpSAFE [114], Project Achilles [116], Pyciuti [118], RAT [119], ROSploit [123], RT-RCT [124], Revealer [120], RiscyROP [121], Robin [122], SOA-Scanner [130], SVED [133], Scanner++ [125], SerialDetector [127], ShoVAT [128], Snout [129], Spicy [131], SuperEye [132], TChecker [135], TORPEDO [136], UE Security Reloaded [137], VAPE-BRIDGE [139], VERA [140], VUDDY [141], VulCNN [143], VulDeePecker [144], VulPecker [147], Vulcan [142], Vulnet [145], Vulnsloit [146], WAPTT [148], WebFuzz [149], WebVIM [150] |
| Exploitation                | Chainsaw [62], Commix [64], ELAID [72], ESASCF [73], FUGIO [77], Firmaster [76], Gail-PT [79], LAID [85], LTESniffer [88], Lore [87], MAIT [90], Mace [89], MaliceScript [92], Mirage [94], Mitch [95], NAUTILUS [97], NAVEX [98], NetCAT [99], No Name (TTCN-3) [102], NodeXP [104], OSV [107], Owfuzz [108], PURITY [117], PentestGPT [113], Pyciuti [118], ROSploit [123], Revealer [120], RiscyROP [121], Robin [122], SOA-Scanner [130], SVED [133], SerialDetector [127], Snout [129], TORPEDO [136], Untangle [138], VAPE-BRIDGE [139], Vulnsloit [146], WAPTT [148], WebVIM [150]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Post Exploitation           | ADaMs [51], AVAIN [55], Delta [68], Diane [70], ESRFuzzer [74], GNPassGAN [80], HILTI [82], IoTFuzzer [83], Mirage [94], NeuralNetworkCracking [100], NoCrack [103], OMEN [106], OSV [107], PassGAN [109], PassGPT [110], PasswordCrackingTraining [111], Pyciuti [118], SemanticGuesser [126], Snout [129], Spicy [131], Untangle [138]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Reporting                   | ESASCF [73], Firmaster [76], No Name (TTCN-3) [102], Pyciuti [118]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |

Table B.7: PTES classification



| <i>Mitre ATT&amp;CK</i> | <i>Tools</i>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Reconnaissance          | AIBugHunter [52], ARMONY [53], AVAIN [55], AVAIN [55], Autosploit [54], Bbuzz [56], Black Ostrich [57], Black Widow [58], Bleem [59], Cairis [60], Censys [61], Chainsaw [62], Chucky [63], Commix [64], CryptoGuard [65], CuPerFuzzer [66], DFBC [69], Deemon [67], Delta [68], Delta [68], Diane [70], EBF [71], ELAID [72], ESASCF [73], ESRFuzzer [74], ESSecA [75], FUGIO [77], FUSE [78], Firmaster [76], Gail-PT [79], Gail-PT [79], HILTI [82], HILTI [82], IoTFuzzer [83], JCOMIX [84], LAID [85], LTESniffer [88], Link [86], Lore [87], Mace [89], MaliceScript [92], MaliceScript [92], Masat [93], Mirage [94], Mirage [94], Mitch [95], MoScan [96], NAUTILUS [97], NAVEX [98], No Name (CSRF) [101], No Name (TTCN-3) [102], No Name (TTCN-3) [102], NodeXP [104], OSV [107], ObjectMap [105], Owfuzz [108], PURITY [117], PenQuest [112], PentestGPT [113], PhpSAFE [114], Pyciuti [118], Pyciuti [118], RAT [119], ROSploit [123], RT-RCT [124], RT-RCT [124], Revealer [120], RiscyROP [121], Robin [122], SOA-Scanner [130], SVED [133], Scanner++ [125], SerialDetector [127], ShoVAT [128], ShoVAT [128], Snout [129], Snout [129], Spicy [131], Spicy [131], SuperEye [132], TAMELESS [134], TChecker [135], TORPEDO [136], UE Security Reloaded [137], VAPE-BRIDGE [139], VERA [140], VUDDY [141], VulCNN [143], VulDeePecker [144], VulPecker [147], Vulcan [142], Vulnet [145], Vulnsloit [146], WAPTT [148], WebFuzz [149], WebVIM [150] |
| Resource Development    | AIBugHunter [52], Autosploit [54], Chucky [63], CuPerFuzzer [66], ELAID [72], ESASCF [73], HARMer [81], HILTI [82], LAID [85], MAIT [90], MAL [91], Owfuzz [108], PJCT [115], PJCT [115], Project Achilles [116], Revealer [120], Spicy [131], UE Security Reloaded [137], Untangle [138], VUDDY [141], VulCNN [143], VulPecker [147]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Initial Access          | Black Ostrich [57], Black Widow [58], Censys [61], Chainsaw [62], Commix [64], Deemon [67], ESASCF [73], ESSecA [75], FUGIO [77], FUSE [78], Firmaster [76], Gail-PT [79], JCOMIX [84], Link [86], Lore [87], MAL [91], Mace [89], MaliceScript [92], Masat [93], Mitch [95], NAUTILUS [97], NAVEX [98], NetCAT [99], No Name (CSRF) [101], NodeXP [104], OSV [107], ObjectMap [105], PURITY [117], PentestGPT [113], PhpSAFE [114], Pyciuti [118], RAT [119], Revealer [120], Robin [122], SOA-Scanner [130], SVED [133], Scanner++ [125], SerialDetector [127], ShoVAT [128], TChecker [135], TORPEDO [136], VAPE-BRIDGE [139], VERA [140], Vulcan [142], Vulnet [145], WAPTT [148], WebFuzz [149], WebVIM [150]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
| Execution               | Bbuzz [56], ESASCF [73], Lore [87], Mirage [94], PentestGPT [113], ROSploit [123], RiscyROP [121], SVED [133], Vulnsloit [146]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Persistence             |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Privilege Escalation    |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Defense Evasion         |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Credential Access       | ADaMs [51], Firmaster [76], GNPASSGAN [80], LTESniffer [88], NeuralNetworkCracking [100], NoCrack [103], OMEN [106], PassGAN [109], PassGPT [110], PasswordCrackingTraining [111], SemanticGuesser [126]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Discovery               | AVAIN [55], Cairis [60], Firmaster [76], HILTI [82], Masat [93], PenQuest [112], RT-RCT [124], Snout [129], Spicy [131], TAMELESS [134], Vulcan [142]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Lateral Movement        |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Collection              | HILTI [82], Spicy [131]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Command And Control     |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Exfiltration            |                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Impact                  | Revealer [120], TORPEDO [136]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |

Table B.8: Mitre ATT&CK classification

| <i>Mitre ATT&amp;CK</i>                                | <i>Tools</i>                                                                                                                                                                                                                                                                                                                                                                                                             |
|--------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Collection: Adversary-In-The-Middle                    | HILTI [82], Spicy [131]                                                                                                                                                                                                                                                                                                                                                                                                  |
| Credential Access: Brute Force: Password Cracking      | GNPassGAN [80], PassGAN [109], PasswordCrackingTraining [111]                                                                                                                                                                                                                                                                                                                                                            |
| Discovery: Cloud Infrastructure Discovery              | MASAT [93], VULCAN [142]                                                                                                                                                                                                                                                                                                                                                                                                 |
| Discovery: Network Service Discovery                   | AVAIN [55], Firmaster [76], HILTI [82], RT-RCT [124], Snout [129], Spicy [131]                                                                                                                                                                                                                                                                                                                                           |
| Enterprise: Credential Access: Brute Force             | Firmaster [76]                                                                                                                                                                                                                                                                                                                                                                                                           |
| Enterprise: Credential Access: Network Sniffing        | LTESniffer [88]                                                                                                                                                                                                                                                                                                                                                                                                          |
| Enterprise: Impact: Service Stop                       | TORPEDO [136]                                                                                                                                                                                                                                                                                                                                                                                                            |
| Enterprise: Initial Access: External Remote Services   | NetCAT [99]                                                                                                                                                                                                                                                                                                                                                                                                              |
| Execution                                              | Bbuzz [56], Lore [87], Mirage [94], PentestGPT [113], ROSploit [123], SVED [133], Vulnsloit [146]                                                                                                                                                                                                                                                                                                                        |
| Execution: Inter-Process Communication                 | RiscyROP [121]                                                                                                                                                                                                                                                                                                                                                                                                           |
| Gather Victim Network Information                      | Lore [87], PentestGPT [113], SVED [133]                                                                                                                                                                                                                                                                                                                                                                                  |
| Impact: Endpoint Denial Of Service                     | Revealer [120]                                                                                                                                                                                                                                                                                                                                                                                                           |
| Initial Access                                         | Gail-PT [79], Lore [87], OSV [107], PentestGPT [113], SVED [133]                                                                                                                                                                                                                                                                                                                                                         |
| Initial Access: Exploit Public Facing Application      | Commix [64], JCOMIX [84], Mitch [95], No Name (CSRF) [101], PURITY [117], Puciuty [118], Robin [122], Vulnet [145], WebVIM [150], ZGrab [61]                                                                                                                                                                                                                                                                             |
| Initial Access: Exploit Public Facing-Application      | WAPTT [148]                                                                                                                                                                                                                                                                                                                                                                                                              |
| Initial Access: Exploit Public-Facing Application      | Black Ostrich [57], Black Widow [58], Chainsaw [62], Deemon [67], FUGIO [77], FUSE [78], Firmaster [76], Link [86], MASAT [93], Mace [89], MaliceScript [92], NAUTILUS [97], NAVEX [98], NodeXP [104], ObjectMap [105], PhpSAFE [114], Revealer [120], SOA-Scanner [130], Scanner++ [125], SerialDetector [127], ShoVAT [128], TChecker [135], TORPEDO [136], VAPE-BRIDGE [139], VERA [140], VULCAN [142], WebFuzz [149] |
| Reconnaissance: Active Scanning                        | LTESniffer [88], TORPEDO [136]                                                                                                                                                                                                                                                                                                                                                                                           |
| Reconnaissance: Active Scanning Vulnerability Scanning | NodeXP [104]                                                                                                                                                                                                                                                                                                                                                                                                             |

| <i>Mitre ATT&amp;CK</i>                                             | <i>Tools</i>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|---------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Reconnaissance: Active Scanning: Vulnerability Scanning             | AIBugHunter [52], ARMONY [53], AVAIN [55], Autosexploit [54], Bbuzz [56], Black Ostrich [57], Black Widow [58], Chainsaw [62], Chucky [63], Commix [64], CryptoGuard [65], CuPerFuzzer [66], DELTA [68], DIANE [70], Deemon [67], EBF [71], ELAID [72], ESRFuzzer [74], FUGIO [77], FUSE [78], Firmaster [76], Gail-PT [79], HILTI [82], IoTFuzzer [83], JCOMIX [84], LAID [85], Link [86], Lore [87], MASAT [93], Mace [89], MaliceScript [92], Mirage [94], Mitch [95], NAUTILUS [97], NAVEX [98], No Name (CSRF) [101], No Name (TTCN-3) [102], OSV [107], ObjectMap [105], Owfuzz [108], PURITY [117], PentestGPT [113], PhpSAFE [114], Puciuty [118], ROSploit [123], RT-RCT [124], Revealer [120], RiscyROP [121], Robin [122], SOA-Scanner [130], SVED [133], Scanner++ [125], SerialDetector [127], ShoVAT [128], Snout [129], Spicy [131], SuperEye [132], TChecker [135], UE Security Reloaded [137], VAPE-BRIDGE [139], VERA [140], VUDDY [141], VULCAN [142], VulCNN [143], VulDeePecker [144], VulPecker [147], Vulnet [145], Vulnsloit [146], WAPTT [148], WebFuzz [149], WebVIM [150], ZGrab [61] |
| Reconnaissance: Gather Victim Identity Information                  | DFBC [69]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Reconnaissance: Gather Victim Network Information                   | AVAIN [55], DELTA [68], Gail-PT [79], HILTI [82], MaliceScript [92], Mirage [94], Puciuty [118], RT-RCT [124], ShoVAT [128], Snout [129], Spicy [131]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Reconnaissance: Gather Victim Network Information: Network Topology | No Name (TTCN-3) [102]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Reconnaissance: Resource Development                                | HARMer [81]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Resource Development: Develop Capabilities                          | HILTI [82], PICT [115], Spicy [131]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Resource Development: Develop Capabilities: Exploits                | ELAID [72], LAID [85], Owfuzz [108], Project Achilles [116], UE Security Reloaded [137], VulCNN [143]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Resource Development: Develop Capabilities: Malware                 | MAIT [90]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Resource Development: Obtain Capabilities: Exploits                 | AIBugHunter [52], Autosexploit [54], Chucky [63], CuPerFuzzer [66], PICT [115], Revealer [120], VUDDY [141], VulPecker [147]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |

Table B.9: Mitre ATT&CK classification (Details)

| <i>CyBOK</i>                                                                                                                              | <i>Tools</i>                                                                                                                                         |
|-------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attacks & Defences: Adversarial Behaviours                                                                                                | Cairis [60], ESASCF [73], ESSecA [75], HARMer [81], Lore [87], MAL [91], PenQuest [112], PenQuest [112], SVED [133], TAMELESS [134]                  |
| Attacks & Defences: Malware & Attack Technology: Malware Analysis: Analysis Techniques: Static Analysis/Dynamic Analysis                  | MAIT [90]                                                                                                                                            |
| Human, Organisational & Regulatory Aspects: Human Factors                                                                                 | ESSecA [75], TAMELESS [134]                                                                                                                          |
| Human, Organisational & Regulatory Aspects: Privacy & Online Rights: Privacy Engineering: Privacy Evaluation                              | DFBC [69]                                                                                                                                            |
| Infrastructure Security: Applied Cryptography: Cryptographic Implementation: Api Design For Cryptographic Libraries                       | CryptoGuard [65]                                                                                                                                     |
| Infrastructure Security: Applied Cryptography: Cryptographic Implementation: Cryptographic Libraries                                      | Firmaster [76]                                                                                                                                       |
| Infrastructure Security: Cyber Physical Systems                                                                                           | ESSecA [75], TAMELESS [134]                                                                                                                          |
| Infrastructure Security: Network Security                                                                                                 | AVAIN [55], Cairis [60], Delta [68], ESASCF [73], Gail-PT [79], HARMer [81], HILTI [82], Lore [87], Masat [93], NetCAT [99], SVED [133], Spicy [131] |
| Infrastructure Security: Network Security: Network Protocols And Their Security                                                           | OSV [107], SuperEye [132], Vulnsloit [146]                                                                                                           |
| Infrastructure Security: Network Security: Network Protocols And Their Security: Security At The Internet Layer                           | Bbuzz [56]                                                                                                                                           |
| Infrastructure Security: Network Security: Network Protocols And Their Security: Security At The Internet Layer: Ipv6 Security            | No Name (TTCN-3) [102]                                                                                                                               |
| Infrastructure Security: Network Security: Networking Applications                                                                        | Vulcan [142]                                                                                                                                         |
| Infrastructure Security: Network Security: Networking Applications: Local Area Networks                                                   | ESRFuzzer [74], Firmaster [76], HILTI [82], No Name (TTCN-3) [102], Pyciuti [118], Spicy [131]                                                       |
| Infrastructure Security: Network Security: Networking Applications: Wireless Networks                                                     | ESRFuzzer [74], Firmaster [76], LTESniffer [88], Ow-fuzz [108], RT-RCT [124], Snout [129], UE Security Reloaded [137]                                |
| Infrastructure Security: Network Security: Other Network Security Topics: Cloud And Data Center Security                                  | Masat [93], Vulcan [142]                                                                                                                             |
| Infrastructure Security: Network Security: Software-Defined Networking And Network Function Virtualization                                | Delta [68]                                                                                                                                           |
| Infrastructure Security: Physical Layer & Telecommunications Security: Identification: Attacks On Physical Layer Identification           | Snout [129]                                                                                                                                          |
| Operating Systems & Virtualization Security: Operating System Hardening                                                                   | ROSploit [123]                                                                                                                                       |
| Physical Layer & Telecommunications Security: Physical Layer Security Of Selected Communication Technologies: Cellular Networks: 4G (Lte) | LTESniffer [88]                                                                                                                                      |

| <i>CyBOK</i>                                                                                                                                                            | <i>Tools</i>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Physical Layer & Telecommunications Security:<br>Physical Layer Security Of Selected Communication<br>Technologies: Cellular Networks: 5G                               | UE Security Reloaded [137]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Resource Development: Develop Capabilities: Ex-<br>ploits                                                                                                               | ESASCF [73]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Software And Platform Security: Software Security:<br>Categories Of Vulnerabilities: Memory Management<br>Vulnerabilities                                               | ARMONY [53], ELAID [72], IoTFuzzer [83], LAID<br>[85], WAPTT [148]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Software And Platform Security: Software Security:<br>Detection Of Vulnerabilities                                                                                      | ARMONY [53], AVAIN [55], Autosploit [54], Bbuzz<br>[56], Black Ostrich [57], Black Widow [58], Cairis<br>[60], Censys [61], Chainsaw [62], Commix [64], Cryp-<br>toGuard [65], Deemon [67], EBF [71], ESASCF [73],<br>FUGIO [77], FUSE [78], Firmaster [76], HILTI [82],<br>JCOMIX [84], Link [86], Mace [89], MaliceScript [92],<br>Mirage [94], Mitch [95], MoScan [96], NAUTILUS<br>[97], NAVEX [98], No Name (CSRF) [101], No Name<br>(TTCN-3) [102], NodeXP [104], OSV [107], Ob-<br>jectMap [105], Owfuzz [108], PJCT [115], PURITY<br>[117], PentestGPT [113], Project Achilles [116], Py-<br>ciuti [118], RAT [119], ROSploit [123], RT-RCT<br>[124], Revealer [120], SOA-Scanner [130], Scan-<br>ner++ [125], SerialDetector [127], ShoVAT [128],<br>Snout [129], Spicy [131], SuperEye [132], TChecker<br>[135], TORPEDO [136], UE Security Reloaded [137],<br>VAPE-BRIDGE [139], VERA [140], VulDeePecker<br>[144], Vulcan [142], Vulnet [145], Vulnsloit [146],<br>WAPTT [148], WebFuzz [149], WebVIM [150] |
| Software And Platform Security: Software Security:<br>Detection Of Vulnerabilities: Dynamic Detection                                                                   | Bbuzz [56], Black Ostrich [57], CuPerFuzzer [66], Di-<br>ane [70], EBF [71], Project Achilles [116]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Software And Platform Security: Software Security:<br>Detection Of Vulnerabilities: Dynamic Detection:<br>Black-Box Fuzzing                                             | Bleem [59], Delta [68], IoTFuzzer [83], Owfuzz [108]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                    |
| Software And Platform Security: Software Security:<br>Detection Of Vulnerabilities: Dynamic Detection:<br>Generating Relevant Executions: Dynamic Symbolic<br>Execution | RiskyROP [121]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
| Software And Platform Security: Software Security:<br>Detection Of Vulnerabilities: Static Detection                                                                    | AIBugHunter [52], Chucky [63], ELAID [72], LAID<br>[85], PhpSAFE [114], Untangle [138], VUDDY [141],<br>VulCNN [143], VulPecker [147]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
| Software And Platform Security: Software Security:<br>Dynamic Detection                                                                                                 | WebFuzz [149]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Software And Platform Security: Software Security:<br>Side-Channel Vulnerabilities                                                                                      | NetCAT [99]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |
| Software And Platform Security: Web & Mobile Se-<br>curity                                                                                                              | Black Ostrich [57], EBF [71], Mace [89], MoScan [96],<br>NAUTILUS [97], NAVEX [98], RAT [119], Revealer<br>[120], Robin [122], Scanner++ [125], ShoVAT [128],<br>VAPE-BRIDGE [139]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Software And Platform Security: Web & Mobile Se-<br>curity: Client Side Vulnerabilities And Mitigations                                                                 | MaliceScript [92]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                       |

| <i>CyBOK</i>                                                                                                                                                             | <i>Tools</i>                                                                                                                                                             |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations                                                                       | Censys [61], PURITY [117], Pyciuti [118], Robin [122], SOA-Scanner [130], TORPEDO [136], VERA [140], Vulnet [145]                                                        |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities                                            | Commix [64], FUGIO [77], ObjectMap [105], Serial-Detector [127]                                                                                                          |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities: Command Injection                         | JCOMIX [84], NodeXP [104]                                                                                                                                                |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities: Cross-Site Request Forgery (Csrf)         | Deemon [67], Mitch [95], No Name (CSRF) [101]                                                                                                                            |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities: Cross-Site Scripting (Xss)                | Black Widow [58], Chainsaw [62], PhpSAFE [114], TChecker [135], WAPTT [148], WebFuzz [149]                                                                               |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities: Cross-Site Scripting (Xss): Reflected Xss | Link [86]                                                                                                                                                                |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities: Sql-Injection                             | Chainsaw [62], PhpSAFE [114], TChecker [135], WAPTT [148], WebVIM [150]                                                                                                  |
| Software And Platform Security: Web & Mobile Security: Server Side Vulnerabilities And Mitigations: Injection Vulnerabilities: User Uploaded Files                       | FUSE [78]                                                                                                                                                                |
| Systems Security: Authentication, Authorisation & Accountability: Authentication: Passwords                                                                              | ADaMs [51], GNPASSGAN [80], NeuralNetwork-Cracking [100], NoCrack [103], OMEN [106], PassGAN [109], PassGPT [110], PasswordCrackingTraining [111], SemanticGuesser [126] |
| Systems Security: Distributed Systems Security                                                                                                                           | Cairis [60], MAL [91], PenQuest [112]                                                                                                                                    |

Table B.10: CyBOK classification

| <i>ACM CCS</i>                                                                                               | <i>Tools</i>                                                                                                                                                            |
|--------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Hardware: Emerging Technologies: Analysis And Design Of Emerging Devices And Systems: Emerging Architectures | AVAIN [55], Diane [70], EBF [71], IoTFuzzer [83], Mirage [94], ROSploit [123], RT-RCT [124], Snout [129]                                                                |
| Human-Centered Computing: Human Computer Interaction (Hci): Interactive Systems And Tools                    | TAMELESS [134]                                                                                                                                                          |
| Networks: Network Components: Intermediate Nodes: Routers                                                    | ESRFuzzer [74]                                                                                                                                                          |
| Networks: Network Protocols: Network Layer Protocols: Routing Protocols                                      | No Name (TTCN-3) [102], OSV [107]                                                                                                                                       |
| Security And Privacy: Cryptography                                                                           | EBF [71]                                                                                                                                                                |
| Security And Privacy: Human And Societal Aspects Of Security And Privacy                                     | DFBC [69]                                                                                                                                                               |
| Security And Privacy: Intrusion/Anomaly Detection And Malware Mitigation: Malware And Its Mitigation         | MAIT [90]                                                                                                                                                               |
| Security And Privacy: Network Security                                                                       | AVAIN [55], Bbuzz [56], Censys [61], NetCAT [99], No Name (TTCN-3) [102], OSV [107], Pyciuti [118], RT-RCT [124], SuperEye [132], Vulcan [142], Vulnsloit [146]         |
| Security And Privacy: Network Security: Mobile And Wireless Security                                         | ESRFuzzer [74], Firmaster [76], LTESniffer [88], Owfuzz [108], Scanner++ [125], Snout [129], UE Security Reloaded [137]                                                 |
| Security And Privacy: Network Security: Security Protocols                                                   | HILTI [82], No Name (TTCN-3) [102], Spicy [131]                                                                                                                         |
| Security And Privacy: Network Security: Web Protocol Security                                                | Bbuzz [56]                                                                                                                                                              |
| Security And Privacy: Security Services: Authorization                                                       | ADaMs [51], GNPassGAN [80], NeuralNetworkCracking [100], NoCrack [103], OMEN [106], PassGAN [109], PassGPT [110], PasswordCrackingTraining [111], SemanticGuesser [126] |
| Security And Privacy: Software And Application Security                                                      | CryptoGuard [65], VulDeePecker [144]                                                                                                                                    |
| Security And Privacy: Software And Application Security: Domain-Specific Security And Privacy Architectures  | ESSecA [75], MAL [91], PenQuest [112]                                                                                                                                   |
| Security And Privacy: Software And Application Security: Software Reverse Engineering                        | RiscyROP [121], VulCNN [143]                                                                                                                                            |
| Security And Privacy: Software And Application Security: Software Security Engineering                       | AIBugHunter [52], Chucky [63], CuPerFuzzer [66], ELAID [72], LAID [85], PJCT [115], Project Achilles [116], Untangle [138], VUDDY [141], VulPecker [147]                |

| <i>ACM CCS</i>                                                                           | <i>Tools</i>                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Security And Privacy: Software And Application Security: Web Applications Security       | Black Ostrich [57], Black Widow [58], Censys [61], Chainsaw [62], Commix [64], Deemon [67], FUGIO [77], FUSE [78], JCOMIX [84], Link [86], Mace [89], MaliceScript [92], Mitch [95], MoScan [96], NAUTILUS [97], NAVEX [98], No Name (CSRF) [101], NodeXP [104], ObjectMap [105], PURITY [117], PhpSAFE [114], Pyciuti [118], RAT [119], Robin [122], SOA-Scanner [130], SerialDetector [127], ShoVAT [128], TChecker [135], TORPEDO [136], VAPE-BRIDGE [139], VERA [140], Vulnet [145], WAPTT [148], WebFuzz [149], WebVIM [150]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
| Security And Privacy: Systems Security: Denial Of Service Attacks                        | Revealer [120]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                        |
| Security And Privacy: Systems Security: Distributed Systems Security                     | MAL [91], PenQuest [112]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                              |
| Security And Privacy: Systems Security: Vulnerability Management: Penetration Testing    | Cairis [60], Diane [70], ESASCF [73], ESSecA [75], Gail-PT [79], HARMer [81], Lore [87], MAL [91], Mirage [94], PenQuest [112], PentestGPT [113], Pyciuti [118], SVED [133], TAMELESS [134]                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |
| Security And Privacy: Systems Security: Vulnerability Management: Vulnerability Scanners | AIBugHunter [52], ARMONY [53], AVAIN [55], Autosploit [54], Black Ostrich [57], Black Widow [58], Bleem [59], Censys [61], Chainsaw [62], Chucky [63], Commix [64], CryptoGuard [65], CuPerFuzzer [66], Deemon [67], Delta [68], EBF [71], ELAID [72], ESSecA [75], FUGIO [77], FUSE [78], Firmaster [76], HILTI [82], IoTFuzzer [83], JCOMIX [84], LAID [85], Link [86], Mace [89], MaliceScript [92], Masat [93], Mitch [95], MoScan [96], NAUTILUS [97], NAVEX [98], No Name (CSRF) [101], No Name (TTCN-3) [102], NodeXP [104], OSV [107], ObjectMap [105], Owfuzz [108], PJCT [115], PURITY [117], PhpSAFE [114], Project Achilles [116], Pyciuti [118], RAT [119], ROSploit [123], RT-RCT [124], Revealer [120], RiscyROP [121], Robin [122], SOA-Scanner [130], Scanner++ [125], SerialDetector [127], ShoVAT [128], Snout [129], Spicy [131], SuperEye [132], TChecker [135], TORPEDO [136], UE Security Reloaded [137], Untangle [138], VAPE-BRIDGE [139], VERA [140], VUDDY [141], VulCNN [143], VulDeePecker [144], VulPecker [147], Vulcan [142], Vulnet [145], Vulnsloit [146], WAPTT [148], WebFuzz [149], WebVIM [150] |

Table B.11: ACM CCS classification



## Appendix C. Review of Tools

We present a review of the EH tools included in our survey, in alphabetical order according to their names.

### *Appendix C.1. Reducing bias in modelling real-world password strength via deep learning and dynamic dictionaries*

**ADaMs** (2021, Pasquini et al. [51]) is an advanced tool aimed at improving the precision of modelling real-world password strengths. This tool leverages deep neural networks to simulate the methodology used by adversaries when constructing attack configurations. The efficiency of ADaMs was demonstrated through case studies involving MyHeritage and Youku using the rules-set generated and RockYou as the external dictionary. For MyHeritage, ADaMs' attack matches the precision of the optimal dictionary approach and achieves a comparable number of successful guesses. Similarly, for Youku, ADaMs outperforms the optimal dictionary in terms of guessing speed, achieving faster results within the initial ( $10^{11}$ ) guesses, demonstrating its effectiveness in real-world scenarios.

### *Appendix C.2. AIBugHunter: A Practical tool for predicting, classifying and repairing software vulnerabilities*

**AIBugHunter** (2023, Fu et al. [52]) is a machine learning-based approach to detecting and mitigating software security bugs within C and C++. This package is integrated into Visual Studio Code to better bridge the gap between real-world developers and academic contributions to vulnerability detection frameworks. The tool was around 10% to 141% more effective than the compared baseline models at predicting CWE-ID within evaluated code samples.

### *Appendix C.3. ARMORY: An automatic security testing tool for buffer overflow defect detection*

**ARMONY** (2013, Chen et al. [53]) is a kernel-based tool for detecting zero-day Buffer Overflow vulnerabilities to prevent the overflowing of sensitive data structures by testing the system and recording the results in a dump file. The components of the software include a coordinator, a checker, and two message storages.

### *Appendix C.4. Autosplit: A Fully Automated Framework for Evaluating the Exploitability of Security Vulnerabilities*

**Autosplit** (2020, Moscovich et al. [54]) is a framework for virtualising and evaluating the components within a system that are required for exploitation via a given vector. Although in the paper the authors outline several factors that can affect exploitation, but the simulation agent only supports four actions: stopping services, deleting packages, changing system firewall rules, and modifying file permissions. The tool was tested against a Metasploitable 2 machine, which is designed to be intentionally vulnerable against a set number of attacks, and the attacker agent only supported Metasploit-based attacks, once again limiting what exploits can and cannot be assessed to those supported with a Metasploit module.

### *Appendix C.5. AVAIN – A Framework for Automated Vulnerability Indication for the IoT in IP-based Networks*

**AVAIN** (2019, Egert et al. [55]) is a framework for Automated Vulnerability Indication in IP-based Internet of Things (IoT) networks. It aims at enhancing security practices of IoT system administrators by automatically deploying existing tools to generate results, presented according to the Common Vulnerability Scoring System (CVSS). The framework's modular design enables the user to integrate arbitrary vulnerability scanners and analysis methods. AVAIN includes four components: the *Controller* processes user instructions to orchestrate the tasks. The *Module Updater* keeps modules up to date, the *Scanner* performs vulnerability scanning, and the *Analyser* processes the collected data.

#### *Appendix C.6. Bbuzz: A bit-aware fuzzing framework for network protocol systematic reverse engineering and analysis*

**Bbuzz** (2017, Blumbergs et al. [56]) is an open-source bit-aware network protocol fuzzing framework designed for systematic reverse engineering and analysis of network protocols. Operating at Layer-2, Bbuzz facilitates rapid protocol assessment, automatic test case creation, and user-friendly fuzzing. In a proprietary NATO Link-1 protocol case study, researchers used Bbuzz to efficiently reverse engineer the protocol, revealing critical components within a single day.

#### *Appendix C.7. Black Ostrich: Web Application Scanning with String Solvers*

**Black Ostrich** (2023, Eriksson et al. [57]) is a tool for crawling web applications with a content-aware approach. The tool is able to differentiate expected input formats such as email addresses, usernames, etc., using regex interpretation to discover more pages on web applications than other crawling approaches. This tool was shown to be effective when compared against existing web application crawlers such as ZAP, Enemy, and Arachni. This tool was shown to achieve 99% coverage, achieving high effectiveness in crawling capability. The tool also showed a 52% improvement over existing methods when discovering vulnerable patterns within those same web pages.

#### *Appendix C.8. Black Widow: Blackbox Data-driven Web Scanning*

**Black Widow** (2021, Eriksson et al. [58]) uses a black box data-driven approach for deep crawling and scanning of modern web apps. It focuses on three core pillars: navigation modelling, traversing, and tracking inter-state dependencies. Black Widow demonstrates significant code coverage improvements compared to other crawlers. Moreover, it excels in vulnerability scanning, detecting more cross-site scripting vulnerabilities without false positives, identifying missed vulnerabilities in older applications, and uncovering new vulnerabilities in production software like HotCRP, osCommerce, PrestaShop, and WordPress.

#### *Appendix C.9. Bleem: Packet Sequence Oriented Fuzzing for Protocol Implementations*

**Bleem** (2023, Luo et al. [59]) is a novel black-box fuzzer designed to enhance the vulnerability detection of protocol implementations through packet-sequence-oriented fuzzing. It features a noninvasive feedback mechanism that examines system outputs (packet sequences) to deduce the internal state transitions within the protocol implementation. This feedback guides the fuzzing process, including generating packet sequences that align with the protocol's logic. Bleem significantly outperforms state-of-the-art protocol fuzzers in terms of branch coverage and vulnerability detection. It achieves up to a 175% increase in branch coverage within 24 hours compared to tools like Peach. Furthermore, Bleem discovered 15 security-critical vulnerabilities across prominent protocol implementations, resulting in 10 CVEs being attributed, showcasing its effectiveness in identifying previously undetected vulnerabilities.

#### *Appendix C.10. Contextualisation of Data Flow Diagrams for Security Analysis*

**Cairis** (2020, Faily et al. [60]) is a novel tool for identifying tainted data flows through the contextualisation of Data Flow Diagrams (DFDs) with other models related to usability and requirements. This adaptation of taint analysis, traditionally employed in code analysis to detect insecure data handling, is applied to design-level analysis. The Cairis tool identifies potential taint sources from human interactions or system processes, as represented in DFDs. The practical viability and the possibility of incorporating it into this tool's current security analysis workflows are demonstrated through its implementation in an open-source software platform.

#### *Appendix C.11. A Search Engine Backed by Internet-Wide Scanning*

**Censys** (2015, Durumeric et al. [61]) is a vulnerability scanning tool that leverages data from continuous Internet-wide scans. Censys uses existing tools, specifically ZMap [170] and ZGrab, for hosting discovery scans across the IPv4 address spaces and application-layer handshakes. Case studies demonstrate Censys's application in analyzing Industrial Control Systems, vulnerabilities like Heartbleed and SSLv3, and institutional attack surfaces. The application of the tool shows Censys's ability to identify vulnerable devices and networks quickly, generate statistical reports on usage patterns, and provide insights into the security posture of devices across the internet.

#### *Appendix C.12. Chainsaw: Chained Automated Workflow-based Exploit Generation*

**Chainsaw** (2016, Alhuzali et al. [62]) offers a solution for automated exploit generation in web applications, surpassing existing methods in identifying and exploiting web injection vulnerabilities. It adeptly handles challenges posed by diverse web app structures, user input, and database back-ends by constructing precise models of application workflows, schemes, and native functions. Evaluated across 9 open-source applications, Chainsaw produced over 199 high-quality first- and second-order injection exploits, showcasing its superiority over comparable approaches in exploit generation for web vulnerabilities.

#### *Appendix C.13. Chucky: exposing missing checks in source code for vulnerability discovery*

**Chucky** (2013, Yamaguchi et al. [63]) is a tool aimed at expediting the auditing of software by exposing missing checks in source code, particularly focusing on input validation. By using static tainting techniques, Chucky identifies anomalies and omitted security-critical conditions, effectively pinpointing 12 previously undiscovered vulnerabilities in Pidgin and LibTIFF among five popular open-source projects. This method enhances the process of discovering security flaws by highlighting crucial areas of missing input validation checks.

#### *Appendix C.14. Commix: automating evaluation and exploitation of command injection vulnerabilities in Web applications*

**Commix** (2019, Stasinopoulos et al. [64]), short for COMMand Injection eXploiter, is an open-source tool aimed at automating the detection and exploitation of command injection flaws in web applications. Commix’s methodology encompasses attack vector generation, a vulnerability detection module, and an exploitation module. The vulnerability detection module utilises the generated attack vectors to probe for potential command injection vulnerabilities within target web applications by injecting and attempting command execution. Subsequently, the exploitation module leverages any confirmed vulnerabilities, exploiting them with the successful attack vector to facilitate the execution of arbitrary commands by the attacker. Commix underwent threefold experimentation—in a virtual lab, against other tools, and within real-world applications—demonstrating its efficacy in identifying and exploiting command injection vulnerabilities across these scenarios, thereby demonstrating its significant value in cybersecurity practices.

#### *Appendix C.15. CryptoGuard: High Precision Detection of Cryptographic Vulnerabilities in Massive-sized Java Projects*

**CryptoGuard** (2019, Rahaman et al. [65]) is a tool with efficient slicing algorithms in Java programs that reduce false alerts by 76% to 80% in cryptographic API misuse threats. Running on large-scale projects like Apache and Android apps, CRYPTO GUARD provided security insights and aided projects like Spark, Ranger, and Ofbiz in code hardening. The tool achieved 98.61% precision by manually confirming 1,277 true positives out of 1,295 Apache alerts. Additionally, it established a benchmark with basic and advanced cases, extensively comparing with CrySL, SpotBugs, and Coverity.

#### *Appendix C.16. Android Custom Permissions Demystified: From Privilege Escalation to Design Shortcomings*

**CuPerFuzzer** (2021, Li et al. [66]) is an automatic fuzzing tool designed to detect vulnerabilities within the Android OS related to custom permissions. Through extensive testing, it uncovered 2,384 effective cases and identified 30 critical paths, exposing severe design shortcomings within the Android permission framework. These issues include dangling custom permissions, inconsistent permission group mapping, permission elevating, and inconsistent permission definition, potentially allowing malicious apps to gain unauthorised system permissions.

#### *Appendix C.17. Deemon: Detecting CSRF with Dynamic Analysis and Property Graphs*

**Deemon** (2017, Pellegrino et al. [67]) introduces an automated security testing framework for CSRF vulnerability detection. Utilising a novel modelling paradigm capturing web app aspects in a unified property graph, it autonomously constructs models from dynamic traces and identifies potentially vulnerable operations via graph traversals. Deemon’s validation approach conducts security tests, and 14 previously unknown CSRF vulnerabilities across 10 open-source web applications have been discovered, showing its efficacy in detecting exploitable issues threatening user accounts and entire websites.

#### *Appendix C.18. Delta: A security assessment framework for software-defined networks.*

**Delta** (2017, Lee et al. [68]) is a novel vulnerability analysis tool that focuses specifically on Software Defined Networking (SDN) and utilizes known published attacks. The tool uses a fuzzing module that automatically detects zero-day vulnerabilities and has been designed specifically for OpenFlow controller platforms.

#### *Appendix C.19. DFBC Recon Tool: Digital Footprint and Breach Check Reconnaissance Tool*

**DFBC** (2021, Yusof et al. [69]) is a reconnaissance tool that provides a Digital Footprint and Breach Check. This software can extract user information that is publicly available and check the breach activity status for accounts with high speed. The tool has both a CLI and GUI and focuses on gathering data on social networks such as Facebook and X/Twitter, as well as email breaches.

#### *Appendix C.20. Diane: Identifying fuzzing triggers in apps to generate under-constrained inputs for iot devices*

**Diane** (2021, Redini et al. [70]) is a tool for vulnerability analysis in IoT targeting Android applications used to control IoT devices, at the network level and UI level by detecting fuzzing triggers. The software has been tested and has successfully identified nine zero-day vulnerabilities. This tool can be applied to discover vulnerabilities in Smart Home appliances such as door Smart Locks. Given its reliance on dynamic analysis, Diane lacks the capability to detect fuzzing triggers that are not executed by the application. Additionally, it is unable to perform fuzzing on nested Java objects.

#### *Appendix C.21. Finding Security Vulnerabilities in IoT Cryptographic Protocol and Concurrent Implementations*

**EBF** (2021, Aljaafari et al. [71]) is a tool used for the discovery of vulnerabilities within IoT devices. It uses static and dynamic analysis to discover issues surrounding memory safety, race conditions, thread leak and arithmetic overflow. The tool simulates a server and a client in order to detect such vulnerabilities within the implemented protocol. The tool demonstrated its effectiveness by detecting a previously unknown race condition bug within WOLFMQTT in only 15 minutes with 22 MB memory consumption. The tool was also verified against pre-existing vulnerabilities within OpenSSL and successfully identified the issues as expected.

#### *Appendix C.22. ELAID: detecting integer-Overflow-to-Buffer-Overflow vulnerabilities by light-weight and accurate static analysis*

**ELAID** (2020, Xu et al. [72]) (Enhanced Lightweight and Accurate method of static IO2BO vulnerability Detection) is a tool designed for detecting Integer-Overflow-to-Buffer-Overflow (IO2BO) vulnerabilities. Built on LLVM [171], ELAID’s indirect call analysis aims to eliminate false positives. It has been tested on NIST’s SAMATE Juliet 1.2 suite [172] and other real-world applications, demonstrating the ability to detect 152 vulnerabilities without false positives. However, the authors acknowledge the need for a combined symbolic execution and fuzzing approach to enhance practicality.

*Appendix C.23. ESASCF: Expertise Extraction, Generalization and Reply Framework for Optimized Automation of Network Security Compliance*

ESASCF (2023, Ghanem et al. [73]) is a tool designed to address the resource-intensity and repetitiveness of the network security auditing process by automating the extraction, processing, storage, and reuse of expertise in similar scenarios or during periodic re-testing. ESASCF leverages industrial and open-source vulnerability assessment and penetration testing tools to automate the security compliance (SC) process. It is designed to autonomously handle SC re-testing, offloading human experts from repetitive SC segments, allowing them to focus on more critical tasks in ad-hoc compliance tests. The framework was tested on networks of different sizes, demonstrating time efficiency and testing effectiveness improvements. Specifically, ESASCF significantly reduces the time required for an expert to complete the first security compliance of typical corporate networks by 50% and 20% in re-testing scenarios.

*Appendix C.24. ESRFuzzer: an enhanced fuzzing framework for physical SOHO router devices to discover multi-Type vulnerabilities*

ESRFuzzer (2021, Zhang et al. [74]) (Enhanced SOHO Router Fuzzing Framework) is as a vulnerability discovery tool tailored for small office and home office (SOHO) routers. It operates through an automated FWSR fuzzing framework, incorporating KEY-VALUE and CONF-READ semantic models with power management for testing environment recovery. Equipped with diverse mutation rules and monitoring mechanisms, the tool efficiently identifies various vulnerability types. ESRFuzzer excels in discovering CONF and READ operation issues, particularly in general and D-CONF modes. Testing on 10 routers revealed 136 issues, with 120 of them confirmed as 0-day vulnerabilities.

ESRFuzzer (2021, Zhang et al. [74]) (Enhanced SOHO Router Fuzzing Framework) is a vulnerability discovery tool for small office and home office (SOHO) routers, employing an automated FWSR fuzzing framework. It uses KEY-VALUE and CONF-READ semantic models with power management for testing environment recovery. With diverse mutation rules and monitoring mechanisms, it identifies various vulnerability types. In general and D-CONF modes, ESRFuzzer excels in discovering CONF and READ operation issues. Testing on 10 routers unveiled 136 issues, 120 confirmed as 0-day vulnerabilities.

*Appendix C.25. ESSecA: An automated expert system for threat modelling and penetration testing for IoT ecosystems*

ESSecA (2022, Rak et al. [75]) is an autonomous system for Threat Modelling. It employs an algorithm that correlates attacks to threats in the penetration testing of IoT systems using a threat catalogue as a query table. This approach involves mapping threats to attacks and filtering out those that are not relevant. The tool is designed with a modular architecture and produces two main outputs: a threat model and a testing plan table. It utilises databases, such as Cyber Threat Intelligence (CTI), to enhance its functionality.

*Appendix C.26. Firmaster: Analysis Tool for Home Router Firmware*

Firmaster (2018, Visoottiviseth et al. [76]) is a tool designed to analyse home router firmware source code vulnerabilities. By emulating router firmware, Firmaster identifies, evaluates, and simulates potential vulnerabilities. Its functions include Password Cracking, SSL Scanning, and Web Static Analysis, addressing the OWASP Top 10 2014 IoT vulnerabilities. The tool validates the uploaded firmware, attempts to crack root passwords, and verifies secure connections. Furthermore, it conducts static and dynamic web analysis to identify PHP source code vulnerabilities.

*Appendix C.27. FUGIO: Automatic Exploit Generation for PHP Object Injection Vulnerabilities*

FUGIO (2022, Park et al. [77]) is a tool addressing PHP Object Injection (POI) vulnerabilities, enabling automatic exploit generation. It uses static and dynamic analyses to create gadget chains, serving as exploit blueprints. By running fuzzing campaigns, FUGIO successfully generated exploit objects, producing 68 exploits from 30 vulnerable applications without false positives. Additionally, it uncovered two previously unreported POI vulnerabilities and created five functional exploits, showing its effectiveness in automatic exploit creation for POI vulnerabilities.

#### *Appendix C.28. FUSE: Finding File Upload Bugs via Penetration Testing*

FUSE (2020, Lee et al. [78]) is a penetration testing tool specifically created to uncover Unrestricted File Upload (UFU) and Unrestricted Executable File Upload (UEFU) vulnerabilities in PHP-based server-side web applications. It effectively generates exploit payloads via upload requests, overcoming content-filtering checks while preserving file execution semantics. FUSE identified 30 previously unreported UEFU vulnerabilities, including 15 CVEs, across 33 real-world web applications.

#### *Appendix C.29. GAIL-PT: An intelligent penetration testing framework with generative adversarial imitation learning*

Gail-PT (2023, Chen et al. [79]) as a framework to automate penetration testing. The tool provides advice to the penetration testers for enhanced decision making reducing the reliance on manual testing whilst utilising Generative Adversarial Imitation Learning (GAIL) based on Reinforcement Learning (RL) and Deep Reinforcement Learning (DRL) that innovates the testing process. The tool has been observed to achieve state-of-the-art results when applied to the Metasploitable2 penetration testing target VM.

#### *Appendix C.30. GNPassGAN: Improved Generative Adversarial Networks For Trawling Offline Password Guessing*

GNPassGAN (2022, Yu et al. [80]) is designed to enhance offline password guessing by leveraging generative adversarial networks (GANs) to generate password guesses by training on datasets obtained from real-world breaches. The tool is benchmarked against PassGAN and other password-guessing methods, using datasets like Rockyou and phpbb for training and evaluation. GNPassGAN demonstrates a significant improvement over PassGAN, achieving 88.03% more accurate password guesses and producing 31.69% fewer duplicates when generating a large number of guesses ( $10^8$ ).

#### *Appendix C.31. HARMer: Cyber-Attacks Automation and Evaluation*

HARMer (2020, Enoch et al. [81]) is an automation framework for cyber-attack generation, that addresses limitations in manual attack execution by red teams. Using the Hierarchical Attack Representation Model (HARM), it outlines requirements, key phases, and security metrics-based attack planning strategies. Through experiments conducted in both enterprise networks and Amazon Web Services, HARMer demonstrates effective modelling of attackers' operations. This framework offers automated assessment capabilities, enabling security administrators to evaluate diverse threats and attacks systematically, facilitating a more efficient defence against cyber threats in networked systems.

#### *Appendix C.32. HILTI: an Abstract Execution Environment for Deep, Stateful Network Traffic Analysis*

HILTI (2014, Sommer et al. [82]) is a tool that employs an abstract machine model specifically designed for deep stateful network traffic analysis. It addresses the significant gap between the high-level conceptualisation of network analysis tasks (such as pattern searching in HTTP requests) and the intricate low-level implementation details required to execute these tasks efficiently and securely. The system facilitates the development of network traffic analysis applications by providing built-in support for common data types, state management, concurrency models, and a secure memory model. This foundation enables developers to create robust applications capable of handling the vast and varied data flows in network traffic, all while operating within real-time performance constraints.

#### *Appendix C.33. IoTFuzzer: Discovering Memory Corruptions in IoT Through App-based Fuzzing*

IoTFuzzer (2018, Chen et al. [83]) is a vulnerability scanning tool designed to detect memory corruption vulnerabilities in IoT devices. It utilises an app-based fuzzing framework that operates without the need for access to the devices' firmware images. The process involves UI analysis to identify network event triggers and data-flow analysis to monitor the movement of fields related to the application protocol. By altering the original fields, it generates fuzzing messages. The effectiveness of IoTFuzzer is demonstrated through experiments, where it successfully uncovered 15 serious vulnerabilities in 9 out of 17 evaluated IoT devices. These vulnerabilities range from stack-based and heap-based buffer overflows to null pointer de-references and unidentified crashes, highlighting the framework's capability to reveal critical security flaws.

*Appendix C.34. JCOMIX: a search-based tool to detect XML injection vulnerabilities in web applications*

JCOMIX (2019, Stallenberg et al. [84]) is a tool developed in Java that is designed to generate attacks (test objectives) to identify XML injection threats in web applications. It assesses information sanitation and validation in micro-service frameworks, aiding in the identification of vulnerabilities.

*Appendix C.35. A Light-Weight and Accurate Method of Static Integer-Overflow-to-Buffer-Overflow Vulnerability Detection*

LAID (2018, Hu et al. [85]) is framework designed to accurately identify potential Integer-Overflow-to-Buffer-Overflow (IO2BO) vulnerabilities in software. The framework combines inter-procedural dataflow analysis and taint analysis to identify potential vulnerabilities and employs a lightweight method for further filtering out false positives. The framework’s effectiveness was evaluated using NIST’s SAMATE Juliet test suite [172] and six known IO2BO vulnerabilities in real-world applications. The framework effectively detected all known IO2BO vulnerabilities in the test suite without any false positives.

*Appendix C.36. Link: Black-box detection of cross-site scripting vulnerabilities using reinforcement learning*

Link (2022, Lee et al. [86]) is an autonomous black-box web scanner that operates without any input from humans, using Reinforcement Learning (RL). This software has been observed to decrease the quantity of attack attempts and finds more true positives with fewer showing as false. Particular success has been observed in XSS vulnerability detection, which can be leveraged in penetration testing.

*Appendix C.37. Lore a Red Team Emulation Tool*

Lore (2023, Holm et al. [87]) is a red team emulation tool utilising boolean logic and trained models for automated red team actions, avoiding manual approaches in cyber defence exercises. Empirical tests demonstrate its model accuracy, achieving twice the compromised machines compared to expert-defined models and five times more than random action selection. Lore’s unique approach enhances red team automation, offering a more engaging and educational experience in cyber defence simulations.

*Appendix C.38. LTESniffer: An Open-Source LTE Downlink/Uplink Eavesdropper*

LTESniffer (2023, Hoang et al. [88]) is designed to capture both uplink and downlink LTE traffic passively. Its architecture encompasses key components such as the conversion of analogue signals to digital samples, identification of modulation schemes and other radio configurations, and data channel decoding, which processes uplink and downlink signals according to their configurations. The results demonstrate that LTESniffer significantly surpasses existing tools and commercial sniffers, achieving a success rate more than twice that of AirScope, particularly in decoding LTE packets within high-throughput scenarios and LTE-A (Advanced) environments.

*Appendix C.39. Mace: Detecting privilege escalation vulnerabilities in web applications*

Mace (2014, Monshizadeh et al. [89]) is an automatic privilege escalation vulnerability analysis tool for web applications. It analyses large code bases to discover zero-day vulnerabilities by observing inconsistencies in the authorisation context and understanding flaws within the application using fundamental abstractions. Implementing the tool has been observed to save weeks of labour-intensive work for security professionals in penetration testing.

*Appendix C.40. MAIT: Malware Analysis and Intelligence Tool*

MAIT (2021, Yucel et al.[90]) (Malware Analysis and Intelligence Tool) utilises state-of-the-art static and dynamic malware analysers alongside open-source malware databases to generate malware signatures and intelligence reports. The tool offers chronological data for malicious files, revealing related vulnerabilities and providing insights into attribution, techniques, tactics, and procedures employed by Advanced Persistent Threat groups in attacks.

#### *Appendix C.41. A meta-language for threat modelling and attack simulations*

**MAL** (2018, Johnson et al. [91]) is a tool designed to facilitate the creation of domain-specific attack languages for cybersecurity threat modelling and attack simulations. MAL enables the semi-automated generation and efficient computation of large attack graphs, distinguishing it from traditional, manual attack graph constructions.

#### *Appendix C.42. Malicescript: A novel browser-based intranet threat*

**MaliceScript** (2018, Liu et al. [92]) is a tool that introduces a novel browser-based Web attack model allowing browsers to collect intranet topology and infiltrate websites from within. The tool is designed to exploit vulnerabilities, insert foreground JavaScript code into malicious web pages, and monitor intranet topology to ensure successful infiltration. Its significance lies in its potential ease of deployment and the challenges associated with detection, emphasising the need for proactive security measures.

#### *Appendix C.43. Masat: Model-based automated security assessment tool for cloud computing*

**MASAT** (2015, Mjihil et al. [93]) (Model-based Automated Security Assessment Tool) is a tool designed to address security issues of cloud computing. Focused on adaptive security assessments, MASAT utilises distributed agents to evaluate the security of virtual machines at different virtualisation levels. These agents employ vulnerability scanners, representation tools for attack models like graphs, and a communication mechanism to share analysis results. MASAT's contributions include comprehensive security assessments for both the cloud infrastructure and virtual machines, efficient task distribution among agents, and parallelised subsystem assessments to reduce analysis time.

#### *Appendix C.44. Mirage: towards a Metasploit-like framework for IoT*

**Mirage** (2019, Cayre et al. [94]) is an open-source attack framework applied to IoT by exploiting wireless communication protocols such as Bluetooth Classic/BLE, Zigbee, Enhanced ShockBurst, Mosart, and Wi-Fi. The software is modular and has the potential for future expansion with additional functionality, which is useful for the development of new wireless protocols. The tool was tested using a Smart Bulb, demonstrating success in assessing the attack surface and reverse-engineering the wireless protocol.

#### *Appendix C.45. Mitch: A Machine Learning Approach to the Black-Box Detection of CSRF Vulnerabilities*

The study by **Mitch** (2019, Calzavara et al. [95]) introduced a browser extension that leverages supervised machine learning to identify Cross-Site Request Forgery (CSRF) vulnerabilities. This extension features an automated system that spots sensitive HTTP requests which need CSRF protection for enhanced security. It was trained using nearly 6,000 HTTP requests from popular websites, enabling it to surpass the effectiveness of existing detection methods. This advancement was evidenced by finding three CSRF vulnerabilities in production software that had previously gone unnoticed by the most advanced tools available.

#### *Appendix C.46. MoScan: a model-based vulnerability scanner for web single sign-on services*

**MoScan** (2021, Wei et al. [96]) is a vulnerability scanning tool for identifying security vulnerabilities in Single Sign-On (SSO) implementations through model-based scanning. By capturing network traces during the execution of SSO services, MoScan incrementally constructs and refines the state machine. This refined state machine enables MoScan to generate specific payloads for testing protocol participants, aiming to identify security vulnerabilities. MoScan's adaptability is demonstrated by testing it against other SSO services, such as Twitter, LinkedIn, and GitHub's authentication plugin in Jenkins. Despite minor adjustments needed for parameter names, MoScan's primary state machine required minor modifications to accommodate different implementations of the OAuth 2.0 standard.



#### *Appendix C.47. NAUTILUS: Automated RESTful API Vulnerability Detection*

**NAUTILUS** (2023, Deng et al. [97]) is proposed to improve RESTful API vulnerability scanning by addressing limitations in existing black box scanners. It utilises a novel annotation strategy to identify proper operation relations and generate meaningful sequences for vulnerability detection. Compared to four state-of-the-art tools, NAUTILUS demonstrates superior performance, detecting 141% more vulnerabilities on average and covering 104% more API operations across six tested services. In real-world scenarios, NAUTILUS detected 23 unique 0-day vulnerabilities, including a remote code execution flaw in Atlassian Confluence and high-risk issues in Microsoft Azure.

#### *Appendix C.48. NAVEX: Precise and Scalable Exploit Generation for Dynamic Web Applications*

**NAVEX** (2018, Alhuzali et al. [98]) is a tool addressing complex vulnerabilities in multi-tier web applications by combining dynamic and static analysis. It integrates both techniques to automatically detect vulnerabilities and create functional exploits. Evaluated over 3.2 million lines of PHP code, NAVEX successfully identified and created 204 exploits, showcasing its scalability and effectiveness in vulnerability analysis and exploit generation for large-scale applications.

#### *Appendix C.49. NetCAT: Practical Cache Attacks from the Network*

**NetCAT** (2020, Kurth et al. [99]) is a tool designed to exploit Data-Direct I/O (DDIO) to observe and manipulate Last-Level Cache (LLC) states, thereby leaking sensitive information from a remote target server without requiring local access or execution privileges. NetCAT reverse engineers the behaviour of DDIO on Intel processors and develops a network-based PRIME+PROBE cache attack technique by crafting specific network packets to manipulate and observe changes in the LLC's state. The efficiency of NetCAT is demonstrated in various attack scenarios, including creating covert channels between network clients and executing keystroke timing attacks to infer sensitive information from encrypted SSH sessions.

#### *Appendix C.50. Fast, lean, and accurate: modelling password guessability using neural networks*

**NeuralNetworkCracking** (2016, Melicher et al. [100]) is a tool designed to predict the guessability of passwords accurately and efficiently in real-time. By harnessing the power of neural networks for generating sequential data, the model utilizes an Artificial Neural Network (ANN) to anticipate the next character in a password sequence, thereby estimating the password's guessability. The effectiveness of the ANN model was benchmarked against traditional password guessability models, where it demonstrated superior performance across various scenarios. Notably, the neural networks were able to guess 70% of 4class8 passwords within 10151015 guesses, significantly outperforming the next best guessing method, which guessed 57%.

#### *Appendix C.51. Identification and Mitigation Tool For Cross-Site Request Forgery (CSRF)*

**No Name (CSRF)** (2020, Rankothge and Randeniya [101]) focuses on the automated detection and mitigation of Cross-Site Request Forgery (CSRF) vulnerabilities in PHP-based web applications [101]. It identifies and mitigates CSRF vulnerabilities by scanning form tags and automatically adding security solutions. However, the evaluation is limited to a few test websites, and the tool is applicable exclusively to PHP.

#### *Appendix C.52. Development of a suite of IPv6 vulnerability scanning tests using the TTCN-3 language*

The **No Name (TTCN-3)** tool, (2018, Leal and Teixeira [102]), is a collection of tests designed to find security weaknesses in IPv6 setups. It uses TTCN-3, a language for defining and executing tests that is endorsed by the European Telecommunications Standards Institute. The tool was evaluated using the SAMATE Juliet 1.2 suite from NIST [172] and proved its effectiveness by identifying and exploiting flaws, particularly focusing on preventing DOS attacks on the IPv6 ICMPv6 protocol over Ethernet networks.

### *Appendix C.53. Cracking-Resistant Password Vaults Using Natural Language Encoders*

**NoCrack** (2015, Chatterjee et al. [103]) is a password-cracking tool that overcomes the limitations of a previous design, Kamouflage [173], which was shown to degrade security. NoCrack utilizes Natural Language Encoder (NLE) as a scheme for secure encoding. This approach utilises natural language processing (n-gram models) with probabilistic context-free grammars, to construct NLEs. These encoders can create realistic decoy passwords, thereby significantly enhancing the resistance of password vaults against cracking efforts.

### *Appendix C.54. NodeXP: NOde.js server-side JavaScript injection vulnerability DETection and eXPloitation*

**NodeXP** (2021, Ntantogian et al. [104]) is a tool addressing security vulnerabilities in web applications, particularly Server-Side JavaScript Injection (SSJI) threats in Node.js. It detects and automatically exploits SSJI vulnerabilities, using obfuscation for enhanced stealth. NodeXP employs dynamic analysis with result and blind-based injection techniques for detection and automated exploitation. Its advanced functionalities, including attack vector obfuscation, distinguish it from other tools, allowing evasion of filtering mechanisms and security measures. Thorough assessments show NodeXP outperforming existing scanners. Released as open-source, it aims to drive research in SSJI vulnerabilities. Contributions include SSJI analysis, a novel detection method, and the discovery of a 0-day SSJI.

### *Appendix C.55. ObjectMap: detecting insecure object deserialization*

**ObjectMap** (2019, Koutroumpouchos et al. [105]) is a tool designed to address serialization-based vulnerabilities prevalent in web applications, particularly in Java and PHP. It aims to fill the existing gap by detecting implementation-agnostic deserialization and object injection vulnerabilities. Additionally, it introduces the first deserialization test environment, serving as a platform for vulnerability detection tool evaluation and educational purposes. Both tools are highly extendable and represent a unique combination of features in this domain, potentially fostering further research and aiding the development of more comprehensive solutions.

### *Appendix C.56. OMEN: Faster password guessing using an ordered Markov enumerator*

**OMEN** (2015, Durmuth et al. [106]) employs an advanced Markov model algorithm that generates passwords in order of decreasing probability, a departure from earlier approaches [174]. This method involves discretising probabilities into bins and iterating over them to identify all passwords corresponding to each bin's probability. OMEN has shown a significant improvement in guessing speed over existing methods, accurately guessing over 40% of passwords within the first 90 million attempts, marking a notable efficiency gain against other methods such as John the Ripper (JtR) and probabilistic context-free grammar (PCFG)-based strategies [175].

### *Appendix C.57. OSV: OSPF vulnerability checking tool*

**OSV** (2017, Kasemsuwan et al. [107]) is a tool that targets OSPF (Open Shortest Path First) network vulnerabilities prevalent in enterprise networks. Typically, OSPF vulnerabilities in router implementations can be mitigated through firmware updates. The tool conducts penetration tests and generates reports, aiding network operators in identifying and rectifying security issues. The tool has been validated on Quagga and Cisco routers.

### *Appendix C.58. Owfuzz: Discovering Wi-Fi Flaws in Modern Devices through Over-The-Air Fuzzing*

**Owfuzz** (2023, Cao et al. [108]) is a fuzzing tool designed for discovering security flaws in Wi-Fi protocols through over-the-air fuzzing methods. Owfuzz sets itself apart from other Wi-Fi fuzzers by offering the capability to conduct fuzzing tests on any Wi-Fi device, enabling the fuzzing of all three Wi-Fi frame types (management, control, and data) across every version of the 802.11 standards, and facilitating interactive testing for a variety of protocol models. In experiments conducted on over 40 contemporary Wi-Fi devices from 7 chipset manufacturers, Owfuzz identified 23 security issues, resulting in the assignment of 8 CVE IDs.

#### *Appendix C.59. PassGAN: A Deep Learning Approach for Password Guessing*

**PassGAN** (2019, Hitaj et al. [109]) utilises a Generative Adversarial Network (GAN) trained on real-world datasets to make accurate password guesses. By autonomously learning the distribution of real passwords from actual leaks, PassGAN eliminates the need for manual rule creation. When combined with HashCat, PassGAN’s output successfully matches 51%-73% more passwords than HashCat alone. This demonstrates the tool’s capacity to automatically extract nuanced password properties not encompassed by current state-of-the-art rules.

#### *Appendix C.60. PassGPT: Password modelling and (Guided) Generation with Large Language Models*

**PassGPT** (2023, Rando et al. [110]) is a tool utilizing GPT-2 architecture and trained on leaked passwords, aiming to improve password guessing and strength estimation. PassGPT incorporates vector quantization to enhance the complexity of password generation (PassVQT). Comprehensive tests were conducted to evaluate PassGPT’s efficacy against current password-guessing tools and to assess its generalization capabilities across various datasets. PassGPT recovers 41.9% of the test set among 109109 guesses, whereas state-of-the-art GAN models matched 23.33%.

#### *Appendix C.61. The Revenge of Password Crackers: Automated Training of Password Cracking Tools*

**PasswordCrackingTraining** (2022, Di Campi et al. [111]) is a password-cracking trainer combining various password-cracking techniques, trained and tested on a dataset of over 700 million real passwords. Their methodology includes evaluating existing hashcat rules and dictionaries and developing efficient algorithms to simulate mask attacks without actual password cracking. This approach nearly doubles the success rate of password-cracking tools compared to off-the-shelf configurations, achieving over 70% success in certain instances.

#### *Appendix C.62. PenQuest: a gamified attacker/defender meta model for cyber security assessment and education*

**PenQuest** (2020, Luh et al. [112]) is a tool designed as a dynamic, multiplayer game that captures the behaviour of attackers and defenders over time, using a rule set based on established information security sources such as STIX CAPEC, CVE/CWE, and NIST SP 800-53. The tool is designed to improve cybersecurity risk assessments and serve as a platform for simulating specific attack scenarios within an abstracted IT infrastructure. PenQuest is structured around three main layers: the service layer, the information layer, and the event layer, each contributing to a comprehensive representation of a cybersecurity scenario.

#### *Appendix C.63. PentestGPT: An LLM-empowered Automatic Penetration Testing Tool*

**PentestGPT** (2023, Deng et al. [113]) utilises Large Language Models (LLMs) for penetration testing, revealing their proficiency in specific tasks but struggles in holistic understanding. Based on LLM-powered automatic penetration testing tool, PENTESTGPT has been released with three modules addressing distinct sub-tasks. Evaluation demonstrates PentestGPT’s 228.6% improvement over GPT-3.5 and effectiveness in real-world challenges. The tool employs Reasoning, Generation, and Parsing Modules, simulating human-like behaviour and adopting a divide-and-conquer problem-solving approach.

#### *Appendix C.64. phpSAFE: A Security Analysis Tool for OOP Web Application Plugins*

**PhpSAFE** (2015, Nunes et al. [114]) is introduced as a solution to identify security vulnerabilities in PHP plugins developed with Object-Oriented Programming (OOP) for web applications. In contrast to existing free tools that lack OOP support, PhpSAFE excels in static code analysis, outperforming two well-known tools when evaluated with 35 plugins in a popular Content Management System. The results highlight the prevalence of vulnerabilities in these plugins, indicating an increasing trend over time, emphasizing the necessity of robust security measures in plugin development.

*Appendix C.65. PJCT: Penetration testing based JAVA code testing tool*

PJCT (2015, Jain et al. [115]) is a tool designed to secure attributes in Java code. This addresses a crucial aspect of secure software development while emphasizing early detection of vulnerabilities during the development process. PJCT highlights seven essential security attributes for identifying vulnerabilities in Java applications. These attributes include network and security packages, techniques for handling exceptions, secure data packet transmission and multithreading.

*Appendix C.66. Project Achilles: A Prototype Tool for Static Method-Level Vulnerability Detection of Java Source Code Using a Recurrent Neural Network*

Project Achilles (2019, Saccente et al. [116]) is a prototype tool for static method-level vulnerability detection in Java source code, leveraging LSTM Recurrent Neural Networks. The tool utilizes NIST's Juliet Java Suite [172], which includes several examples of defective Java methods for various vulnerabilities. Employing an array of LSTM networks, the tool achieves over 90% accuracy for 24 out of 29 Common Weakness Enumeration (CWE) vulnerabilities in an evaluation with around 45,000 test cases.

*Appendix C.67. PURITY: a Planning-based secURITY testing tool*

PURITY (2015, Bozic and Wotawa [117]) is a security testing tool that employs a planning-centric methodology to preemptively identify and rectify vulnerabilities during the software development cycle. By executing automated test cases, PURITY focuses on detecting prevalent security flaws like SQL injections and cross-site scripting, simulating malicious activities through predetermined sequences of actions. PURITY generates concrete test cases from plans based on specific initial values and predefined actions, mimicking the behaviours of potential attackers, providing a versatile platform for both automated and manual evaluation of web applications throughout the software development life cycle.

*Appendix C.68. Pyciuti: A Python Based Customizable and Flexible Cybersecurity Utility Tool for Penetration Testing*

Pyciuti (2023, Muralidharan et al. [118]) is a Python-based general-purpose tool that integrates custom scanners, crawlers, malware functionalities, and more, offering flexibility and customisation for both beginners and experienced professionals. Users can access various subdomains such as OSINT, network-based tools, web-based tools, malware tools, and documentation, streamlining the execution of tasks. The tool records findings, scans, and exploits, providing a consolidated report while prioritising accuracy and performance.

*Appendix C.69. RAT: Reinforcement-Learning-Driven and Adaptive Testing for Vulnerability Discovery in Web Application Firewalls*

RAT (2022, Amouei et al. [119]) (Reinforcement-Learning-Driven and Adaptive Testing) is a tool for discovering vulnerabilities, specifically SQL injection (SQLi) and Cross-site Scripting (XSS), in Web Application Firewalls (WAFs). The tool's methodology begins with clustering similar attack samples, followed by applying a reinforcement learning technique that efficiently identifies bypassing attack patterns. The approach is further refined by integrating an adaptive search algorithm, which aids in discovering almost all possible bypassing payloads with higher efficiency. RAT outperforms existing methods by significant margins (33.53% and 63.16% on average) when tested against well-configured WAFs.

*Appendix C.70. Revealer: Detecting and Exploiting Regular Expression Denial-of-Service Vulnerabilities*

Revealer (2021, Liu et al. [120]) is a tool designed to detect and exploit Regular expression Denial-of-Service (ReDoS) vulnerabilities present in extended-featured regular expressions (regexes). Revealer employs a combined method using static and dynamic analyses to identify vulnerable regex structures and generate attack strings that induce recursive backtracking. In evaluation against 29,088 regexes and comparison with three state-of-the-art tools, Revealer outperformed existing solutions, detecting all known vulnerabilities, finding 213 new vulnerabilities whilst surpassing the highest performing tool by 140.64%. Additionally, it detected 45 vulnerable regexes in real-world applications, demonstrating its effectiveness and efficiency in detecting and exploiting ReDoS vulnerabilities.

#### *Appendix C.71. RiscyROP: Automated Return-Oriented Programming Attacks on RISC-V and ARM64*

**RiscyROP** (2022, Cloosters et al. [121]) is an automated Return-Oriented Programming (ROP) tool specifically designed for RISC-V and ARM64 architectures. It employs symbolic execution to analyze available gadgets and autonomously generate complex multi-stage chains for arbitrary function calls. The tool’s effectiveness is evidenced by its analysis of real-world software from public repositories, demonstrating its capability to identify usable gadgets for executing attacker-controlled function calls.

#### *Appendix C.72. Robin: A Web Security Tool*

**Robin** (2020, Giroto and Zorzo [122]) is a web security tool that includes a Proxy module for listing, intercepting, and editing HTTP and HTTPS requests. Robin’s capabilities extend to active scanning, brute-force attack simulations, encoding/decoding contents using various hashing patterns, and providing a detailed Wiki module for understanding and safeguarding against common vulnerabilities. The tool’s potential is demonstrated through a real case study involving a news company’s website.

#### *Appendix C.73. ROSploit: Cybersecurity Tool for ROS*

**ROSploit** (2019, Rivera et al. [123]) is a tool for the assessment of the security of the Robot Operating System (ROS). The tool covers reconnaissance and exploitation. Its reconnaissance component integrates with Nmap, offering two scripts for master node scans and wide port scans, identifying ROS nodes and services. The exploitation component, built in Python, mirrors Metasploit’s modular design. Moreover, ROSploit enables simulated attacks without a complete ROS installation.

#### *Appendix C.74. RT-RCT: an online tool for real-time retrieval of connected things*

**RT-RCT** (2021, Fagroud et al. [124]) utilises network port scanning techniques [176] to extract real-time data from connected devices within the IoT domain. The main goal is to introduce a retrieval tool that swiftly provides users with current information about each requested entity. Real-time device data is collected through network port scanning, with a specific emphasis on the Python-nmap library. The data collection process involves a series of scans, each targeting specific information that may take considerable time to retrieve. To reduce time, parallel scans are implemented, ensuring simultaneous and accelerated execution of all scans to improve overall retrieval speed and efficiency.

#### *Appendix C.75. Scanner++: Enhanced Vulnerability Detection of Web Applications with Attack Intent Synchronization*

**Scanner++** (2023, Yin et al. [125]) demonstrates an enhancement of vulnerability assessment scanning technology in web applications. By utilizing purification mechanisms to refine attack intents from the request packets in the base scanners. The scanner has a synchronisation mechanism for runtime intent for the scanner’s detection spots. This has been evaluated against four practitioner tools including BurpSuite, AWVS, Arachni, and ZAP testing on real-world finance web apps where the tool demonstrated to have a higher coverage when being compared to the practitioner tools by approximately 15%-70%.

#### *Appendix C.76. On the Semantic Patterns of Passwords and their Security Impact*

**SemanticGuesser** (2014, Veras et al. [126]) is a framework that uses Natural Language Processing (NLP) techniques for the segmentation, semantic classification, and generalisation of passwords. The methodology begins with password segmentation to isolate distinct words or elements found within the passwords. Following this, it employs part-of-speech tagging and semantic classification through NLP methodologies, primarily utilising resources such as WordNet to decipher the meanings of the segments. Experimental results have shown that this method can guess about 67% more passwords from the LinkedIn data breach and 32% more from the MySpace leak, demonstrating its effectiveness in understanding and exploiting the semantic structures of passwords.

*Appendix C.77. SerialDetector: Principled and Practical Exploration of Object Injection Vulnerabilities for the Web*

**SerialDetector** (2021, Shcherbakov et al. [127]) employs taint-based dataflow analysis to automatically detect OIV (Object Injection Vulnerability) patterns in .NET assemblies. By identifying untrusted information flow from public entry points to sensitive methods, it uncovers vulnerabilities and matches them with available gadgets, validating the feasibility of OIV attacks. The evaluation conducted on Azure DevOps Server showcased SerialDetector’s effectiveness by discovering three CVEs and demonstrating its capability in identifying remote code execution vulnerabilities. Additionally, it performed a broad security analysis of recent CVEs, affirming its efficiency and effectiveness in OIV detection.

*Appendix C.78. ShoVAT: Shodan-based vulnerability assessment tool for Internet-facing services*

**ShoVAT** (2016, Genge et al. [128]) is a vulnerability analysis tool based on Shodan. This software acquires the output of traditional queries in Shodan to analyse service-specific data by leveraging the search engine. By adding to existing modules this tool provides the opportunity to analyse other targets in the penetration test.

*Appendix C.79. Snout: An Extensible IoT Pen-Testing Tool*

**Snout** (2019, Mikulskis et al. [129]) is a Software-Defined Radio (SDR)-based utility toolkit for passive sniffing and interaction with various IoT protocols, including Zigbee, Bluetooth, and Wi-Fi. Available as a Python 3 package or as a Docker container, Snout enables enumeration and analysis of multiple wireless protocols, including non-IP IoT protocols.

*Appendix C.80. SOA-Scanner: an integrated tool to detect vulnerabilities in service-based infrastructures*

**SOA-Scanner** (2013, Antunes et al. [130]) is a vulnerability analysis tool designed for service-oriented architectures (SOA) after the application has been deployed. The tool tests services based on their level of access using an iterative process to discover services, resources, and interactions in real-time. Additionally, it provides anomaly detection, categorising services based on whether they are within reach, under full control, or under partial control.

*Appendix C.81. Spicy: a unified deep packet inspection framework for safely dissecting all your data*

**Spicy** (2016, Sommer et al. [131]) includes a format specification language, a compiler toolchain, and an API to address the challenges of deep packet inspection (DPI) across diverse network protocols and file formats. The Spicy framework automates the dissection process, enhancing DPI efficiency and safety. Enabling developers to create specific dissectors for varied protocols, Spicy is a reliable DPI tool. Its flexibility makes it valuable for processing network data from untrusted sources in diverse formats.

*Appendix C.82. SuperEye: A Distributed Port Scanning System*

**SuperEye** (2019, Li et al. [132]) is an advanced distributed port scanning system adopting a distributed structure with task redundancy and real-time state display. SuperEye’s core control subsystem efficiently manages distributed nodes, tasks, and result processing, leveraging a custom protocol stack to optimise resource utilisation. The distributed architecture significantly boosts scanning speed, mitigating risks associated with Intrusion Detection Systems (IDS). Innovative features include a script for port scanning and visualisation tools offering real-time updates.

*Appendix C.83. SVED: Scanning, Vulnerabilities, Exploits and Detection*

**SVED** (2016, Holm et al. [133]) is a tool designed for secure and replicable experiments, enabling controlled execution and logging of malicious activities, including software exploits and intrusion detection alerts. Its distributed architecture supports extensive experiments involving numerous attackers, sensors, and targets. SVED automatically integrates threat intelligence from diverse services, ensuring up-to-date information for enhanced experimentation and analysis in cybersecurity.

#### *Appendix C.84. A Hybrid Threat Model for Smart Systems*

**TAMELESS** (2023, Valenza et al. [134]) is an automated threat modelling tool that includes a threat modelling approach integrating cyber, physical, and human elements, and a threat analysis method designed to evaluate the security posture of system components. TAMELESS can analyse threats, verify security properties, and produce graphical outputs of its analyses, thereby assisting security architects in identifying optimal prevention and mitigation solutions. The efficiency and applicability of TAMELESS have been demonstrated through case study evaluations involving unauthorised access to safe boxes, web servers, and wind farms, showcasing its effectiveness in real-world scenarios.

#### *Appendix C.85. TChecker: Precise Static Inter-Procedural Analysis for Detecting Taint-Style Vulnerabilities in PHP Applications*

**TChecker** (2022, Luo et al. [135]) introduces a context-sensitive inter-procedural static taint analysis tool specifically tailored for PHP applications, addressing the challenge of taint-style vulnerabilities like SQL injection and cross-site scripting. By modelling PHP objects and dynamic language features, TChecker conducts iterative data-flow analysis to refine object types and accurately identify call targets. Comprehensive evaluations across diverse modern PHP applications showcased TChecker’s effectiveness, discovering 18 previously unknown vulnerabilities while outperforming existing static analysis tools in vulnerability detection. It not only detected more vulnerabilities but also maintained a relatively good precision, surpassing competitors while releasing its source code to foster further research in this domain.

#### *Appendix C.86. Detecting and exploiting second order denial-of-service vulnerabilities in web applications*

**TORPEDO** (2015, Olivo et al. [136]) is a second-order vulnerability scanning tool that detects Denial of Service (DoS), Cross-Site Scripting (XSS), and SQL Injection. The program searches for two-phased DoS attacks that work by polluting a database with junk entries and resource exhaustion. When applied to six highly used web apps, it detected thirty-seven vulnerabilities and eighteen false positives.

#### *Appendix C.87. UE Security Reloaded: Developing a 5G Standalone User-Side Security Testing Framework*

**UE Security Reloaded** (2023, Hoang et al. [137]) is an open-source security testing framework specifically developed for 5G Standalone (SA) User Equipment (UE). This tool enhances existing open-source suites (Open5GS and srsRAN) by creating an extensive range of test cases for both the 5G Non-Access Stratum (NAS) and Radio Resource Control (RRC) layers. Such an approach offers in-depth insights through experiments on 5G SA mobile phones. The framework allows for the transmission of 5G control-plane messages (NAS and RRC) to a UE and facilitates the modification of these messages to examine the UE’s reactions under a variety of conditions.

#### *Appendix C.88. Untangle: Aiding Global Function Pointer Hijacking for Post-CET Binary Exploitation*

**Untangle** (2023, Bertani et al. [138]) is a tool that exploits global function pointer hijacking in order to defeat Intel’s Control-Flow Enforcement Technology (CET). The method combines symbolic execution and static code analysis to identify global function pointers within C libraries, which, when compromised, facilitate control-flow hijacking attacks. Experimental results demonstrated the effectiveness of Untangle in identifying global function pointers across eight widely used open-source C libraries.

#### *Appendix C.89. VAPE-BRIDGE: Bridging OpenVAS Results for Automating Metasploit Framework*

**VAPE-BRIDGE** (2022, Vimala et al. [139]) is a tool designed to streamline the transition between vulnerability assessment (VA) and penetration testing (PenTest) processes by automating the conversion of scan results from the Open Vulnerability Assessment Scanner (OpenVAS) into executable scripts for the Metasploit Framework. The VAPE-BRIDGE system comprises three main components: Scan result extraction, responsible for parsing the VA scan results from OpenVAS; Target list repository, accountable for maintaining a database of identified vulnerabilities to be used in the PenTest process; and the Automated shell scripts exploitation, which generates shell scripts based on the extracted vulnerabilities, which are then executed within Metasploit to simulate attacks and test the system’s resilience.

#### *Appendix C.90. Vera: A flexible model-based vulnerability testing tool*

VERA (2013, Blome et al. [140]) is an automated tool that supports Penetration Testers to define attacker models (separating payloads and behaviour) using state machines for vulnerability analysis in web applications. The models acquired are then converted into libraries for specific vulnerability targeting. The tool is highly flexible with the availability to expand and integrate custom libraries to enhance functionality.

#### *Appendix C.91. VUDDY: A Scalable Approach for Vulnerable Code Clone Discovery*

VUDDY (2017, Kim et al. [141]) aims to detect defective code in large open-source programs. In particular, it is capable to process a billion lines of code in under 15 hours and quickly identify code clones using function-level granularity and a length-filtering technique. The evaluation included comparison with four other code clone detection methods and VUDDY showed better scalability and accuracy. For example, it was possible to find zero-day vulnerabilities popular software like Apache Web Server and Ubuntu Linux OS.

#### *Appendix C.92. Vulcan: Vulnerability assessment framework for cloud computing*

Vulcan (2013, Kamongi et al. [142]) is a tool for vulnerability analysis and remediation in cloud and mobile computing. This tool provides software and zero-day vulnerability modelling and assessments. The tool is very flexible, presenting the opportunity to add original modules by developers and the integration of Vulcan into other vulnerability analysis tools that, for example, focus on web application vulnerabilities to expand their assessment to cloud and mobile technology.

#### *Appendix C.93. VulCNN: An Image-Inspired Scalable Vulnerability Detection System*

VulCNN (2022, Wu et al. [143]) is designed to address the limitations of existing text-based and graph-based vulnerability detection methods. The tool converts the source code of functions into images that preserve program details and then uses these images to detect vulnerabilities through a Convolutional Neural Network (CNN) model. VulCNN was evaluated on a dataset of 13,687 vulnerable and 26,970 non-vulnerable functions. With an accuracy of 82% and a True Positive Rate (TPR) of 94%, VulCNN outperformed eight other state-of-the-art vulnerability detectors, including both commercial tools and deep learning-based approaches.

#### *Appendix C.94. VulDeePecker: A Deep Learning-Based System for Vulnerability Detection*

VulDeePecker (2018, Zhen et al. [144]) employs deep learning for software vulnerability detection, aiming to reduce reliance on human-defined features and mitigate false negatives. It uses code gadgets to represent and transform programs into vectors suitable for deep learning. The system's evaluation, using the first vulnerability dataset for deep learning, demonstrates significantly fewer false negatives compared to other methods, with reasonable false positives. VulDeePecker successfully detects four previously unreported vulnerabilities in Xen, Seamonkey, and Libav, unnoticed by other detection systems, highlighting its efficacy in uncovering vulnerabilities missed by existing approaches.

#### *Appendix C.95. An Intelligent and Automated WCMS Vulnerability-Discovery Tool: The Current State of the Web*

Vulnet (2019, Cigoj and Blazic [145]) is characterized by its capability to conduct automated, rapid, and dynamic vulnerability scans across a wide array of internet websites. Specifically, VulNet focuses on those utilising the WordPress Web Content Management Systems (WCMS) and its associated plugins. A crucial aspect of the tool involves the application of a scoring mechanism tailored to evaluate known vulnerabilities. It's important to note that VulNet's vulnerability detection is limited to WordPress web applications and their associated plugins.



#### *Appendix C.96. Vulnsloit: A Module for Semi-automatic Exploitation of Vulnerabilities*

**Vulnsloit** (2020, Castiglione et al. [146]) is a semi-automatic penetration testing tool that collects vulnerability data using existing tools like the Nmap Scripting Engine (NSE) and the Vulscan scanner [176]. This data is then processed to identify relevant exploits from various repositories, including local and remote sources. In preliminary testing on Metasploitable2, Vulnsloit identified 23 open ports and approximately 220,000 vulnerabilities.

#### *Appendix C.97. VulPecker: an automated vulnerability detection system based on code similarity analysis*

**VulPecker** (2016, Li et al. [147]) automatically detects specific vulnerabilities within software source code. Leveraging a set of defined features characterizing patches and utilizing code-similarity algorithms tailored for different vulnerability types, VulPecker successfully identifies 40 vulnerabilities not listed in the National Vulnerability Database (NVD). Among these, 18 previously unknown vulnerabilities (anonymized for ethical considerations) are confirmed, while 22 vulnerabilities have been patched silently by vendors in later product releases.

#### *Appendix C.98. WAPTT-Web application penetration testing tool*

**WAPTT** (2014, Duric et al. [148]) is designed for web application penetration testing using page similarity detection. The structure of the tool is modular and when compared to tools such as Nikto, Vega, and ZAP, the tool detected similar or greater quantity of vulnerabilities in the area of XSS, but at the price of increasing detection time.

#### *Appendix C.99. webFuzz: Grey-Box Fuzzing for Web Applications*

**WebFuzz** (2021, van Rooij et al. [149]) is a gray-box fuzzing tool designed for web applications, with a focus on discovering vulnerabilities like cross-site scripting (XSS). It effectively utilises instrumentation, outperforming black-box fuzzers by identifying XSS vulnerabilities swiftly and covering more code. WebFuzz has demonstrated its capability by discovering one zero-day vulnerability in WordPress and five in CE-Phoenix.

#### *Appendix C.100. Identification and Mitigation Tool for Sql Injection Attacks (SQLIA)*

**WebVIM** (2020, Rankothge et al. [150]) is a tool designed for identifying SQL injection vulnerabilities in PHP-based web applications during the development phase. When vulnerabilities are detected, WebVIM automatically adds security solutions to the source code. However, the evaluation is very limited, and the tool focuses exclusively on PHP applications.

## References

- [1] P. Modesti, L. Golightly, L. Holmes, C. Opara, M. Moscini, Bridging the Gap: A Survey and Classification of Research-Informed Ethical Hacking Tools, *Journal of Cybersecurity and Privacy* 4 (3) (2024) 410–448. doi:10.3390/jcp4030021.
- [2] S. D. Duque Anton, D. Fraunholz, D. Schneider, Investigating the ecosystem of offensive information security tools, *arXiv e-prints* (2020). arXiv:2012.08811, doi:10.48550/arXiv.2012.08811.
- [3] M. M. Leal, P. Musgrave, Backwards from zero: How the u.s. public evaluates the use of zero-day vulnerabilities in cybersecurity, *Contemporary Security Policy* 44 (3) (2023) 437–461. doi:10.1080/13523260.2023.2216112.
- [4] A. Valenza, G. Costa, A. Armando, Never trust your victim: Weaponizing vulnerabilities in security scanners, in: *23rd International Symposium on Research in Attacks, Intrusions and Defenses ({RAID} 2020)*, 2020, pp. 17–29. arXiv:2006.09769, doi:10.48550/arxiv.2006.09769.
- [5] M. Denis, C. Zena, T. Hayajneh, Penetration testing: Concepts, attack methods, and defense strategies, in: *2016 IEEE Long Island Systems, Applications and Technology Conference (LISAT)*, IEEE, 2016, pp. 1–6. doi:10.1109/lisat.2016.7494156.
- [6] J.-P. A. Yaacoub, H. N. Noura, O. Salman, A. Chehab, Ethical hacking for iot: Security issues, challenges, solutions and recommendations, *Internet of Things and Cyber-Physical Systems* 3 (2023) 280–308. doi:10.1016/j.iotcps.2023.04.002.
- [7] P. S. Aarya, A. Rajan, K. P. S. Sachin, R. Gopi, G. Sreenu, Web scanning: Existing techniques and future, in: *2018 Second International Conference on Intelligent Computing and Control Systems (ICICCS)*, IEEE, 2018, pp. 123–128. doi:10.1109/iccons.2018.8662934.
- [8] E. A. Altulaihan, A. Alismail, M. Frikha, A survey on web application penetration testing, *Electronics* 12 (5) (2023) 1229. doi:10.3390/electronics12051229.
- [9] A. Shanley, M. N. Johnstone, Selection of penetration testing methodologies: A comparison and evaluation (2015). doi:10.4225/75/57b69c4ed938d.
- [10] PTES Working Group, The penetration testing execution standard (2011). URL <http://www.pentest-standard.org/>
- [11] B. E. Strom, A. Applebaum, D. P. Miller, K. C. Nickels, A. G. Pennington, C. B. Thomas, Mitre att&ck: Design and philosophy, in: *Technical report*, The MITRE Corporation, 2018.
- [12] A. Rashid, H. Chivers, G. Danezis, E. Lupu, A. Martin (Eds.), *Cyber Security Body of Knowledge*, The National Cyber Security Centre, 2021, version 1.1.0. URL [https://www.cybok.org/knowledgebase1\\_1/](https://www.cybok.org/knowledgebase1_1/)
- [13] B. Rous, Major update to acm’s computing classification system, *Commun. ACM* 55 (11) (2012) 12. doi:10.1145/2366316.2366320.
- [14] M. Bishop, *Computer Security: Art and Science*, Pearson Education, 2018. URL <https://books.google.ch/books?id=bz58DwAAQBAJ>
- [15] J. A. Yaacoub, H. N. Noura, O. Salman, A. Chehab, A survey on ethical hacking: Issues and challenges, *CoRR abs/2103.15072* (2021). arXiv:2103.15072, doi:10.48550/arxiv.2103.15072.
- [16] M. Walker, *CEH Certified Ethical Hacker All-in-One Exam Guide, Fifth Edition*, McGraw Hill LLC, 2021. URL <https://books.google.ch/books?id=EuBIEAAAQBAJ>

- [17] S. L. N. Hald, J. M. Pedersen, An updated taxonomy for characterizing hackers according to their threat properties, in: 2012 14th International Conference on Advanced Communication Technology (ICACT), IEEE, 2012, pp. 81–86.
- [18] D. Oliver, A. B. Randolph, Hacker definitions in information systems research, *J. Comput. Inf. Syst.* 62 (2) (2022) 397–409. doi:10.1080/08874417.2020.1833379.
- [19] M. Aljaidi, A. Alsarhan, G. Samara, R. Alazaidah, S. Almatarneh, M. Khalid, Y. A. Al-Gumaei, Nhs wannacry ransomware attack: Technical explanation of the vulnerability, exploitation, and counter-measures, in: 2022 International Engineering Conference on Electrical, Energy, and Artificial Intelligence (EICEEAI), IEEE, 2022, pp. 1–6. doi:10.1109/eiceeai56378.2022.10050485.
- [20] M. Qin, G. Mogos, Cyber-attacks on swift systems of financial institutions, in: Proceedings of the 5th International Conference on Computer Science and Software Engineering, 2022, pp. 596–599. doi:10.1145/3569966.3570116.
- [21] D. P. Fidler, The us election hacks, cybersecurity, and international law, *American Journal of International Law* 110 (2016) 337–342.
- [22] T. Steffens, Attribution of Advanced Persistent Threats - How to Identify the Actors Behind Cyber-Espionage, Springer, 2020. doi:10.1007/978-3-662-61313-9.
- [23] Z. Liu, C. Chen, L. Y. Zhang, S. Gao, Working Mechanism of Eternalblue and Its Application in Ransomworm, Springer International Publishing, 2022, pp. 178–191. doi:10.1007/978-3-031-18067-5\_13.
- [24] Concil of Europe, Convention on cybercrime, European Treaty Series - No. 185 (2001).
- [25] Council of the European Union, European Parliament, Directive 2013/40/eu of the european parliament and of the council of 12 august 2013 on attacks against information systems and replacing council framework decision 2005/222/jha (2013).  
URL <https://eur-lex.europa.eu/legal-content/EN/ALL/?uri=celex:32013L0040>
- [26] United Kingdom Parliament, Computer misuse act 1990 (1990).  
URL <https://www.legislation.gov.uk/ukpga/1990/18/contents>
- [27] V. V. Gehring, The Internet in public life, Rowman & Littlefield, 2004.
- [28] D.-O. Jaquet-Chiffelle, M. Loi, Ethical and unethical hacking, *The ethics of cybersecurity* (2020) 179–204doi:10.1007/978-3-030-29053-5\_9.
- [29] G. Vishnuram, K. Tripathi, A. K. Tyagi, Ethical hacking: Importance, controversies and scope in the future, in: 2022 International Conference on Computer Communication and Informatics (ICCCI), IEEE, 2022, pp. 01–06. doi:10.1109/iccci54379.2022.9740860.
- [30] E. Filiol, F. Mercaldo, A. Santone, A method for automatic penetration testing and mitigation: A red hat approach, *Procedia Computer Science* 192 (2021) 2039–2046. doi:10.1016/j.procs.2021.08.210.
- [31] V. Chandrika, Ethical hacking: Types of ethical hackers, *International Journal of Emerging Technology in Computer Science & Electronics (IJETCSE)* 11 (1) (2014) 44–45.
- [32] E. I. Egho-Promise, M. Sitti, Big data security management in digital environment, *American Journal of Multidisciplinary Research & Development (AJMRD)* 6 (02) (2024) 01–34.
- [33] MITRE, Common vulnerabilities and exposures.  
URL <https://cve.mitre.org/>

- [34] MITRE, Common weakness enumeration.  
URL <https://cwe.mitre.org/>
- [35] PCI Security Standards Council, Payment card industry data security standard: Requirements and testing procedures, v4.0 (2022).  
URL [https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4\\_0.pdf](https://docs-prv.pcisecuritystandards.org/PCI%20DSS/Standard/PCI-DSS-v4_0.pdf)
- [36] PCI Security Standards Council, Pci data security standard - penetration testing guidance (2017).  
URL [https://listings.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1\\_1.pdf](https://listings.pcisecuritystandards.org/documents/Penetration-Testing-Guidance-v1_1.pdf)
- [37] B. Rathore, M. Brunner, M. Dilaj, O. Herrera, P. Brunati, R. Subramaniam, S. Raman, U. Chavan, Information systems security assessment framework (issaf), Draft 0.2 B 1 (2006) 2006.
- [38] P. Herzog, The open source security testing methodology manual (2010).  
URL <https://www.isecom.org/OSSTMM.3.pdf>
- [39] K. A. Scarfone, M. P. Souppaya, A. Cody, A. D. Orebaugh, Sp 800-115. technical guide to information security testing and assessment (2008).
- [40] F. E. Cerullo, Owasp top 10 2009, in: C. Serrão, V. Aguilera Díaz, F. Cerullo (Eds.), Web Application Security, Springer Berlin Heidelberg, Berlin, Heidelberg, 2010, pp. 19–19. doi:10.1007/978-3-642-16120-9\_10.
- [41] M. Meucci, A. Muller, Owasp testing guide v4.0 (2014).  
URL [https://owasp.org/www-project-web-security-testing-guide/assets/archive/OWASP\\_Testing\\_Guide\\_v4.pdf](https://owasp.org/www-project-web-security-testing-guide/assets/archive/OWASP_Testing_Guide_v4.pdf)
- [42] D. Moher, L. Shamseer, M. Clarke, D. Ghersi, A. Liberati, M. Petticrew, P. Shekelle, L. A. Stewart, P.-P. Group, Preferred reporting items for systematic review and meta-analysis protocols (prisma-p) 2015 statement, Systematic reviews 4 (2015) 1–9.
- [43] D. N. Astrida, A. R. Saputra, A. I. Assaafi, Analysis and evaluation of wireless network security with the penetration testing execution standard (ptes), Sinkron: jurnal dan penelitian teknik informatika 7 (1) (2022) 147–154. doi:10.33395/sinkron.v7i1.11249.
- [44] P. Rajesh, M. Alam, M. Tahernezehadi, A. Monika, G. Chanakya, Analysis of cyber threat detection and emulation using mitre attack framework, in: 2022 International Conference on Intelligent Data Science Technologies and Applications (IDSTA), IEEE, 2022, pp. 4–12. doi:10.1109/idsta55301.2022.9923170.
- [45] A. Georgiadou, S. Mouzakitis, D. Askounis, Assessing mitre att&ck risk using a cyber-security culture framework, Sensors 21 (9) (2021) 3267. doi:10.3390/s21093267.
- [46] S. Messinis, N. Temenos, N. E. Protonotarios, I. Rallis, D. Kalogeras, N. Doulamis, Enhancing internet of medical things security with artificial intelligence: A comprehensive review, Computers in Biology and Medicine (2024) 108036doi:10.1016/j.combiomed.2024.108036.
- [47] O. Alexander, M. Belisle, J. Steele, Mitre att&ck for industrial control systems: Design and philosophy, The MITRE Corporation: Bedford, MA, USA 29 (2020).
- [48] L. Williams, The Cyber Security Body of Knowledge v1.1.0, 2021, University of Bristol, 2021, Ch. Secure Software Lifecycle, kA Version 1.0.2.  
URL <https://www.cybok.org/>
- [49] L. Nautiyal, A. Rashid, J. Hallett, B. Shreeve, The uk’s cyber security degree certification programme: A cybok case study, Tech. rep. (2020).

- [50] S. Attwood, A. Williams, Exploring the uk cyber skills gap through a mapping of active job listings to the cyber security body of knowledge (cybok), in: *Proceedings of the 27th International Conference on Evaluation and Assessment in Software Engineering*, 2023, pp. 273–278. doi:10.1145/3593434.3593459.
- [51] D. Pasquini, M. Cianfriglia, G. Ateniese, M. Bernaschi, Reducing bias in modeling real-world password strength via deep learning and dynamic dictionaries, in: M. D. Bailey, R. Greenstadt (Eds.), *30th USENIX Security Symposium*, USENIX Security 2021, August 11-13, 2021, USENIX Association, 2021, pp. 821–838.  
URL <https://www.usenix.org/conference/usenixsecurity21/presentation/pasquini>
- [52] M. Fu, C. Tantithamthavorn, T. Le, Y. Kume, V. Nguyen, D. Phung, J. Grundy, Aibug Hunter: A practical tool for predicting, classifying and repairing software vulnerabilities, *Empirical Software Engineering* 29 (1) (Nov. 2023). doi:10.1007/s10664-023-10346-3.
- [53] L.-H. Chen, F.-H. Hsu, Y. Hwang, M.-C. Su, W.-S. Ku, C.-H. Chang, Armory: An automatic security testing tool for buffer overflow defect detection, *Computers & Electrical Engineering* 39 (7) (2013) 2233–2242. doi:10.1016/j.compeleceng.2012.07.005.
- [54] N. Moscovich, R. Bitton, Y. Mallah, M. Inokuchi, T. Yagyu, M. Kalech, Y. Elovici, A. Shabtai, Autosplit: A fully automated framework for evaluating the exploitability of security vulnerabilities (2020). doi:10.48550/arXiv.2007.00059.
- [55] R. Egert, T. Grube, D. Born, M. Mühlhäuser, AVAIN – a framework for automated vulnerability indication for the IoT in IP-based networks, in: *2019 International Conference on Networked Systems, NetSys 2019*, Munich, Germany, March 18-21, 2019, IEEE, 2019, pp. 1–3. doi:10.1109/NetSys.2019.8854493.
- [56] B. Blumbergs, R. Vaarandi, Bbuzz: A bit-aware fuzzing framework for network protocol systematic reverse engineering and analysis, in: *2017 IEEE Military Communications Conference, MILCOM 2017*, Baltimore, MD, USA, October 23-25, 2017, IEEE, 2017, pp. 707–712. doi:10.1109/MILCOM.2017.8170785.
- [57] B. Eriksson, A. Stjerna, R. De Masellis, P. Rüemmer, A. Sabelfeld, Black ostrich: Web application scanning with string solvers, in: *Proceedings of the 2023 ACM SIGSAC Conference on Computer and Communications Security, CCS '23*, ACM, 2023. doi:10.1145/3576915.3616582.
- [58] B. Eriksson, G. Pellegrino, A. Sabelfeld, Black widow: Blackbox data-driven web scanning, in: *42nd IEEE Symposium on Security and Privacy, SP 2021*, San Francisco, CA, USA, 24-27 May 2021, IEEE, 2021, pp. 1125–1142. doi:10.1109/SP40001.2021.00022.
- [59] Z. Luo, J. Yu, F. Zuo, J. Liu, Y. Jiang, T. Chen, A. Roychoudhury, J. Sun, Bleem: Packet sequence oriented fuzzing for protocol implementations, in: J. A. Calandrino, C. Troncoso (Eds.), *32nd USENIX Security Symposium*, USENIX Security 2023, Anaheim, CA, USA, August 9-11, 2023, USENIX Association, 2023, pp. 4481–4498.  
URL <https://www.usenix.org/conference/usenixsecurity23/presentation/luo-zhengxiong>
- [60] S. Faily, R. Scandariato, A. Shostack, L. Sion, D. Ki-Aries, Contextualisation of data flow diagrams for security analysis, in: H. E. III, O. Gadyatskaya (Eds.), *Graphical Models for Security - 7th International Workshop, GraMSec 2020*, Boston, MA, USA, June 22, 2020 Revised Selected Papers, Vol. 12419 of *Lecture Notes in Computer Science*, Springer, 2020, pp. 186–197. doi:10.1007/978-3-030-62230-5\_10.
- [61] Z. Durumeric, D. Adrian, A. Mirian, M. Bailey, J. A. Halderman, A search engine backed by Internet-wide scanning, in: *22nd ACM Conference on Computer and Communications Security*, 2015, pp. 542–553. doi:10.1145/2810103.2813703.

- [62] A. Alhuzali, B. Eshete, R. Gjomemo, V. N. Venkatakrishnan, Chainsaw: Chained automated workflow-based exploit generation, in: E. R. Weippl, S. Katzenbeisser, C. Kruegel, A. C. Myers, S. Halevi (Eds.), Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security, Vienna, Austria, October 24-28, 2016, ACM, 2016, pp. 641–652. doi:10.1145/2976749.2978380.
- [63] F. Yamaguchi, C. Wressnegger, H. Gascon, K. Rieck, Chucky: exposing missing checks in source code for vulnerability discovery, in: A. Sadeghi, V. D. Gligor, M. Yung (Eds.), 2013 ACM SIGSAC Conference on Computer and Communications Security, CCS’13, Berlin, Germany, November 4-8, 2013, ACM, 2013, pp. 499–510. doi:10.1145/2508859.2516665.
- [64] A. Stasinopoulos, C. Ntantogian, C. Xenakis, Commix: automating evaluation and exploitation of command injection vulnerabilities in web applications, *Int. J. Inf. Sec.* 18 (1) (2019) 49–72. doi:10.1007/s10207-018-0399-z.
- [65] S. Rahaman, Y. Xiao, S. Afrose, F. Shaon, K. Tian, M. Frantz, M. Kantarcioglu, D. D. Yao, Cryptoguard: High precision detection of cryptographic vulnerabilities in massive-sized java projects, in: L. Cavallaro, J. Kinder, X. Wang, J. Katz (Eds.), Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security, CCS 2019, London, UK, November 11-15, 2019, ACM, 2019, pp. 2455–2472. doi:10.1145/3319535.3345659.
- [66] R. Li, W. Diao, Z. Li, J. Du, S. Guo, Android custom permissions demystified: From privilege escalation to design shortcomings, in: 42nd IEEE Symposium on Security and Privacy, SP 2021, San Francisco, CA, USA, 24-27 May 2021, IEEE, 2021, pp. 70–86. doi:10.1109/SP40001.2021.00070.
- [67] G. Pellegrino, M. Johns, S. Koch, M. Backes, C. Rossow, Deemon: Detecting CSRF with dynamic analysis and property graphs, in: B. Thuraisingham, D. Evans, T. Malkin, D. Xu (Eds.), Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security, CCS 2017, Dallas, TX, USA, October 30 - November 03, 2017, ACM, 2017, pp. 1757–1771. doi:10.1145/3133956.3133959.
- [68] S. Lee, C. Yoon, C. Lee, S. Shin, V. Yegneswaran, P. A. Porras, Delta: A security assessment framework for software-defined networks., in: NDSS, 2017. doi:10.14722/ndss.2017.23457.
- [69] C. K. Ng, Y. Yusof, N. S. N. Ab Aziz, Dfbc recon tool: Digital footprint and breach check reconnaissance tool, in: 2021 14th International Conference on Developments in eSystems Engineering (DeSE), IEEE, 2021, pp. 526–530. doi:10.1109/dese54285.2021.9719440.
- [70] N. Redini, A. Continella, D. Das, G. De Pasquale, N. Spahn, A. Machiry, A. Bianchi, C. Kruegel, G. Vigna, Diane: Identifying fuzzing triggers in apps to generate under-constrained inputs for iot devices, in: 2021 IEEE Symposium on Security and Privacy (SP), IEEE, 2021, pp. 484–500. doi:10.1109/sp40001.2021.00066.
- [71] F. Aljaafari, R. Menezes, M. A. Mustafa, L. C. Cordeiro, Finding security vulnerabilities in iot cryptographic protocol and concurrent implementations (2021). doi:10.48550/arXiv.2103.11363.
- [72] L. Xu, M. Xu, F. Li, W. Huo, ELAID: detecting integer-overflow-to-buffer-overflow vulnerabilities by light-weight and accurate static analysis, *Cybersecur.* 3 (1) (2020) 1–19. doi:10.1186/s42400-020-00058-2.
- [73] M. C. Ghanem, T. M. Chen, M. A. Ferrag, M. E. Kettouche, Esascf: Expertise extraction, generalization and reply framework for optimized automation of network security compliance, *IEEE Access* 11 (2023) 129840–129853. doi:10.1109/access.2023.3332834.
- [74] Y. Zhang, W. Huo, K. Jian, J. Shi, L. Liu, Y. Zou, C. Zhang, B. Liu, Esrfuzzer: an enhanced fuzzing framework for physical SOHO router devices to discover multi-type vulnerabilities, *Cybersecur.* 4 (1) (2021) 24. doi:10.1186/s42400-021-00091-9.

- [75] M. Rak, G. Salzillo, D. Granata, Esseca: An automated expert system for threat modelling and penetration testing for iot ecosystems, *Computers and Electrical Engineering* 99 (2022) 107721. doi:10.1016/j.compeleceng.2022.107721.
- [76] V. Visoottiviset, P. Jutadhammakorn, N. Pongchanchai, P. Kosolyudhthasarn, Firmaster: Analysis tool for home router firmware, in: 2018 15th International Joint Conference on Computer Science and Software Engineering (JCSSE), 2018, pp. 1–6. doi:10.1109/JCSSE.2018.8457340.
- [77] S. Park, D. Kim, S. Jana, S. Son, FUGIO: automatic exploit generation for PHP object injection vulnerabilities, in: K. R. B. Butler, K. Thomas (Eds.), 31st USENIX Security Symposium, USENIX Security 2022, Boston, MA, USA, August 10–12, 2022, USENIX Association, 2022, pp. 197–214.
- [78] T. Lee, S. Wi, S. Lee, S. Son, FUSE: finding file upload bugs via penetration testing, in: 27th Annual Network and Distributed System Security Symposium, NDSS 2020, San Diego, California, USA, February 23–26, 2020, The Internet Society, 2020. doi:10.14722/ndss.2020.23126.
- [79] J. Chen, S. Hu, H. Zheng, C. Xing, G. Zhang, Gail-pt: An intelligent penetration testing framework with generative adversarial imitation learning, *Computers & Security* 126 (2023) 103055. doi:10.1016/j.cose.2022.103055.
- [80] F. Yu, M. V. Martin, Gnpassgan: Improved generative adversarial networks for trawling offline password guessing, in: 2022 IEEE European Symposium on Security and Privacy Workshops (EuroS&PW), IEEE, 2022. doi:10.1109/eurospw55150.2022.00009.
- [81] S. Y. Enoch, Z. Huang, C. Y. Moon, D. Lee, M. K. Ahn, D. S. Kim, Harmer: Cyber-attacks automation and evaluation, *IEEE Access* 8 (2020) 129397–129414. arXiv:2006.14352, doi:10.1109/ACCESS.2020.3009748.
- [82] R. Sommer, M. Vallentin, L. De Carli, V. Paxson, Hilti: an abstract execution environment for deep, stateful network traffic analysis, in: Proceedings of the 2014 Conference on Internet Measurement Conference, IMC '14, ACM, 2014. doi:10.1145/2663716.2663735.
- [83] J. Chen, W. Diao, Q. Zhao, C. Zuo, Z. Lin, X. Wang, W. C. Lau, M. Sun, R. Yang, K. Zhang, Iotfuzzer: Discovering memory corruptions in iot through app-based fuzzing, in: 25th Annual Network and Distributed System Security Symposium, NDSS 2018, San Diego, California, USA, February 18–21, 2018, The Internet Society, 2018. doi:10.14722/ndss.2018.23159.
- [84] D. M. Stallenberg, A. Panichella, JCOMIX: a search-based tool to detect XML injection vulnerabilities in web applications, in: Proceedings of the 2019 27th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering, ESEC/FSE 2019, Association for Computing Machinery, New York, NY, USA, 2019, pp. 1090–1094. doi:10.1145/3338906.3341178.
- [85] M. Xu, S. Li, L. Xu, F. Li, W. Huo, J. Ma, X. Li, Q. Huang, A light-weight and accurate method of static integer-overflow-to-buffer-overflow vulnerability detection, in: F. Guo, X. Huang, M. Yung (Eds.), Information Security and Cryptology - 14th International Conference, Inscrypt 2018, Fuzhou, China, December 14–17, 2018, Revised Selected Papers, Vol. 11449 of Lecture Notes in Computer Science, Springer, 2018, pp. 404–423. doi:10.1007/978-3-030-14234-6\_22.
- [86] S. Lee, S. Wi, S. Son, Link: Black-box detection of cross-site scripting vulnerabilities using reinforcement learning, in: Proceedings of the ACM Web Conference 2022, 2022, pp. 743–754. doi:10.1145/3485447.3512234.
- [87] H. Holm, Lore a red team emulation tool, *IEEE Trans. Dependable Secur. Comput.* 20 (2) (2023) 1596–1608. doi:10.1109/TDSC.2022.3160792.

- [88] T. D. Hoang, C. Park, M. Son, T. Oh, S. Bae, J. Ahn, B. Oh, Y. Kim, Ltesniffer: An open-source lte downlink/uplink eavesdropper, in: *Proceedings of the 16th ACM Conference on Security and Privacy in Wireless and Mobile Networks, WiSec '23*, Association for Computing Machinery, New York, NY, USA, 2023, pp. 43–48. doi:10.1145/3558482.3590196.
- [89] M. Monshizadeh, P. Naldurg, V. N. Venkatakrishnan, Mace: Detecting privilege escalation vulnerabilities in web applications, in: *Proceedings of the 2014 ACM SIGSAC Conference on Computer and Communications Security*, 2014, pp. 690–701. doi:10.1145/2660267.2660337.
- [90] C. Yucel, A. Lockett, I. Chalkias, D. Mallis, V. Katos, Mait: Malware analysis and intelligence tool, *Information & Security* 50 (1) (2021) 49–65. doi:10.11610/isij.5024.
- [91] P. Johnson, R. Lagerström, M. Ekstedt, A meta-language for threat modelling and attack simulations, in: *Proceedings of the 13th International Conference on Availability, Reliability and Security*, 2018, pp. 1–8. doi:10.1145/3230833.3232799.
- [92] C. Liu, X. Cui, Z. Wang, X. Wang, Y. Feng, X. Li, Malicescript: A novel browser-based intranet threat, in: *2018 IEEE Third International Conference on Data Science in Cyberspace (DSC)*, IEEE, 2018, pp. 219–226. doi:10.1109/dsc.2018.00039.
- [93] O. Mjihil, D. S. Kim, A. Haqiq, Masat: Model-based automated security assessment tool for cloud computing, in: *2015 11th International Conference on Information Assurance and Security (IAS)*, IEEE, 2015, pp. 97–103. doi:10.1109/isias.2015.7492752.
- [94] R. Cayre, V. Nicomette, G. Auriol, E. Alata, M. Kaaniche, G. Marconato, Mirage: towards a metasploit-like framework for iot, in: *2019 IEEE 30th International Symposium on Software Reliability Engineering (ISSRE)*, IEEE, 2019, pp. 261–270. doi:10.1109/issre.2019.00034.
- [95] S. Calzavara, M. Conti, R. Focardi, A. Rabitti, G. Tolomei, Mitch: A machine learning approach to the black-box detection of CSRF vulnerabilities, in: *IEEE European Symposium on Security and Privacy, EuroS&P 2019*, Stockholm, Sweden, June 17-19, 2019, IEEE, 2019, pp. 528–543. doi:10.1109/EuroSP.2019.00045.
- [96] H. Wei, B. Hassanshahi, G. Bai, P. Krishnan, K. Vorobyov, Moscan: a model-based vulnerability scanner for web single sign-on services, in: C. Cadar, X. Zhang (Eds.), *ISSTA '21: 30th ACM SIGSOFT International Symposium on Software Testing and Analysis*, Virtual Event, Denmark, July 11-17, 2021, ACM, 2021, pp. 678–681. doi:10.1145/3460319.3469081.
- [97] G. Deng, Z. Zhang, Y. Li, Y. Liu, T. Zhang, Y. Liu, G. Yu, D. Wang, NAUTILUS: automated restful API vulnerability detection, in: J. A. Calandrino, C. Troncoso (Eds.), *32nd USENIX Security Symposium*, USENIX Security 2023, Anaheim, CA, USA, August 9-11, 2023, USENIX Association, 2023.
- [98] A. Alhuzali, R. Gjomemo, B. Eshete, V. N. Venkatakrishnan, NAVEX: precise and scalable exploit generation for dynamic web applications, in: W. Enck, A. P. Felt (Eds.), *27th USENIX Security Symposium*, USENIX Security 2018, Baltimore, MD, USA, August 15-17, 2018, USENIX Association, 2018, pp. 377–392.
- [99] M. Kurth, B. Gras, D. Andriesse, C. Giuffrida, H. Bos, K. Razavi, Netcat: Practical cache attacks from the network, in: *2020 IEEE Symposium on Security and Privacy (SP)*, IEEE, 2020. doi:10.1109/sp40000.2020.00082.
- [100] W. Melicher, B. Ur, S. Komanduri, L. Bauer, N. Christin, L. F. Cranor, Fast, lean, and accurate: Modeling password guessability using neural networks, in: D. D. Silva, B. Ford (Eds.), *2017 USENIX Annual Technical Conference, USENIX ATC 2017*, Santa Clara, CA, USA, July 12-14, 2017, USENIX Association, 2017.  
URL <https://www.usenix.org/conference/atc17/technical-sessions/presentation/melicher>



- [101] W. H. Rankothge, S. M. N. Randeniya, Identification and mitigation tool for cross-site request forgery (csrf), in: 2020 IEEE 8th R10 Humanitarian Technology Conference (R10-HTC), 2020, pp. 1–5. doi:10.1109/R10-HTC49770.2020.9357029.
- [102] A. G. Leal, I. C. Teixeira, Development of a suite of ipv6 vulnerability scanning tests using the TTCN-3 language, in: 2018 International Symposium on Networks, Computers and Communications, ISNCC 2018, Rome, Italy, June 19-21, 2018, IEEE, 2018, pp. 1–6. doi:10.1109/ISNCC.2018.8530888.
- [103] R. Chatterjee, J. Bonneau, A. Juels, T. Ristenpart, Cracking-resistant password vaults using natural language encoders, in: 2015 IEEE Symposium on Security and Privacy, SP 2015, San Jose, CA, USA, May 17-21, 2015, IEEE Computer Society, 2015, pp. 481–498. doi:10.1109/SP.2015.36.
- [104] C. Ntantogian, P. Bountakas, D. Antonaropoulos, C. Patsakis, C. Xenakis, Nodexp: Node.js server-side javascript injection vulnerability detection and exploitation, Journal of Information Security and Applications 58 (2021) 102752. doi:10.1016/j.jisa.2021.102752.
- [105] N. Koutroumpouchos, G. Lavdanis, E. Veroni, C. Ntantogian, C. Xenakis, Objectmap: detecting insecure object deserialization, in: Y. Manolopoulos, G. A. Papadopoulos, A. Stassopoulou, I. Dionysiou, I. Kyriakides, N. Tsapatsoulis (Eds.), Proceedings of the 23rd Pan-Hellenic Conference on Informatics, PCI 2019, Nicosia, Cyprus, November 28-30, 2019, ACM, 2019, pp. 67–72. doi:10.1145/3368640.3368680.
- [106] M. Dürmuth, F. Angelstorf, C. Castelluccia, D. Perito, A. Chaabane, Omen: Faster password guessing using an ordered markov enumerator, in: Engineering Secure Software and Systems: 7th International Symposium, ESSoS 2015, Milan, Italy, March 4-6, 2015. Proceedings 7, Springer, 2015, pp. 119–132. doi:10.1007/978-3-319-15618-7\_10.
- [107] P. Kasemsuwan, V. Visoottiviset, Osv: Ospf vulnerability checking tool, in: 2017 14th International Joint Conference on Computer Science and Software Engineering (JCSSE), IEEE, 2017, pp. 1–6. doi:10.1109/jcsse.2017.8025919.
- [108] H. Cao, L. Huang, S. Hu, S. Shi, Y. Liu, Owfuzz: Discovering wi-fi flaws in modern devices through over-the-air fuzzing, in: Proceedings of the 16th ACM Conference on Security and Privacy in Wireless and Mobile Networks, WiSec '23, Association for Computing Machinery, New York, NY, USA, 2023, pp. 263–273. doi:10.1145/3558482.3590174.
- [109] B. Hitaj, P. Gasti, G. Ateniese, F. Pérez-Cruz, Passgan: A deep learning approach for password guessing, in: R. H. Deng, V. Gauthier-Umaña, M. Ochoa, M. Yung (Eds.), Applied Cryptography and Network Security - 17th International Conference, ACNS 2019, Bogota, Colombia, June 5-7, 2019, Proceedings, Vol. 11464 of Lecture Notes in Computer Science, Springer, 2019, pp. 217–237. doi:10.1007/978-3-030-21568-2\_11.
- [110] J. Rando, F. Pérez-Cruz, B. Hitaj, Passgpt: Password modeling and (guided) generation with large language models, in: G. Tsudik, M. Conti, K. Liang, G. Smaragdakis (Eds.), Computer Security - ESORICS 2023 - 28th European Symposium on Research in Computer Security, The Hague, The Netherlands, September 25-29, 2023, Proceedings, Part IV, Vol. 14347 of Lecture Notes in Computer Science, Springer, 2023, pp. 164–183. doi:10.1007/978-3-031-51482-1\_9.
- [111] A. M. D. Campi, R. Focardi, F. L. Luccio, The revenge of password crackers: Automated training of password cracking tools, in: V. Atluri, R. D. Pietro, C. D. Jensen, W. Meng (Eds.), Computer Security - ESORICS 2022 - 27th European Symposium on Research in Computer Security, Copenhagen, Denmark, September 26-30, 2022, Proceedings, Part II, Vol. 13555 of Lecture Notes in Computer Science, Springer, 2022, pp. 317–336. doi:10.1007/978-3-031-17146-8\_16.

- [112] R. Luh, M. Temper, S. Tjoa, S. Schrittwieser, H. Janicke, Penquest: a gamified attacker/defender meta model for cyber security assessment and education, *J. Comput. Virol. Hacking Tech.* 16 (1) (2020) 19–61. doi:10.1007/S11416-019-00342-X.
- [113] G. Deng, Y. Liu, V. M. Vilches, P. Liu, Y. Li, Y. Xu, T. Zhang, Y. Liu, M. Pinzger, S. Rass, Pentestgpt: An llm-empowered automatic penetration testing tool, *CoRR abs/2308.06782* (2023). arXiv:2308.06782, doi:10.48550/arXiv.2308.06782.
- [114] P. J. C. Nunes, J. Fonseca, M. Vieira, phpsafe: A security analysis tool for OOP web application plugins, in: 45th Annual IEEE/IFIP International Conference on Dependable Systems and Networks, DSN 2015, Rio de Janeiro, Brazil, June 22-25, 2015, IEEE Computer Society, 2015, pp. 299–306. doi:10.1109/DSN.2015.16.
- [115] S. Jain, R. Johari, A. Kaur, Pjct: Penetration testing based java code testing tool, in: International Conference on Computing, Communication & Automation, IEEE, 2015, pp. 800–805. doi:10.1109/ccaa.2015.7148483.
- [116] N. Saccente, J. Dehlinger, L. Deng, S. Chakraborty, Y. Xiong, Project achilles: A prototype tool for static method-level vulnerability detection of java source code using a recurrent neural network, in: 34th IEEE/ACM International Conference on Automated Software Engineering Workshops, ASE Workshops 2019, San Diego, CA, USA, November 11-15, 2019, IEEE, 2019, pp. 114–121. doi:10.1109/ASEW.2019.00040.
- [117] J. Bozic, F. Wotawa, Purity: a planning-based security testing tool, in: 2015 IEEE International Conference on Software Quality, Reliability and Security-Companion, IEEE, 2015, pp. 46–55. doi:10.1109/qrs-c.2015.19.
- [118] M. Muralidharan, K. B. Babu, G. Sujatha, Pyciuti: A python based customizable and flexible cybersecurity utility tool for penetration testing, in: 2023 International Conference on Innovative Data Communication Technologies and Application (ICIDCA), IEEE, 2023, pp. 679–683. doi:10.1109/icidca56705.2023.10099938.
- [119] M. Amouei, M. Rezvani, M. Fateh, RAT: reinforcement-learning-driven and adaptive testing for vulnerability discovery in web application firewalls, *IEEE Trans. Dependable Secur. Comput.* 19 (5) (2022) 3371–3386. doi:10.1109/TDSC.2021.3095417.
- [120] Y. Liu, M. Zhang, W. Meng, Revealer: Detecting and exploiting regular expression denial-of-service vulnerabilities, in: 42nd IEEE Symposium on Security and Privacy, SP 2021, San Francisco, CA, USA, 24-27 May 2021, IEEE, 2021, pp. 1468–1484. doi:10.1109/SP40001.2021.00062.
- [121] T. Cloosters, D. Paaßen, J. Wang, O. Draissi, P. Jauernig, E. Stapf, L. Davi, A.-R. Sadeghi, Riscyrop: Automated return-oriented programming attacks on risc-v and arm64, in: Proceedings of the 25th International Symposium on Research in Attacks, Intrusions and Defenses, RAID '22, Association for Computing Machinery, New York, NY, USA, 2022, pp. 30–42. doi:10.1145/3545948.3545997.
- [122] G. Giroto, A. F. Zorzo, Robin: A web security tool, *CoRR abs/2007.06629* (2020). arXiv:2007.06629, doi:10.48550/arxiv.2007.06629.
- [123] S. Rivera, S. Lagraa, R. State, Rosploit: Cybersecurity tool for ROS, in: 3rd IEEE International Conference on Robotic Computing, IRC 2019, Naples, Italy, February 25-27, 2019, IEEE, 2019, pp. 415–416. doi:10.1109/IRC.2019.00077.
- [124] F. Z. Fagroud, H. Toumi, Y. Baddi, S. El Filali, et al., Rt-rct: an online tool for real-time retrieval of connected things, *Bulletin of Electrical Engineering and Informatics* 10 (5) (2021) 2804–2810. doi:10.11591/eei.v10i5.2901.

- [125] Z. Yin, Y. Xu, F. Ma, H. Gao, L. Qiao, Y. Jiang, Scanner++: Enhanced vulnerability detection of web applications with attack intent synchronization, *ACM Trans. Softw. Eng. Methodol.* 32 (1) (Feb. 2023). doi:10.1145/3517036.
- [126] R. Veras, C. Collins, J. Thorpe, On semantic patterns of passwords and their security impact, in: 21st Annual Network and Distributed System Security Symposium, NDSS 2014, San Diego, California, USA, February 23-26, 2014, The Internet Society, 2014. doi:10.14722/ndss.2014.23103.
- [127] M. Shcherbakov, M. Balliu, Serialdetector: Principled and practical exploration of object injection vulnerabilities for the web, in: 28th Annual Network and Distributed System Security Symposium, NDSS 2021, virtually, February 21-25, 2021, The Internet Society, 2021. doi:10.14722/ndss.2021.24550.
- [128] B. Genge, C. Enachescu, Shovat: Shodan-based vulnerability assessment tool for internet-facing services, *Secur. Commun. Networks* 9 (15) (2016) 2696–2714. doi:10.1002/SEC.1262.
- [129] J. Mikulskis, J. K. Becker, S. Gvozdenovic, D. Starobinski, Snout: An extensible iot pen-testing tool, in: L. Cavallaro, J. Kinder, X. Wang, J. Katz (Eds.), *Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security, CCS 2019, London, UK, November 11-15, 2019*, ACM, 2019, pp. 2529–2531. doi:10.1145/3319535.3363248.
- [130] N. Antunes, M. Vieira, Soa-scanner: an integrated tool to detect vulnerabilities in service-based infrastructures, in: 2013 IEEE International Conference on Services Computing, IEEE, 2013, pp. 280–287. doi:10.1109/scc.2013.28.
- [131] R. Sommer, J. Amann, S. Hall, Spicy: a unified deep packet inspection framework for safely dissecting all your data, in: S. Schwab, W. K. Robertson, D. Balzarotti (Eds.), *Proceedings of the 32nd Annual Conference on Computer Security Applications, ACSAC 2016, Los Angeles, CA, USA, December 5-9, 2016*, ACM, 2016, pp. 558–569. doi:10.1145/2991079.2991100.
- [132] Z. Li, X. Yu, D. Wang, Y. Liu, H. Yin, S. He, Supereye: A distributed port scanning system, in: X. Sun, Z. Pan, E. Bertino (Eds.), *Artificial Intelligence and Security - 5th International Conference, ICAIS 2019, New York, NY, USA, July 26-28, 2019, Proceedings, Part IV, Vol. 11635 of Lecture Notes in Computer Science*, Springer, 2019, pp. 46–56. doi:10.1007/978-3-030-24268-8\_5.
- [133] H. Holm, T. Sommestad, SVED: scanning, vulnerabilities, exploits and detection, in: J. Brand, M. C. Valenti, A. Akinpelu, B. T. Doshi, B. L. Gorsic (Eds.), *2016 IEEE Military Communications Conference, MILCOM 2016, Baltimore, MD, USA, November 1-3, 2016*, IEEE, 2016, pp. 976–981. doi:10.1109/MILCOM.2016.7795457.
- [134] F. Valenza, E. Karafili, R. V. Steiner, E. C. Lupu, A hybrid threat model for smart systems, *IEEE Trans. Dependable Secur. Comput.* 20 (5) (2023) 4403–4417. doi:10.1109/TDSC.2022.3213577.
- [135] C. Luo, P. Li, W. Meng, Tchecker: Precise static inter-procedural analysis for detecting taint-style vulnerabilities in PHP applications, in: H. Yin, A. Stavrou, C. Cremers, E. Shi (Eds.), *Proceedings of the 2022 ACM SIGSAC Conference on Computer and Communications Security, CCS 2022, Los Angeles, CA, USA, November 7-11, 2022*, ACM, 2022, pp. 2175–2188. doi:10.1145/3548606.3559391.
- [136] O. Olivo, I. Dillig, C. Lin, Detecting and exploiting second order denial-of-service vulnerabilities in web applications, in: *Proceedings of the 22nd ACM SIGSAC Conference on Computer and Communications Security*, 2015, pp. 616–628. doi:10.1145/2810103.2813680.
- [137] E. Bitsikas, S. Khandker, A. Salous, A. Ranganathan, R. Piqueras Jover, C. Pöpper, Ue security reloaded: Developing a 5g standalone user-side security testing framework, in: *Proceedings of the 16th ACM Conference on Security and Privacy in Wireless and Mobile Networks, WiSec '23*, Association for Computing Machinery, New York, NY, USA, 2023, pp. 121–132. doi:10.1145/3558482.3590194.

- [138] A. Bertani, M. Bonelli, L. Binosi, M. Carminati, S. Zanero, M. Polino, Untangle: Aiding global function pointer hijacking for post-cet binary exploitation, in: D. Gruss, F. Maggi, M. Fischer, M. Carminati (Eds.), *Detection of Intrusions and Malware, and Vulnerability Assessment - 20th International Conference, DIMVA 2023, Hamburg, Germany, July 12-14, 2023, Proceedings*, Vol. 13959 of *Lecture Notes in Computer Science*, Springer, 2023, pp. 256–275. doi:10.1007/978-3-031-35504-2\_13.
- [139] K. Vimala, S. Fugkeaw, Vape-bridge: Bridging openvas results for automating metasploit framework, in: *2022 14th International Conference on Knowledge and Smart Technology (KST)*, IEEE, 2022. doi:10.1109/kst53302.2022.9729085.
- [140] A. Blome, M. Ochoa, K. Li, M. Peroli, M. T. Dashti, Vera: A flexible model-based vulnerability testing tool, in: *2013 IEEE Sixth International Conference on Software Testing, Verification and Validation, IEEE, 2013*, pp. 471–478. doi:10.1109/icst.2013.65.
- [141] S. Kim, S. Woo, H. Lee, H. Oh, VUDDY: A scalable approach for vulnerable code clone discovery, in: *2017 IEEE Symposium on Security and Privacy, SP 2017, San Jose, CA, USA, May 22-26, 2017*, IEEE Computer Society, 2017, pp. 595–614. doi:10.1109/SP.2017.62.
- [142] P. Kamongi, S. Kotikela, K. Kavi, M. Gomathisankaran, A. Singhal, Vulcan: Vulnerability assessment framework for cloud computing, in: *2013 IEEE 7th international conference on software security and reliability, IEEE, 2013*, pp. 218–226. doi:10.1109/sere.2013.31.
- [143] Y. Wu, D. Zou, S. Dou, W. Yang, D. Xu, H. Jin, Vulcnn: An image-inspired scalable vulnerability detection system, in: *Proceedings of the 44th International Conference on Software Engineering, ICSE '22, Association for Computing Machinery, New York, NY, USA, 2022*, pp. 2365–2376. doi:10.1145/3510003.3510229.
- [144] Z. Li, D. Zou, S. Xu, X. Ou, H. Jin, S. Wang, Z. Deng, Y. Zhong, Vuldeepecker: A deep learning-based system for vulnerability detection, in: *25th Annual Network and Distributed System Security Symposium, NDSS 2018, San Diego, California, USA, February 18-21, 2018*, The Internet Society, 2018. doi:10.14722/ndss.2018.23158.
- [145] P. Cigoj, B. J. Blazic, An intelligent and automated wcms vulnerability-discovery tool: The current state of the web, *IEEE Access* 7 (2019) 175466–175473. doi:10.1109/ACCESS.2019.2957573.
- [146] A. Castiglione, F. Palmieri, M. Petraglia, R. Pizzolante, Vulsploit: A module for semi-automatic exploitation of vulnerabilities, in: V. Casola, A. De Benedictis, M. Rak (Eds.), *Testing Software and Systems*, Springer, Springer International Publishing, Cham, 2020, pp. 89–103. doi:10.1007/978-3-030-64881-7\_6.
- [147] Z. Li, D. Zou, S. Xu, H. Jin, H. Qi, J. Hu, Vulpecker: an automated vulnerability detection system based on code similarity analysis, in: S. Schwab, W. K. Robertson, D. Balzarotti (Eds.), *Proceedings of the 32nd Annual Conference on Computer Security Applications, ACSAC 2016, Los Angeles, CA, USA, December 5-9, 2016*, ACM, 2016, pp. 201–213. doi:10.1145/2991079.2991102.
- [148] Z. Đurić, Waptt-web application penetration testing tool, *Advances in Electrical and Computer Engineering* 14 (1) (2014) 93–102. doi:10.4316/AECE.2014.01015.
- [149] O. van Rooij, M. A. Charalambous, D. Kaizer, M. Papaevripides, E. Athanasopoulos, webfuzz: Grey-box fuzzing for web applications, in: E. Bertino, H. Schulmann, M. Waidner (Eds.), *Computer Security - ESORICS 2021 - 26th European Symposium on Research in Computer Security, Darmstadt, Germany, October 4-8, 2021, Proceedings, Part I*, Vol. 12972 of *Lecture Notes in Computer Science*, Springer, 2021, pp. 152–172. doi:10.1007/978-3-030-88418-5\_8.

- [150] W. H. Rankothge, M. Randeniya, V. Samaranayaka, Identification and mitigation tool for sql injection attacks (SQLIA), in: 15th IEEE International Conference on Industrial and Information Systems, ICIIS 2020, Rupnagar, India, November 26-28, 2020, IEEE, 2020, pp. 591–595. doi:10.1109/ICIIS51140.2020.9342703.
- [151] J. Ding, Y. Atif, S. F. Andler, B. Lindström, M. Jeusfeld, Cps-based threat modeling for critical infrastructure protection, *ACM SIGMETRICS Performance Evaluation Review* 45 (2) (2017) 129–132. doi:10.1145/3152042.3152080.
- [152] I. Agadakos, C.-Y. Chen, M. Campanelli, P. Anantharaman, M. Hasan, B. Copos, T. Lepoint, M. Locasto, G. F. Ciocarlie, U. Lindqvist, Jumping the air gap: Modeling cyber-physical attack paths in the internet-of-things, in: *Proceedings of the 2017 workshop on cyber-physical systems security and privacy*, 2017, pp. 37–48. doi:10.1145/3140241.3140252.
- [153] L. M. Castiglione, E. C. Lupu, Hazard driven threat modelling for cyber physical systems, in: *Proceedings of the 2020 Joint Workshop on CPS&IoT Security and Privacy*, 2020, pp. 13–24. doi:10.1145/3411498.3419967.
- [154] M. Evans, Y. He, L. Maglaras, H. Janicke, Heart-is: A novel technique for evaluating human error-related information security incidents, *Computers & Security* 80 (2019) 74–89. doi:10.1016/j.cose.2018.09.002.
- [155] N. David, A. David, R. R. Hansen, K. G. Larsen, A. Legay, M. C. Olesen, C. W. Probst, Modeling social-technical attacks with timed automata, in: *Proceedings of the 7th acm ccs international workshop on managing insider security threats*, 2015, pp. 21–28. doi:10.1145/2808783.2808787.
- [156] S. U. R. Malik, A. Anjum, S. A. Moqurrah, G. Srivastava, Towards enhanced threat modelling and analysis using a markov decision process, *Computer Communications* 194 (2022) 282–291. doi:10.1016/j.comcom.2022.07.038.
- [157] E. Kalliamvakou, G. Gousios, K. Blincoe, L. Singer, D. M. German, D. Damian, An in-depth study of the promises and perils of mining github, *Empirical Software Engineering* 21 (2016) 2035–2071. doi:10.1007/s10664-015-9393-5.
- [158] A. Metzger, *Free and open source software (FOSS) and other alternative license models: a comparative analysis*, Vol. 12, Springer, 2015.
- [159] S. Mirhosseini, C. Parnin, Docable: Evaluating the executability of software tutorials, in: *Proceedings of the 28th ACM Joint Meeting on European Software Engineering Conference and Symposium on the Foundations of Software Engineering*, 2020, pp. 375–385. doi:10.5281/zenodo.3903727.
- [160] T. Walshe, A. Simpson, An empirical study of bug bounty programs, in: *2020 IEEE 2nd international workshop on intelligent bug fixing (IBF)*, IEEE, 2020, pp. 35–44. doi:10.1109/ibf50092.2020.9034828.
- [161] K. Lynch, M. Ivancheva, Academic freedom and the commercialisation of universities: a critical ethical analysis, *Ethics in Science and Environmental Politics* 15 (1) (2015) 71–85. doi:10.3354/esep00160.
- [162] University College and Union, *Workload survey 2021 data report* (Jun. 2022).  
URL <https://www.ucu.org.uk/media/12905/UCU-workload-survey-2021-data-report/pdf/WorkloadReportJune22.pdf>
- [163] M. Alhamed, M. M. H. Rahman, A systematic literature review on penetration testing in networks: Future research directions, *Applied Sciences* 13 (12) (2023) 6986. doi:10.3390/app13126986.

- [164] K. U. Sarker, F. Yunus, A. Deraman, Penetration taxonomy: A systematic review on the penetration process, framework, standards, tools, and scoring methods, *Sustainability* 15 (13) (2023) 10471. doi:10.3390/su151310471.
- [165] J. Shahid, M. K. Hameed, I. T. Javed, K. N. Qureshi, M. Ali, N. Crespi, A comparative study of web application security parameters: Current trends and future directions, *Applied Sciences* 12 (8) (2022) 4077. doi:10.3390/app12084077.
- [166] A. Alzahrani, A. Alqazzaz, Y. Zhu, H. Fu, N. Almashfi, Web application security tools analysis, in: 2017 IEEE 3rd International Conference on Big Data Security on Cloud (BigDataSecurity), IEEE International Conference on High Performance and Smart Computing (HPSC), and IEEE International Conference on Intelligent Data and Security (IDS), IEEE, 2017, pp. 237–242. doi:10.11114/smc.v5i2.2663.
- [167] U. Ravindran, R. V. Potukuchi, A review on web application vulnerability assessment and penetration testing., *Review of Computer Engineering Studies* 9 (1) (2022). doi:10.18280/rces.090101.
- [168] A. S. L. Kowta, K. Bhowmick, J. R. Kaur, N. Jeyanthi, Analysis and overview of information gathering & tools for pentesting, in: 2021 International Conference on Computer Communication and Informatics (ICCCI), IEEE, 2021, pp. 1–13. doi:10.1109/iccci50826.2021.9457015.
- [169] P. Zilberman, R. Puzis, S. Bruskin, S. Shwarz, Y. Elovici, Sok: A survey of open-source threat emulators, arXiv preprint arXiv:2003.01518 (2020).
- [170] Z. Durumeric, E. Wustrow, J. A. Halderman, {ZMap}: fast internet-wide scanning and its security applications, in: 22nd USENIX Security Symposium (USENIX Security 13), 2013, pp. 605–620.
- [171] C. Lattner, V. S. Adve, LLVM: A compilation framework for lifelong program analysis & transformation, in: 2nd IEEE / ACM International Symposium on Code Generation and Optimization (CGO 2004), 20–24 March 2004, San Jose, CA, USA, IEEE Computer Society, 2004, pp. 75–88. doi:10.1109/CGO.2004.1281665.
- [172] P. E. Black, P. E. Black, Juliet 1.3 test suite: Changes from 1.2, US Department of Commerce, National Institute of Standards and Technology, 2018. doi:10.6028/NIST.TN.1995.
- [173] H. Bojinov, E. Bursztein, X. Boyen, D. Boneh, Kamouflage: Loss-resistant password management, in: Computer Security—ESORICS 2010: 15th European Symposium on Research in Computer Security, Athens, Greece, September 20–22, 2010. Proceedings 15, Springer, 2010, pp. 286–302. doi:10.1007/978-3-642-15497-3\_18.
- [174] A. Narayanan, V. Shmatikov, Fast dictionary attacks on passwords using time-space tradeoff, in: Proceedings of the 12th ACM conference on Computer and communications security, 2005, pp. 364–372. doi:10.1145/1102120.1102168.
- [175] M. Weir, S. Aggarwal, B. De Medeiros, B. Glodek, Password cracking using probabilistic context-free grammars, in: 2009 30th IEEE symposium on security and privacy, IEEE, 2009, pp. 391–405. doi:10.1109/sp.2009.8.
- [176] P. C. Pale, Mastering the Nmap Scripting Engine, Packt Publishing Ltd, 2015.